Hunter 관리자 가이드

버전 1.25.0 · 한국어 · 최종 갱신 2026-09-24

이 문서는 사내 폐쇄망에서 Hunter를 설치하고 인증, 권한, 연동, 진단 정책, AI와 운영 데이터를 관리하는 절차를 설명합니다.

프로젝트 소개 · 사용자 가이드 · HTML · PDF · 전체 화면

> 화면은 실제 애플리케이션을 캡처했습니다. 로그인·OIDC·방문 추적의 변경 장면은 v1.9.0이고, 변경 없는 이전 기능은 v1.8.0의 검증 캡처를 보존했습니다. 예시 자산과 발견 건은 문서용 데이터이며 신규 설치 시 자동 생성되지 않습니다. 아래 제공 범위와 확장 범위를 구분하여 운영하세요. 에이전트 화면은 로컬 SSE 모의 모델과 실제 Hunter UI로 검증한 예시이며 실제 모델 품질·취약점 탐지 성능의 검증 결과가 아닙니다.

1. 아키텍처와 제공 범위

1.1 구성

Hunter 서비스 이미지에는 Go API 서버, React + Mantine 화면, 로컬 UI 자산과 내장 제한 진단 워커가 포함됩니다. PostgreSQL은 조직이 별도 운영합니다. 앱 서버는 8080 포트에서 API와 정적 화면을 함께 제공합니다.

```
사용자 브라우저 → 사내 TLS 프록시 → hunter:v1.25.0 → 사내 PostgreSQL
                                        ├→ 사내 Keycloak (선택)
                                        ├→ 사내 OpenAI 호환 AI (선택)
                                        ├→ 승인된 HTTP 진단 대상
                                        ├→ 등록한 REST·PostgreSQL 연동
                                        └→ 사내 SMTP·메시지·ITSM 게이트웨이 (선택)
외부 진단 엔진 → 승인된 결과 JSON → Hunter 결과 가져오기
개인 API 키 → REST API / MCP → 동일한 권한·진단 정책
```

운영 데이터는 PostgreSQL에 저장합니다. 설정 비밀정보와 증거의 암호화에 `ENCRYPTION_KEY`를 사용하고, 비밀번호는 bcrypt 해시, 개인 API 키는 SHA-256 해시로 보관합니다. 서비스 이미지는 비특권 사용자로 실행하며 Docker 소켓이나 임의 명령 실행 인터페이스를 노출하지 않습니다.

1.2 현재 버전에서 실제 제공하는 기능

영역	제공 내용
자산	서비스 카탈로그, 환경·망·담당자·중요도·관련 대상, 발견 후보
인증	로컬 관리자·사용자, Keycloak OIDC discovery, 세션
권한	역할별 변경 가능한 기능 권한, 사용자·서비스 범위, 개인 키
진단	제한된 HTTP 보안 헤더 검사, 읽기 전용 합성 데이터 권한 비교
통제	서비스 승인, 유효 범위, 요청률·시간·요청 수 제한, 긴급 중지
작업	PostgreSQL 기반 작업 큐, 임대·생존 확인·취소, 변경 이벤트, 주기적 예약, 망별 워커
결과	수동 등록, Nuclei·Trivy·ZAP·SARIF·Gitleaks JSON 수입, 중복 관찰
업무	발견 건 상태, SLA·조치함·암호화 댓글, 사유·만료가 있는 위험 수용, 재검증
자료 반입	KEV·EPSS 기준일과 SHA-256, 운영 위험 점수와 근거

영역	제공 내용
소프트웨어 명세	CycloneDX·SPDX SBOM, 구성요소 영향 서비스·버전 비교·라이선스 검토 표시
캠페인	최대 20개 대상의 원자적·멱등 시작, 동일 조건 내장 완료 결과 비교
운영 점검	DB·큐·워커·긴급 중지·설정 여부·반입 자료 갱신 상태
연동	REST 수집, 읽기 전용 PostgreSQL 수집, 웹훅, API
알림	SMTP·문자·카카오톡·HTTP 채널, 고정·동적 수신자 규칙, 암호화 큐·이력·제한 재시도
자동화	당직·묶음·기한 예고·주간 요약·개인 업무 확인, 전달 결과·대체·보호·모의 검사·보존
변경·ITSM	서명 변경 목록에 따른 검사 선택, 외부 티켓 조회·콜백·로컬 충돌 보호 동기화
관계·보고	등록 데이터 관계 그래프, 위험 현황, JSON·CSV 내보내기
AI	OpenAI 호환·Anthropic·Gemini·Ollama 네이티브, 역할별 대체·한도·완료 답 SSE
선택 연동	검색6종, 임베딩·Graphiti·선택pgvector, mTLS 고정 격리 진단, OTLP/Langfuse
에이전트	PentAGI MIT 코어, Hunter 도구 기반 실행, 추가 입력·일시 중지·명시적 체크포인트 재개·MD/HTML/PDF
개발자 도구	OpenAPI, 개인 Bearer 키의 HTTP MCP, 인증된 조회 GraphQL
참여	발견 건 기여 점수와 집계, 현금 보상 자동 지급 제외

기존 일반 목록·보고서·대시보드·관계 그래프는 접근 가능한 자료를 종류별 생성 시각 기준 최신 5,000건까지 조회·집계하며 그 범위 안에서 목록을 탐색합니다. v1.4 조치함은 현재 접근 가능한 미조치 발견 건에 대해 서버 검색·집계·페이지를 처리하므로 이 한도를 그대로 적용하지 않습니다. 새 SBOM·캠페인도 전용 저장소와 조회 경로를 사용합니다. 서로 다른 화면의 수치를 같은 모집단으로 해석하지 마세요.

1.3 별도 확장이 필요한 영역

같은 서비스 이미지를 워커 전용 모드로 망별 배치할 수 있습니다. 진단 컨테이너를 동적으로 생성하는 실행 플랫폼, 외부 스캐너 바이너리, 브라우저 회귀 테스트 실행기, Kubernetes·DNS·Harbor 전용 discovery 클라이언트는 번들하지 않습니다. 제공된 REST·DB 수집과 API를 사내 시스템에 맞게 연결하는 형태입니다.

전체 소스의 AI 자동 분석, 의미 기반 오탐 확정과 공통 원인 자동 병합, 자동 코드 수정·병합, 메신저 전용 봇, Canary 대규모 배포, 조직 평판·보상 지급, 전체 업무 역할 매트릭스 자동 생성은 후속 확장 영역입니다. 그래프는 등록된 관계를 보여주며 전사 공격 경로를 자동 증명하지 않습니다. 개선 초안은 설정한 외부 REST API로 명시적으로 발송할 수 있습니다.

외부 스캐너·브라우저의 직접 네트워크 통신을 Hunter가 통제한다고 가정해서는 안 됩니다. 해당 도구의 실행 환경, 접근 통제, 오프라인 규칙·취약점 DB 반입과 갱신은 조직에서 별도로 운영합니다.

2. 설치 전 준비

준비 항목	요구 사항
실행 서버	Linux amd64, Docker Engine 및 Compose v2
PostgreSQL	사내 운영 PostgreSQL, Hunter 전용 DB·계정, 스키마 생성·변경 권한
네트워크	Hunter → PostgreSQL 및 선택한 사내 인증·AI·연동 대상
사용자 접속	사내 DNS 이름과 HTTPS 종단 프록시 권장
관리자 정보	초기 관리자 ID, 고유한 12~72바이트 비밀번호
암호화 키	무작위 32바이트의 base64 인코딩 값
반입 파일	릴리즈의 `hunter-v1.25.0.tar.gz`, compose.yaml, .env.example
백업	DB 백업과 암호화 키를 분리하여 안전하게 보관할 위치

서비스 자원은 사용량에 따라 산정합니다. 시작점으로 2 vCPU와 2~4 GiB 메모리를 두고 실제 응답 지연, 연결 수, 진단량에 따라 조정할 수 있으나, 이는 성능 검증 수치나 용량 보장이 아닙니다. 연결한 AI 모델의 메모리·가속기 자원은 Hunter 서버와 별개입니다.

브라우저가 접근하는 주소와 서버가 접근하는 주소를 구분합니다. 컨테이너 안의 `localhost`는 Hunter 컨테이너 자신입니다. 사내 DB 또는 Keycloak 호스트 주소를 사용합니다.

3. 오프라인 배포

3.1 릴리즈 파일 검증과 반입

인터넷이 허용된 구간에서 GitHub 릴리즈의 서비스 이미지 압축 파일을 내려받습니다. 릴리즈 본문에 표시된 SHA-256과 비교한 뒤 조직의 반입 절차를 따릅니다.

```
sha256sum hunter-v1.25.0.tar.gz

gzip --test hunter-v1.25.0.tar.gz
```

첨부 자산은 `hunter-v버전.tar.gz` 한 개이며 내부 이미지 이름은 `hunter:v버전`입니다. PostgreSQL 이미지나 문서 PDF는 릴리즈 첨부 자산에 포함하지 않습니다. GitHub가 자동 표시하는 소스 코드 ZIP·TAR 다운로드는 사용자 첨부 자산과 별개입니다.

3.2 네 가지 환경변수 설정

운영 디렉터리에 `compose.yaml`과 `.env.example`을 복사하고 다음 명령으로 환경 파일을 준비합니다.

```
cp .env.example .env

chmod 600 .env

openssl rand -base64 32
```

생성한 암호화 키를 `.env`에 넣고 다음 네 값을 모두 실제 정보로 바꿉니다. 이 파일을 Git에 커밋하지 않습니다.

```
POSTGRES_DSN=postgres://hunter:URL_ENCODED_PASSWORD@postgres.internal:5432/hunter?sslmode=verify-full

BOOTSTRAP_ADMIN=admin

BOOTSTRAP_ADMIN_PASSWORD=A_UNIQUE_LONG_BOOTSTRAP_PASSWORD

ENCRYPTION_KEY=BASE64_ENCODED_32_RANDOM_BYTES
```

환경변수	의미	운영 시 유의 사항
POSTGRES_DSN	PostgreSQL 연결 문자열	비밀번호의 특수문자는 URL 인코딩, TLS 정책 적용
BOOTSTRAP_ADMIN	처음 생성할 로컬 관리자 아이디	사용자가 전혀 없는 DB에서만 초기 생성
BOOTSTRAP_ADMIN_PASSWORD	초기 관리자 비밀번호	12~72바이트, 기존 계정 비밀번호를 덮어쓰지 않음

환경변수	의미	운영 시 유의 사항
ENCRYPTION_KEY	설정·증거 암호화 키	32바이트 base64, 기존 DB와 같은 키를 유지

런타임 설정용 환경변수는 위 네 가지입니다. 서비스명, 공개 주소, OIDC, AI, 세션, 권한, 연동과 진단 정책은 관리자 화면에서 저장합니다.

암호화 키를 재기동마다 생성하면 안 됩니다. 기존 DB에 다른 키를 제공하면 시작 검증이 실패합니다. 초기 관리자 환경변수를 바꾸는 것으로 기존 관리자 계정을 복구하거나 비밀번호를 바꿀 수 없습니다.

3.3 이미지 불러오기와 실행

```
docker load -i hunter-v1.25.0.tar.gz

docker image inspect hunter:v1.25.0

docker compose up -d

docker compose ps

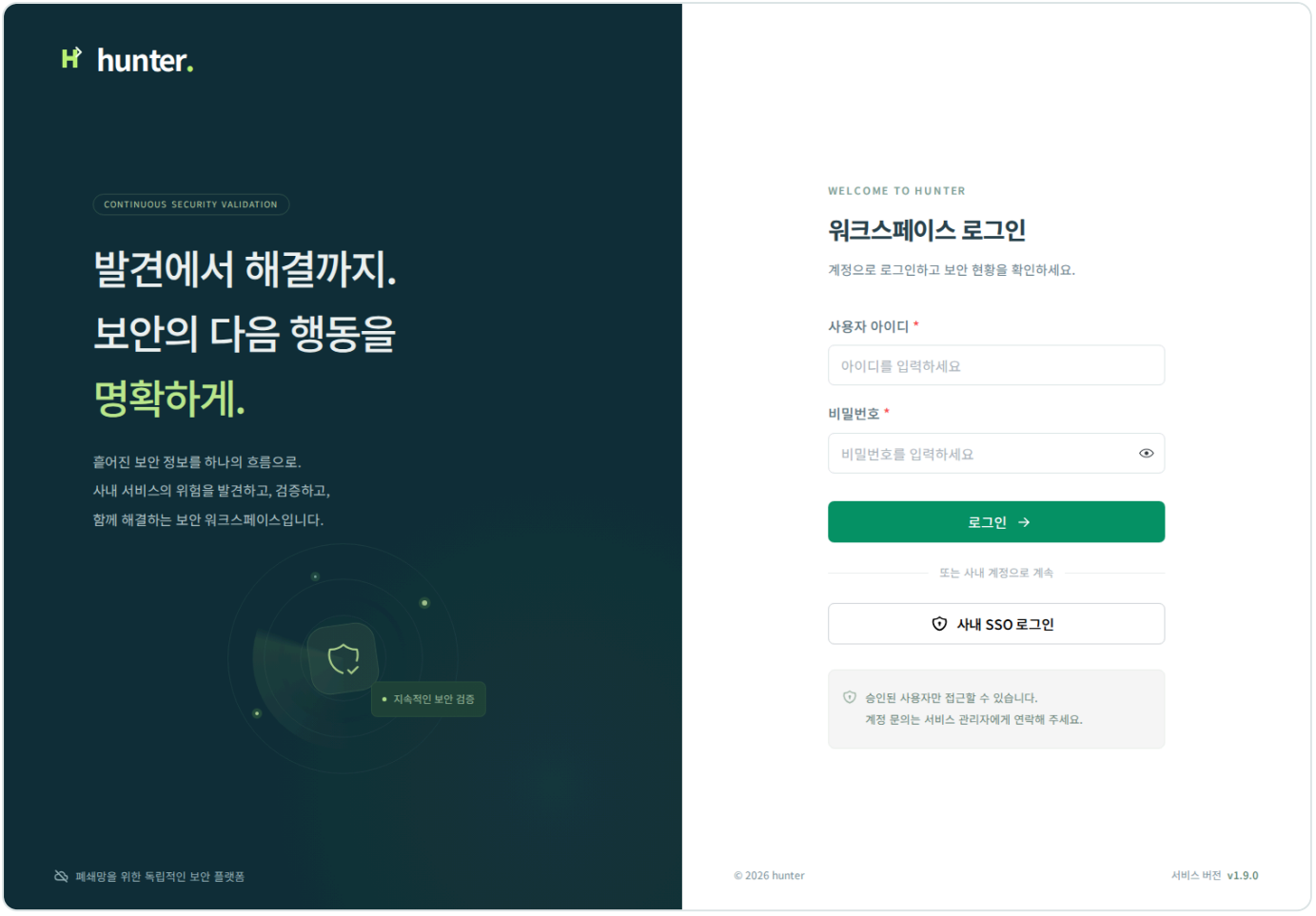
curl --fail http://localhost:8080/api/health
```

정상 상태 응답에는 상태와 버전이 포함됩니다. 오류가 있으면 `docker compose logs --tail=100 hunter`로 원인을 확인합니다. DSN이나 비밀값이 노출된 터미널 기록은 공유하지 마세요.

Compose는 `pull_policy: never`로 자동 이미지 다운로드를 하지 않습니다. 루트 파일시스템은 읽기 전용이고 임시 공간은 제한된 tmpfs입니다. PostgreSQL은 Compose에 포함하지 않습니다.

3.4 최초 로그인

브라우저에서 `http://서버주소:8080` 또는 사내 HTTPS 주소에 접속해 초기 관리자 계정으로 로그인합니다. **개인화 → 내 프로필**에서 초기 비밀번호를 운영 비밀번호로 변경합니다.



다음 순서로 설정하면 연결 오류를 줄일 수 있습니다.

1. 서비스 외부 접근 주소와 서비스 이름
2. 사내 인증서 신뢰 설정과 HTTPS
3. OIDC 연결
4. 역할별 권한과 사용자
5. 서비스·진단 정책·허용 범위
6. 선택적 AI와 사내 자산 연동
7. 필요한 경우 팀장 검토·승인

4. HTTPS와 사내 인증서

사용자 접속은 사내 TLS 프록시에서 HTTPS로 종단하고 Hunter의 8080 포트로 전달합니다. 프록시는 `Host`를 보존하고 AI 스트리밍 응답을 버퍼링하지 않도록 설정합니다. 공개 주소를 실제 HTTPS 주소로 저장하면 보안 쿠키 설정과 OIDC 리다이렉트에 사용됩니다.

Nginx를 사용하는 조직의 예시는 다음과 같습니다. 인증서 경로는 실제 운영 환경에 맞게 지정합니다.

```
server {
    listen 443 ssl;
    server_name hunter.internal;
    ssl_certificate     /etc/nginx/certs/hunter.crt;
    ssl_certificate_key /etc/nginx/certs/hunter.key;

    location / {
        proxy_pass http://hunter:8080;
        proxy_set_header Host $host;
        proxy_set_header X-Forwarded-Proto https;
        proxy_buffering off;
        proxy_read_timeout 600s;
        client_max_body_size 10m;
    }
}
```

네트워크 구성에 따라 `hunter:8080`은 실제 백엔드 주소로 변경합니다. 임의 외부 호스트의 forwarded 헤더를 신뢰하는 구성을 피하고 프록시 접근 경로를 통제합니다.

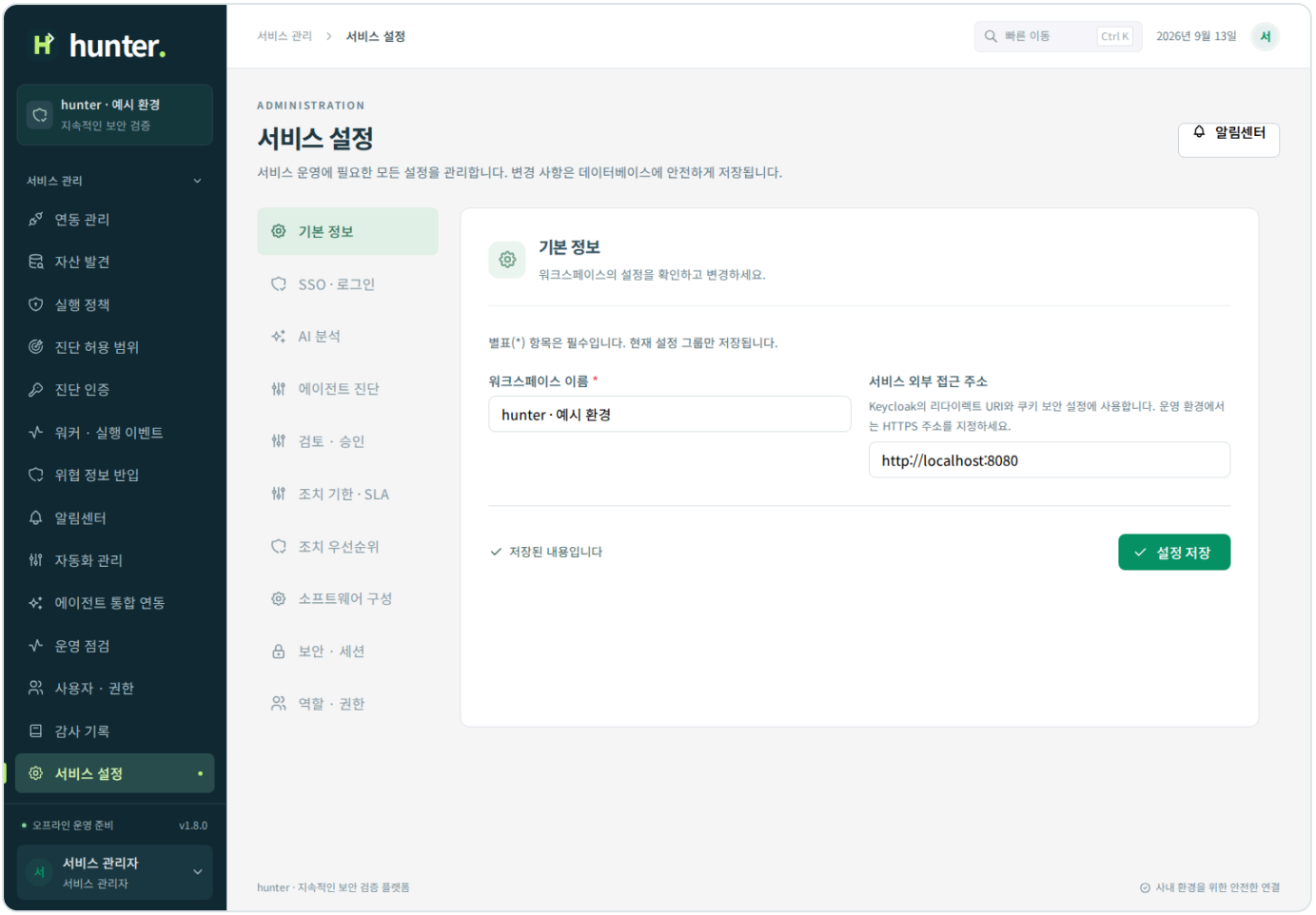
서비스에서 접근하는 사내 HTTPS 대상이 사설 CA를 사용하면 **서비스 설정 → 보안·세션 → 신뢰 CA**에 PEM 인증서를 등록합니다. 이 설정은 적용된 사내 HTTP 클라이언트와 알림 SMTP의 신뢰 확장에 사용됩니다. 서버 자신의 HTTPS 인증서나 PostgreSQL 드라이버의 TLS 루트 인증서 설정과는 별개입니다.

PostgreSQL TLS는 DSN의 `sslmode=verify-full`과 `sslrootcert=/경로/ca.pem` 등을 통해 구성합니다. 필요하면 CA 파일을 읽기 전용으로 마운트합니다. TLS 검증을 끄는 방식으로 인증서 문제를 우회하지 않습니다.

5. 서비스 전체 설정

관리자 → 서비스 설정에서 그룹별로 값을 저장합니다. 설정은 DB에 보관되며 일반적인 변경에 재배포가 필요하지 않습니다.

알림 채널·발송 규칙·이력은 **알림센터**, 연락처·당직·전달 결과·변경/ITSM·보존 정책은 **자동화 관리**에서 관리하며 같은 DB와 관리자 권한을 사용합니다.



설정 그룹	주요 내용
기본 정보	서비스 이름, 외부 접근 주소
SSO·로그인	OIDC 활성화·기존 세션 자동 진입, Issuer, Client ID, Client Secret, 신규 계정 역할
MCP·SSO 연결	개인 키 없이 Keycloak 액세스 토큰으로 `/mcp` 연결 허용 (`mcp.oauth.*`) — 기본 꺼짐, § 15.6
방문 추적	사용 여부·공개 코드·허용 원점과 저장 전 격리 미리보기
다른 서비스로 보내기	실행 보고서를 받아 갈 수 있는 사내 서비스의 허용 목록 (`handoff.targets`) — 기본은 비어 있음
AI 분석	활성화, Base URL, API 키, 모델, 최대 출력 토큰, 컨텍스트 창
에이전트 진단	활성화, 반복·모델·도구 한도, 제한 시간, 진단·후보·기억 허용
검토·승인	팀장 검토·승인 흐름 활성화

설정 그룹	주요 내용
보안·세션	새 세션 유효 시간, 개인 키 최대 수명, 사내 신뢰 CA
역할·권한	팀장·분석가·열람자별 기능 권한
조치 기한(SLA)	활성화, 심각도별 일수, 임박 기준
위험 우선순위	KEV 가산, EPSS 임계·가산, 자료 노후화 기준
소프트웨어 명세	SBOM 갱신 기준, 검토할 라이선스 식별자 목록

5.1 입력과 저장 상태 확인

별표(*)가 붙은 항목은 필수이며 **설정 저장**은 현재 그룹에만 적용됩니다. 폼 아래에 `저장된 내용입니다`, `저장하지 않은 변경 사항이 있습니다`, `저장 중입니다…`, 저장 완료 시각을 표시합니다. 값이 달라진 그룹은 설정 메뉴에서도 표시합니다.

필수값이나 URL·숫자 등의 형식이 잘못되면 폼 위의 오류 요약과 해당 입력 옆의 메시지를 확인합니다. 요약의 링크를 선택하면 문제가 있는 입력으로 이동합니다. 서버 저장 실패도 폼 안에 표시하며 입력값은 남아 있으므로 원인을 수정한 뒤 다시 저장할 수 있습니다. 성공 표시가 나타나기 전에 저장 완료로 판단하지 마세요.

5.2 저장하지 않은 설정 그룹 이동

현재 그룹을 변경한 상태에서 다른 설정 그룹을 선택하면 다음 중 하나를 고릅니다.

- **계속 수정**: 현재 그룹으로 돌아가 입력을 계속합니다.
- **입력 유지하고 이동**: 현재 입력을 저장하지 않고 화면에 보관한 채 다른 그룹을 확인합니다. 같은 설정 화면 안에서 돌아오면 입력을 이어갈 수 있습니다.
- **저장 후 이동**: 현재 그룹을 저장한 뒤 선택한 그룹으로 이동합니다. 저장에 실패하면 오류를 해결해야 합니다.

이 보관은 자동 저장이나 장기 초안 저장이 아닙니다. 브라우저 새로고침·탭 닫기에는 브라우저가 제공하는 미저장 경고가 표시될 수 있지만, 브라우저 정책과 사용자 조작에 따라 경고가 생략될 수 있습니다. 다른 업무 페이지로 떠나기 전에는 변경한 각 그룹을 직접 저장하세요.

관리 목록에는 상단 결과 수·적용 조건별 해제·저장 보기·표 표시 설정을 제공합니다. 저장 보기와 행 간격은 **현재 브라우저의 사용자·메뉴별 설정**이며 관리자가 조직 전체 설정을 바꾸는 기능과 다릅니다. 보기 적용 시 첫 페이지부터 표시하며, 이름·조회 조건만 저장하고 현재 계정의 권한을 그대로 적용합니다. 자세한 절차는 사용자 가이드를 참고하세요.

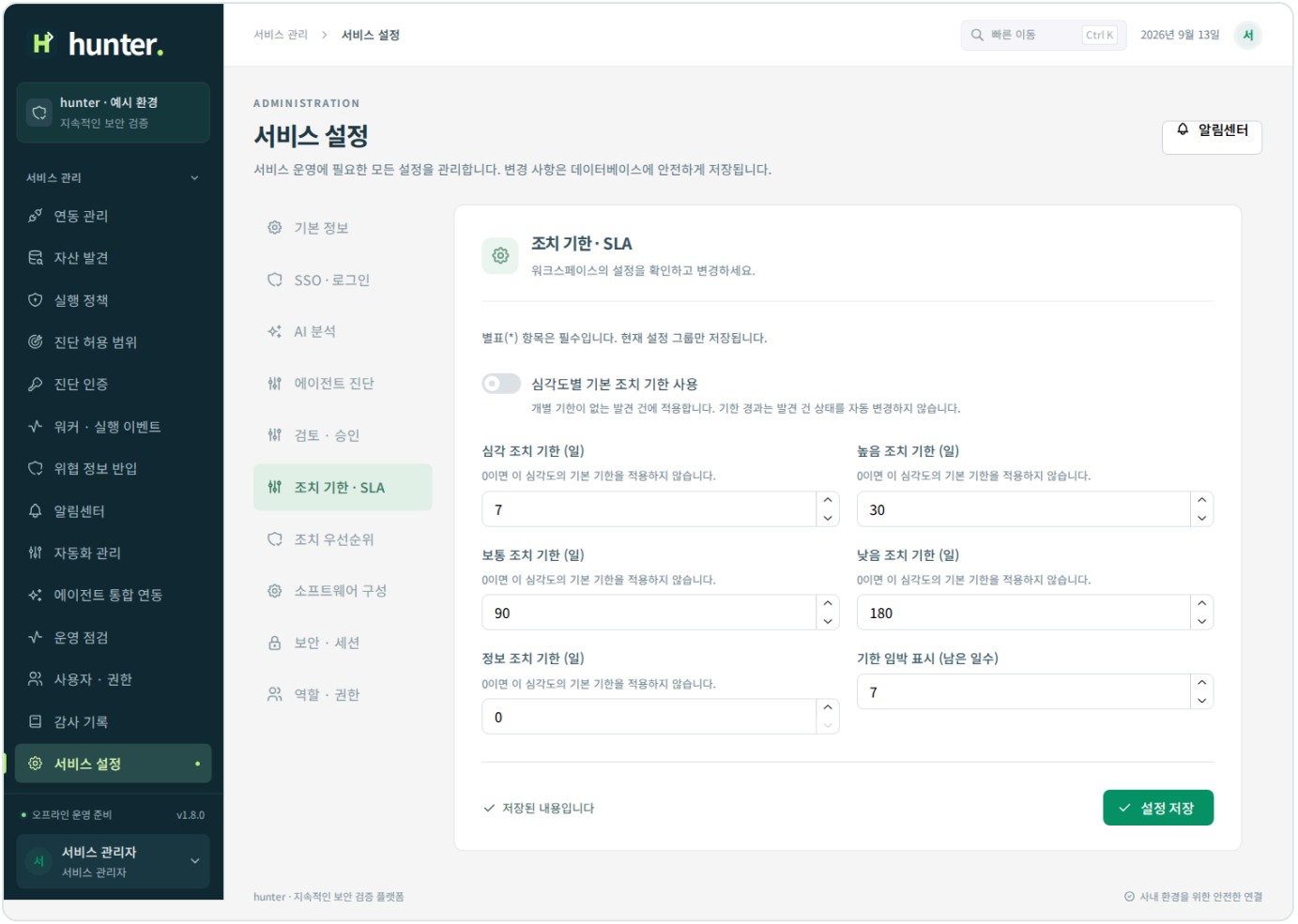
비밀 설정은 조회할 때 원문을 반환하지 않습니다. 저장됨 표시로 여부를 확인하며 빈 입력은 기존 값을 유지합니다. API에서 명시적인 비밀 삭제 옵션을 제공하는 경우에만 삭제됩니다. 설정 화면의 일반 텍스트에 비밀번호를 넣지 않습니다. 설정·비밀번호 폼의 미저장 비밀값은 현재 화면의 메모리 초안이며 브라우저 저장 보기에 넣지 않습니다. 성공적으로 제출한 비밀 입력은 화면에서 비웁니다.

5.3 SLA 조치 기한 정책

SLA는 기본 비활성화입니다. 관리자 설정의 조치 기한 그룹에서 활성화한 뒤 심각도별 일수와 임박 기준을 저장합니다. 기본값은 심각 7일, 높음 30일, 보통 90일, 낮음 180일, 정보 0일과 임박 7일입니다. 0일은 해당 심각도의 자동 기한을 두지 않습니다.

수동 `due_date`가 있으면 이를 우선합니다. 그렇지 않으면 발견 건 생성 시각에 설정 일수를 더한 기한을 조회 시 계산합니다. 정책 변경은 계산 기한에 즉시 반영되며 수동 기한이나 최초 생성 시각을 덮어쓰지 않습니다. 날짜는 시간대를 포함하는 RFC3339 형식입니다. 영업일 달력·공휴일 제외·휴무 조직별 계산은 현재 범위에 없습니다.

조치함은 해결·오탐·유효한 위험 수용을 제외하고 임박·초과·미배정 건을 구분합니다. 위험 수용이 만료된 건은 현재 상태 정리 작업 전에라도 포함합니다. 정책을 정하기 전 조직의 조치 담당자와 기준일·예외 처리 방식을 합의하고, 기한 변경 사유는 발견 건 댓글에 남깁니다.



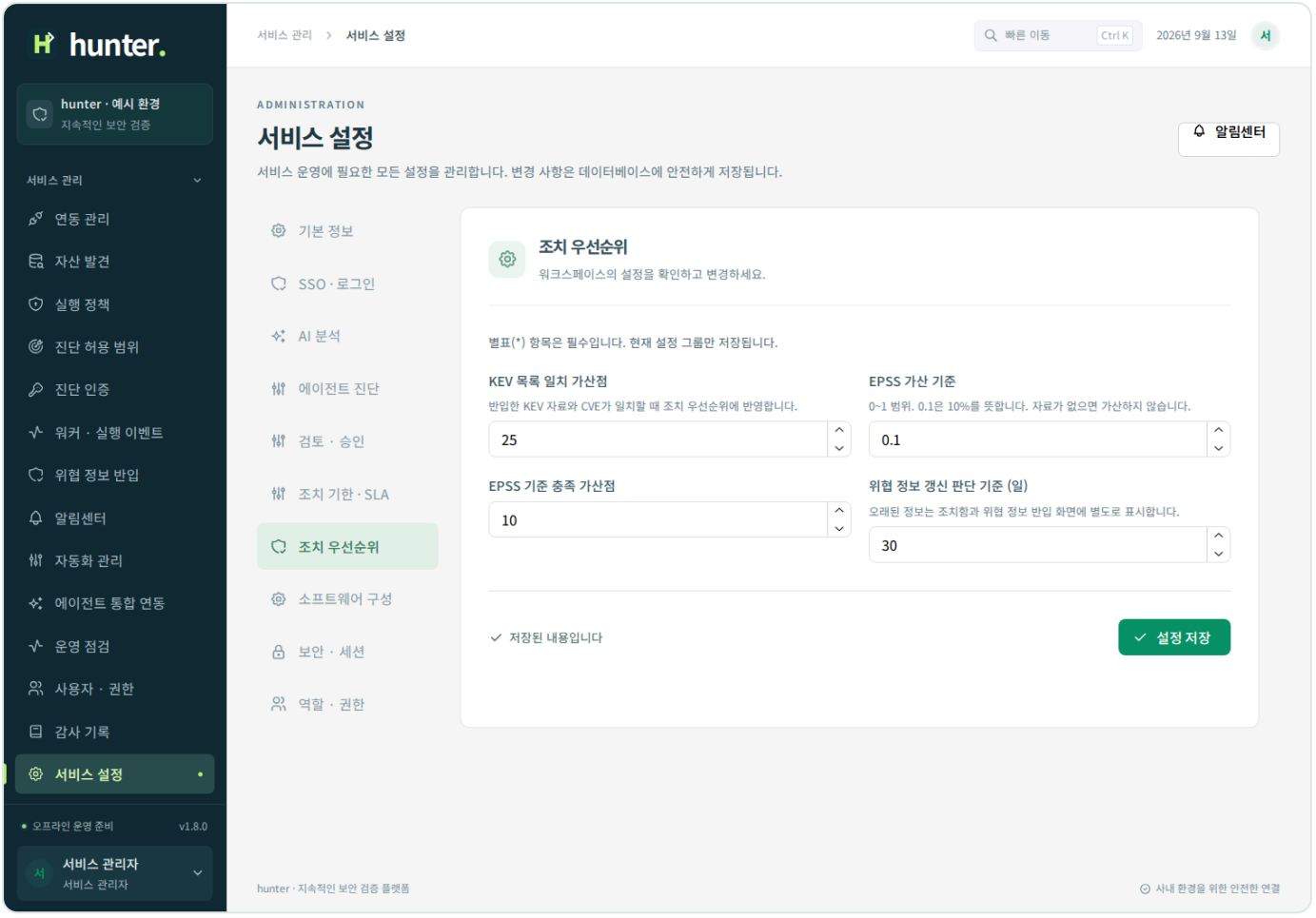
5.4 위험 점수와 자료 노후화

현재 운영 우선순위 방식은 `hunter-priority-v1`입니다. 기술적 심각도 기본점수는 심각/높음/보통/낮음/정보 순서로 70/50/30/10/0이고, 서비스 중요도 Tier 1/2/3/4 가산은 15/10/5/0입니다. 여기에 KEV와 EPSS 가산을 더하며 상한은 100점입니다.

설정	기본값	의미
KEV 가산	25	반입 목록에 해당 CVE가 있는 경우

설정	기본값	의미
EPSS 임계	0.1	이 값 이상인 유효 EPSS에 가산
EPSS 가산	10	기준을 넘는 EPSS의 가산점
자료 노후화	30일	기준일이 지나면 오래된 자료로 표시

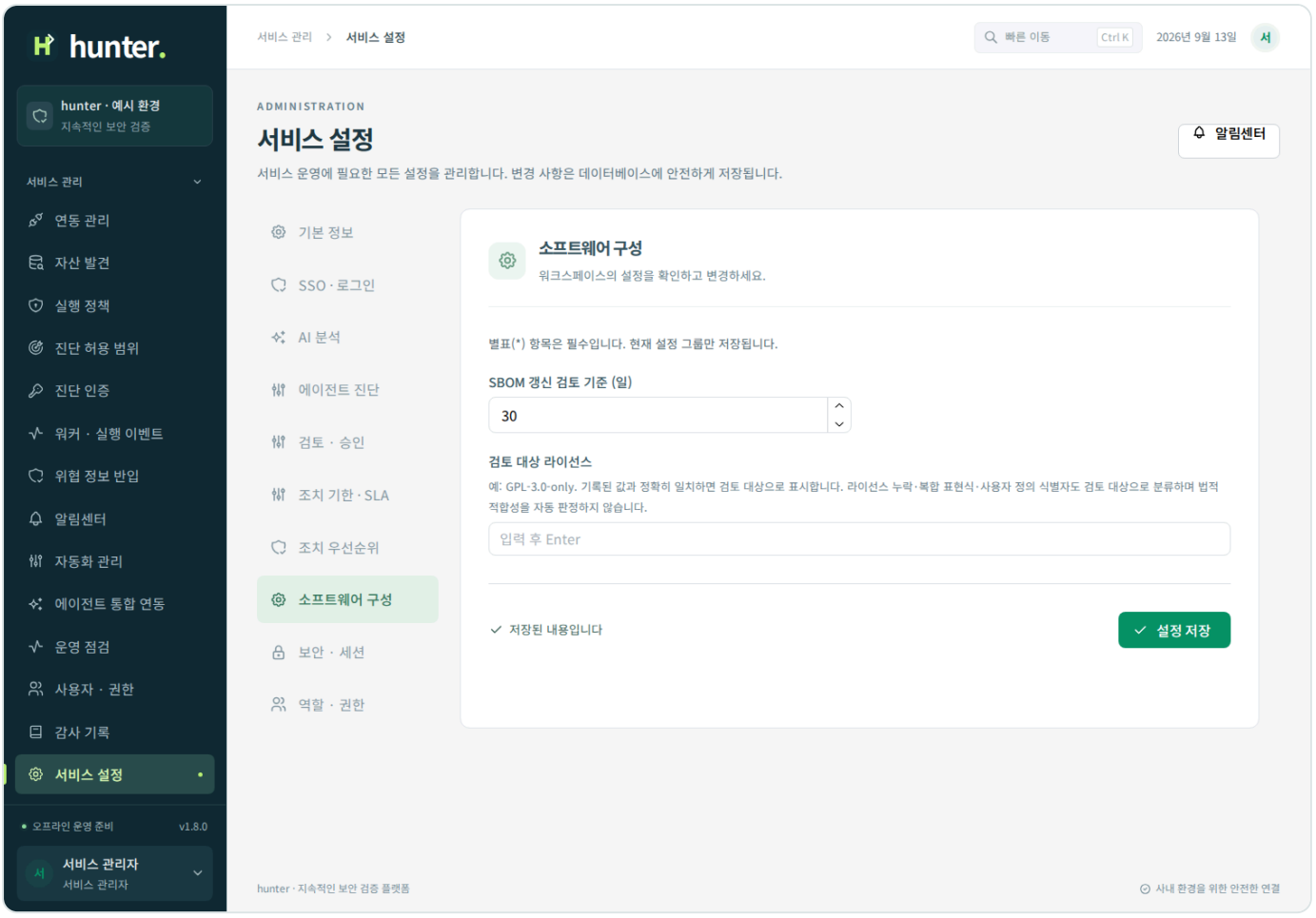
EPSS가 없거나 오래되었으면 가산하지 않습니다. 오래된 KEV의 포함 사실은 과거 악용 근거로 유지하므로 가산하되 기준일 경고를 함께 표시합니다. 점수가 바뀌어도 심각도·상태·서비스 승인·진단 권한은 변경되지 않습니다. 이 점수는 침해 확률, CVSS 또는 공식 인증 지표가 아닙니다.



5.5 SBOM 갱신과 라이선스 검토 규칙

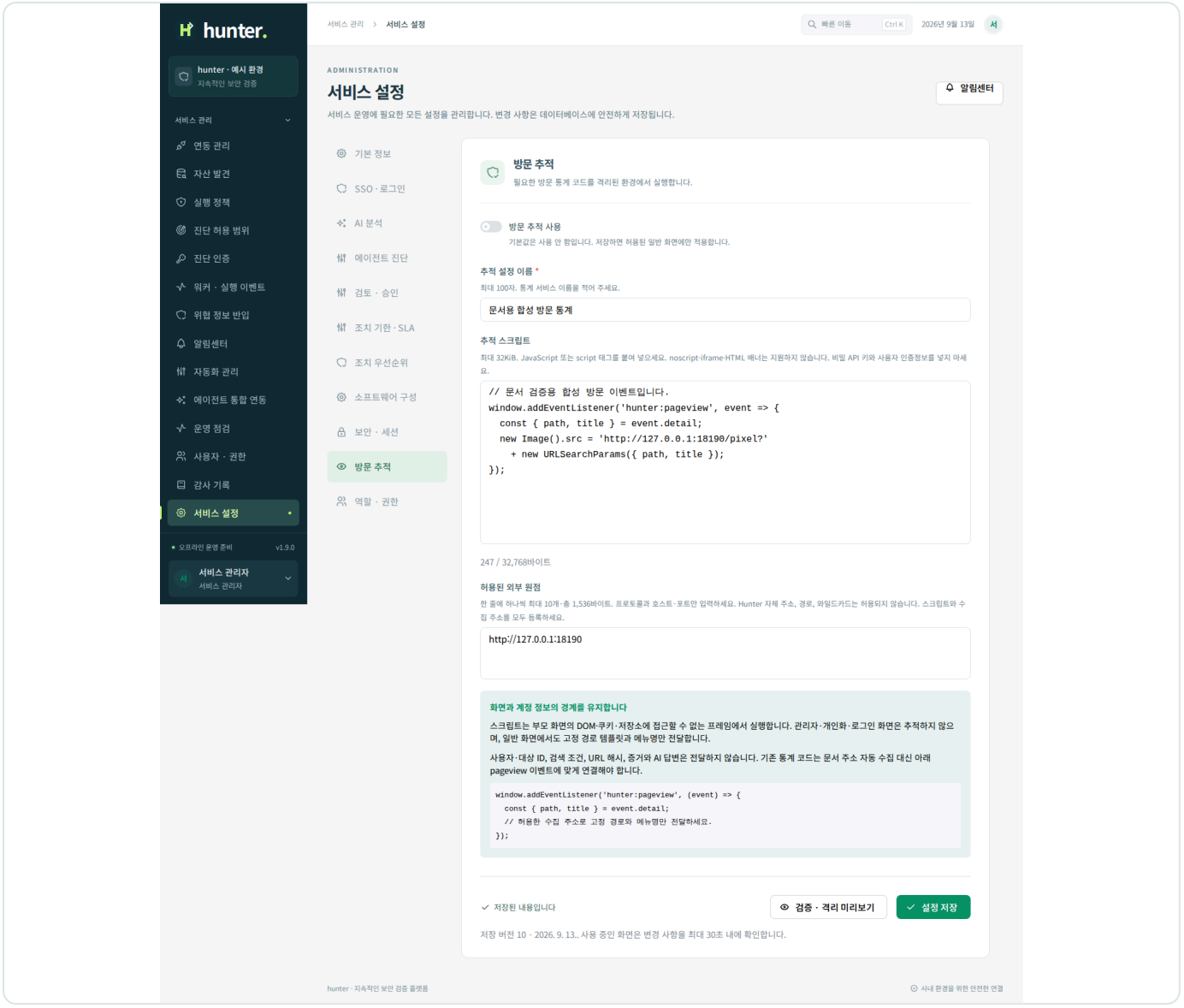
소프트웨어 명세 설정에서 갱신 기준일(기본 30일, 1~3650일)과 검토 라이선스 목록(최대 100개)을 관리합니다. 갱신 기준은 Hunter에 마지막으로 반입한 시각에 적용하며 실제 배포 시각이나 공급자 갱신을 자동 확인하지 않습니다.

검토 목록의 식별자에 해당하거나 라이선스가 없고, `NOASSERTION` · `NONE` · `LicenseRef-` ·복합 표현식 등에 해당하면 검토 필요를 표시합니다. 일반 식별자의 완전한 SPDX 유효성 검사, AND/OR/WITH 표현식의 법률적 평가, 라이선스 승인 워크플로는 제공하지 않습니다. 목록 미해당을 재배포 허용으로 해석하지 마세요.

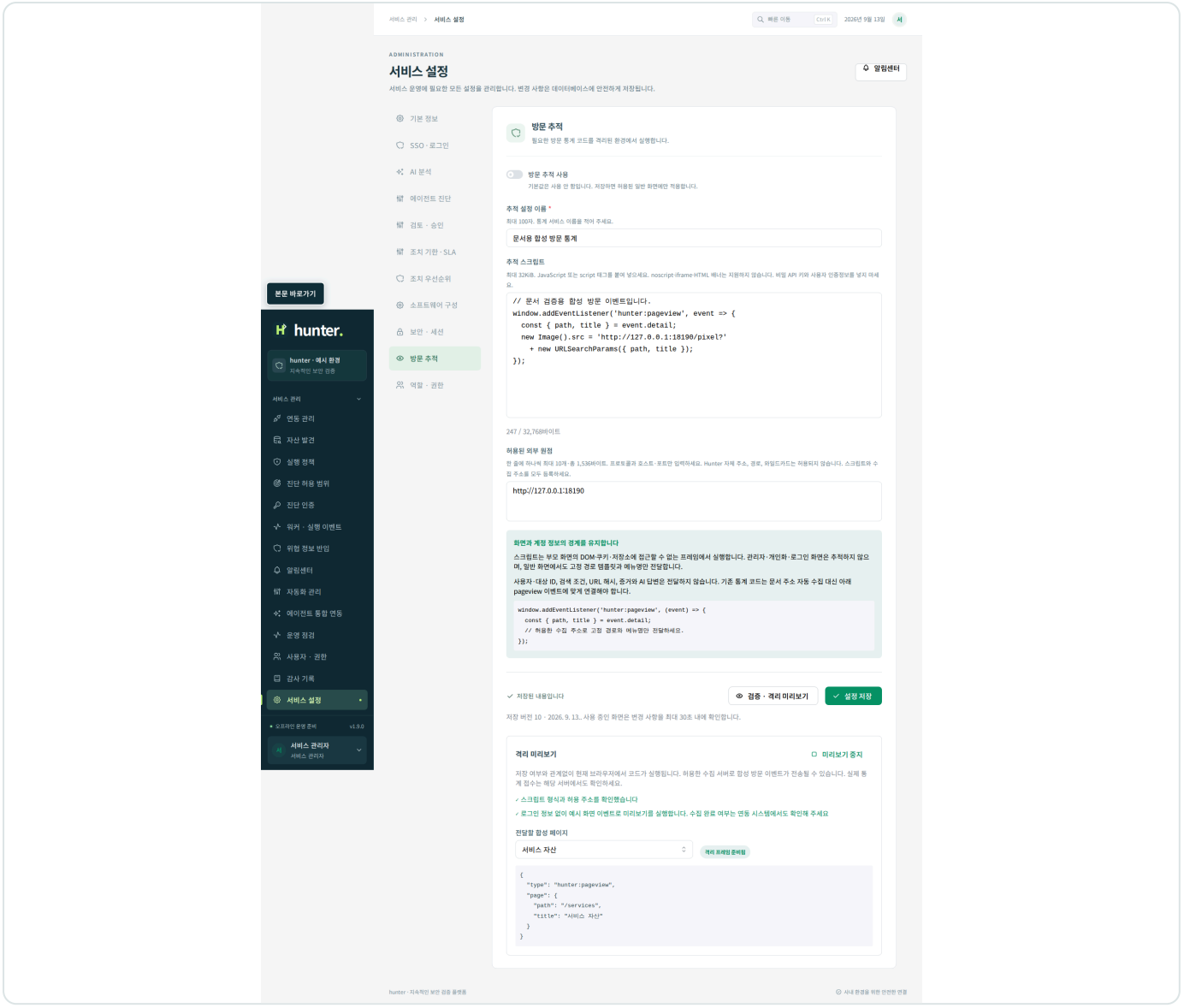


5.6 방문 추적 코드 설정

서비스 설정 → 방문 추적에서 사용 여부, 이름, 공개 스크립트와 허용 원점을 관리합니다. 기본값은 사용 안 함입니다. 별도 환경변수나 재배포 없이 같은 PostgreSQL에 설정을 암호화 저장합니다. 이 기능은 **관리자 브라우저 세션**이 필요하며 개인 API 키로 관리하거나 미리보기를 실행할 수 없습니다.



1. 수집 시스템에서 사용할 **공개 코드**를 준비합니다. 비밀 API 키·사용자 인증정보를 브라우저 코드에 넣지 않습니다.
2. 이름을 1~100자로 입력하고 JavaScript 또는 script 태그를 붙여 넣습니다. 전체 코드는 유효 UTF-8 **32KiB**, HTML 형식의 script 태그는 **최대 10개**입니다. 임의 HTML, noscript, iframe, meta 태그와 배너는 지원하지 않습니다.
3. **허용된 외부 원점**에 필요한 정확한 원점을 한 줄씩 최대 10개 입력합니다. 예: `https://stats.internal`, `https://assets.internal:8443`. 경로·쿼리·와일드카드·자격정보는 제외합니다. 각 원점 입력은 300바이트, 정규화 후 전체 허용 원점은 1536바이트 이하입니다. 호스트 최대253바이트·DNS 라벨 최대63바이트를 검사하고 국제 도메인 이름은 IDNA로 정규화합니다. 현재 요청 주소 또는 기본 정보에 등록한 Hunter 자체 원점은 허용할 수 없습니다.
4. **검증 · 격리 미리보기**로 현재 초안을 검사합니다. 설정을 저장하거나 운영 추적을 켜지 않지만, 브라우저는 코드를 실제 실행하여 허용한 수집기에 합성 방문 이벤트를 보낼 수 있습니다. 조직에서 승인한 시험 수집기를 사용합니다.
5. 문법·원점·연결 결과를 확인하고 수집기에서도 시험 이벤트를 확인합니다. **준비 완료**는 인라인 실행 또는 외부 코드 로드 후 bridge가 준비됐다는 뜻이며 실제 통계 접수·분석 완료를 보장하지 않습니다.
6. 검토한 뒤 사용 여부를 켜고 저장합니다. 현재 브라우저는 변경을 알리고, 다른 사용 중인 활성 화면은 최대 30초 주기로 설정을 다시 확인합니다. 비활성 탭의 즉각 반영을 보장하지 않습니다.



기본 페이지 이벤트는 `hunter:pageview`입니다. 다음 예제는 `https://stats.internal`을 허용 주소에 추가한 경우의 사내 수집기 어댑터입니다. 서버는 `text/plain` 본문의 JSON을 처리하도록 준비합니다. `no-cors` 응답은 브라우저에서 접수 본문을 읽을 수 없으므로 수집 시스템 측 확인이 필요합니다.

```
window.addEventListener('hunter:pageview', (event) => {
  fetch('https://stats.internal/collect', {
    method: 'POST',
    mode: 'no-cors',
    credentials: 'omit',
    headers: { 'Content-Type': 'text/plain' },
    body: JSON.stringify(event.detail)
  });
});
```

전달하는 자료는 `{path, title}` 뿐입니다. 일반 메뉴와 `/agents/:id`·`/software/:id`·`/campaigns/:id` 같은 고정 상세 템플릿을 사용하고 실제 자료 ID·쿼리·해시·사용자 식별자·발견 증거·AI 대화는 넣지 않습니다. 로그인·관리자·개인화 페이지는 제외합니다. 수집기는 HTTP 연결의 IP·User-Agent 등 브라우저 기본 정보를 별도로 관측할 수 있으므로 이를 개인정보 전송이 전혀 없는 기능으로 설명하지 않습니다.

격리와 호환 범위: 코드는 별도 CSP `sandbox allow-scripts` 프레임에서 실행하며 Hunter 쿠키·localStorage·부모 DOM에 접근할 수 없습니다. `eval`, iframe, worker, 폼 제출, 새 창·상위 화면 이동 권한을 부여하지 않습니다. 스크립트 로드·연결·이미지는 지정한 원점으로 제한합니다. 사용자·DOM 자동 수집, 쿠키 또는 저장소를 전제로 한 범용 분석 SDK는 그대로 동작하지 않을 수 있으므로 위 페이지 이벤트용 어댑터로 연결합니다. 서버는 JavaScript 문법 전체를 정적 검증하지 않으므로 실제 브라우저 미리보기로 확인합니다.

콘텐츠 보안 정책(CSP)과 차단된 출처: Hunter 화면 자체의 정책은 `script-src 'self'`이며 추적 코드를 위해 `'unsafe-inline'`이나 nonce를 더하지 않습니다. 코드는 요청마다 별도로 만드는 격리 프레임 안에서만 실행되고, 그 프레임의 정책은 추적이 켜진 동안에만 존재하며 `script-src`·`connect-src`·`img-src`를 **허용된 외부 원점**으로 제한합니다. 추적을 끄면 프레임이 사라지므로 정책은 원래대로 좁아집니다. 허용 원점에 없는 주소로 스크립트 로드·요청·이미지를 시도하면 브라우저가 조용히 차단하는데, 이때 프레임이 `securitypolicyviolation` 이벤트의 **출처와 지시어**를 로그인한 부모 화면에 전달하고, 부모 화면이 세션·CSRF 검사를 거친 `POST /api/tracking/violations`로 서버에 대신 신고합니다(격리 프레임은 불투명 출처라 `report-uri`에 세션이 실리지 않습니다). 서버는 http(s) 출처만 정규화해 **이 인스턴스의 메모리**에 출처·지시어별 최대 100개(가장 오래된 항목부터 축출)를 보관하며, 경로·쿼리·실제 문서 주소는 저장하지 않고 재시작하면 사라집니다. 설정 화면 아래 **보안 정책에서 차단된 출처** 패널에서 목록을 새로 고치고, **허용 목록에 추가**를 누르면 해당 원점이 허용 원점 입력에 채워지므로 검토한 뒤 저장합니다. 격리 미리보기 중 차단된 출처도 같은 방식으로 경고 안에 표시됩니다. 이 목록은 로그인한 사용자 브라우저가 보낸 값이므로 수집기 주소가 맞는지 확인한 뒤 허용하고, `inline`·`eval`·`data:`·`blob:` 차단은 허용 대상이 아니라 기록하지 않습니다. 기록은 감사 로그가 아니며 **기록 지우기**만 감사 사건(`tracking.violations.clear`)으로 남습니다. 추적이 꺼져 있으면 관리자 미리보기만 신고할 수 있습니다.

저장 충돌과 복구: GET으로 받은 숫자 `revision`을 PUT에 전달하며 다른 관리자가 먼저 저장하면 409로 거부합니다. 화면에서 내 입력을 유지한 채 최신 자료를 확인하고 다시 검토합니다. 여기서는 `expected_updated_at`을 사용하지 않습니다. 미리보기는 현재 관리자 전용·5분·한 번 사용이며 새 시험은 그 관리자의 이전 미사용 미리보기를 대체합니다. 만료·소비 후 다시 시작할 수 있습니다. 코드가 차단되거나 로드에 실패하면 허용 원점·HTTPS 혼합 콘텐츠·수집기 CORS·코드 문법을 확인합니다. `Origin: null`의 격리 환경을 고려하되 비밀을 사용하는 인증 API의 CORS를 광범위하게 열어 우회하지 않습니다.

API	동작
`GET /api/admin/tracking`	현재 설정·revision 조회, 관리자 세션 전용
`PUT /api/admin/tracking`	전체 공개 코드·허용 원점·사용 여부 저장, revision 비교
`POST /api/admin/tracking/test`	5분·1회용 초안 미리보기 발급, 운영 설정 변경 없음
`GET /api/tracking/config`	로그인 브라우저의 활성 여부·현재 프레임 주소
`GET /api/tracking/frame?revision=N`	현재 버전의 격리 HTML, 비활성 404·버전 충돌 409
`GET /api/tracking/preview/{token}`	현재 관리자 토큰을 원자적으로 소비하고 초안 실행
`POST /api/tracking/violations`	로그인 화면이 프레임의 정책 차단(출처·지시어·고정 경로)을 대신 신고, 최대 100건
`GET /api/admin/tracking/violations`	인스턴스 메모리의 차단 출처 목록(최근 순, 허용 여부 포함)
`DELETE /api/admin/tracking/violations`	차단 출처 기록 지우기, 감사 사건 기록

자세한 규격과 공개 자료의 근거는 SSO·방문 추적 조사를 참고하세요.

5.7 다른 서비스로 보내기 허용 목록

생각은 umm 의 캔버스에서 시작해 muni 의 문서가 되고 ptium 의 슬라이드가 되어 weekly 의 보고로 들어갑니다. 형식은 이미 맞았지만 단계마다 사람이 파일을 내려받아 다시 올리는 손이 남아 있었습니다. Hunter 는 사내 문서 넘기기 표준(`HANDOFF-STANDARD.md`)의 **보내는 쪽**이며, 보내는 것은 **에이전트 실행 보고서의 Markdown** 하나입니다. 받는 쪽은 만들지 않습니다 — Hunter 가 들이는 진단 결과·SBOM 은 이 표준의 형식 표에 없는 형식입니다.

어떻게 넘어가는가

1. 사용자가 실행 상세의 **실행 보고서** 메뉴에서 **다른 서비스로 보내기 → (서비스 이름)** 을 고릅니다.
2. Hunter 가 그 순간의 Markdown 보고서(다운로드와 같은 본문·같은 권한 검사)를 만들고 `POST /api/v1/handoff/claims` 로 **표(claim)** 를 발급합니다 — 256비트 난수, **5분**, **한 번**만 쓸 수 있고, 그 사용자가 읽을 수 있는 그 실행 하나에만 묶입니다.
3. 브라우저가 새 창에서 받는 서비스의 `https://<서비스>/handoff?source=<Hunter 주소>&claim=<표>` 를 엽니다. 새 창은 opener 가 끊긴 상태로 열립니다.
4. 받는 서비스가 `GET <Hunter 주소>/api/v1/handoff/claims/<표>` 로 문서를 받아 갑니다. 로그인은 없습니다 — 표가 곧 자격입니다. 받아 가는 순간 표는 지워지고, 두 번째 요청·만료된 표·발급된 적 없는 표는 모두 같은 `404` 로 답하며 이유를 구별해 주지 않습니다.

문서는 표를 발급하는 순간 만들어 암호화해 표와 함께 저장하므로(`handoff_claims`, 표는 SHA-256 다이제스트로만 저장) 받는 쪽이 가져가는 바이트는 표가 알린 `bytes` 그대로입니다. 만료된 행은 다음 표를 발급할 때 정리됩니다. 사용자당 아직 쓰지 않은(만료 전·미수령) 표는 **20개**까지이며, 초과하면 `POST /api/v1/handoff/claims` 가 `429` 로 거절하고 행·감사 기록을 남기지 않습니다 — 표 하나를 받아 가거나 만료되면 다시 발급됩니다. 감사 기록(`agent.handoff`)에는 실행 ID·바이트 수만 남고 표는 남지 않으며, 오류 로그도 이 경로를 `/api/v1/handoff/claims/{claim}` 으로만 적습니다.

`source` 는 **기본 정보 → 서비스 외부 접근 주소**의 오리진입니다. 받는 쪽은 이 값을 자기 허용 목록과 대조하므로 그쪽 목록의 표기와 스킴·호스트·포트가 정확히 같아야 합니다.

허용 목록 설정

관리자 → 서비스 설정 → **다른 서비스로 보내기**. 기본값은 **비어 있고**, 그때는 실행 상세의 보고서 메뉴에 보내기 항목이 나타나지 않으며 `POST /api/v1/handoff/claims` 도 `404` 로 거절합니다 — 새로 설치한 곳에서는 아무것도 달라지지 않습니다.

항목	뜻
이름	메뉴에 보이는 이름(1~60자). 예: `Ptium`
주소 (오리진)	`https://ptium.intra` 처럼 **스킴과 호스트(포트)까지만**. 경로·쿼리·자격 증명·와일드카드가 있으면 저장되지 않습니다. 같은 주소를 두 번 적을 수 없습니다.
그 서비스가 받는 형식	표준의 형식 표에 있는 말(`markdown` `docx` `csv` `xlsx` `txt` `pptx`) 중 하나 이상. Hunter 는 `markdown` 만 보내므로 **`markdown` 이 없는 항목은 저장되어도 메뉴에 오르지 않습니다.**

표준의 형식 표대로면 `muni` · `ptium` · `weekly` 가 `markdown` 을 받습니다. `kanpic` 은 받지 않으므로 적어도 메뉴에 나오지 않습니다. 목록은 20개까지입니다.

API 로는 `PUT /api/settings/handoff` 에 아래 모양을 보냅니다(관리자 권한, 브라우저 세션이면 `X-Hunter-CSRF: 1`).

```
{"targets": [
  {"name": "Ptium",  "origin": "https://ptium.intra",  "formats": ["markdown", "docx", "csv", "xlsx",
"txt"]},
  {"name": "Weekly", "origin": "https://weekly.intra", "formats": ["markdown", "docx", "pptx"]}
]}
```

받는 쪽에 알려 줄 것

받는 서비스의 관리자는 자기 허용 목록에 Hunter 의 오리진(위 `source`)을 적어야 합니다. 그쪽 목록에 없으면 받는 서비스는 Hunter 에 아무 요청도 보내지 않고 거절합니다 — 그것이 표준입니다.

확인 절차

1. 목록이 비어 있을 때 실행 상세의 **실행 보고서** 메뉴에 **다른 서비스로 보내기**가 없는지 봅니다.
2. 서비스를 하나 적고 저장한 뒤 메뉴에 그 이름이 나오는지, 고르면 새 창에 받는 서비스의 `/handoff?source=…&claim=…` 가 열리는지 봅니다. 팝업이 막히면 화면이 그렇게 말합니다.

3. 감사 기록에서 `agent.handoff` 사건에 실행 ID·바이트 수만 있고 표가 없는지 봅니다.

4. 같은 표로 두 번 받으면(`curl -i <Hunter 주소>/api/v1/handoff/claims/<표>`) 두 번째는 `404` 입니다.

경로	역할
`GET /api/handoff/targets`	`markdown` 을 받는 보낼 곳 목록과 `source` , 에이전트 조회 권한
`POST /api/v1/handoff/claims`	`{"resource": "<실행 ID>", "format": "markdown"}` → `201` 표 발급, 보낼 곳 미설정·접근 불가 실행 `404` , 사용자당 미사용 표 20개 초과 `429`
`GET /api/v1/handoff/claims/{claim}`	로그인 없이 표로 한 번 받아 가기, 그 외 모두 `404`
`PUT /api/settings/handoff`	허용 목록 저장, 관리자 권한

6. Keycloak·OIDC SSO

6.1 Keycloak 클라이언트 준비

조직의 Keycloak realm에서 OpenID Connect 클라이언트를 생성합니다.

Keycloak 항목	설정 예시
Client ID	hunter
Client authentication	활성화
Standard flow	활성화
Valid redirect URIs	https://hunter.internal/api/auth/oidc/callback
Web origins	https://hunter.internal

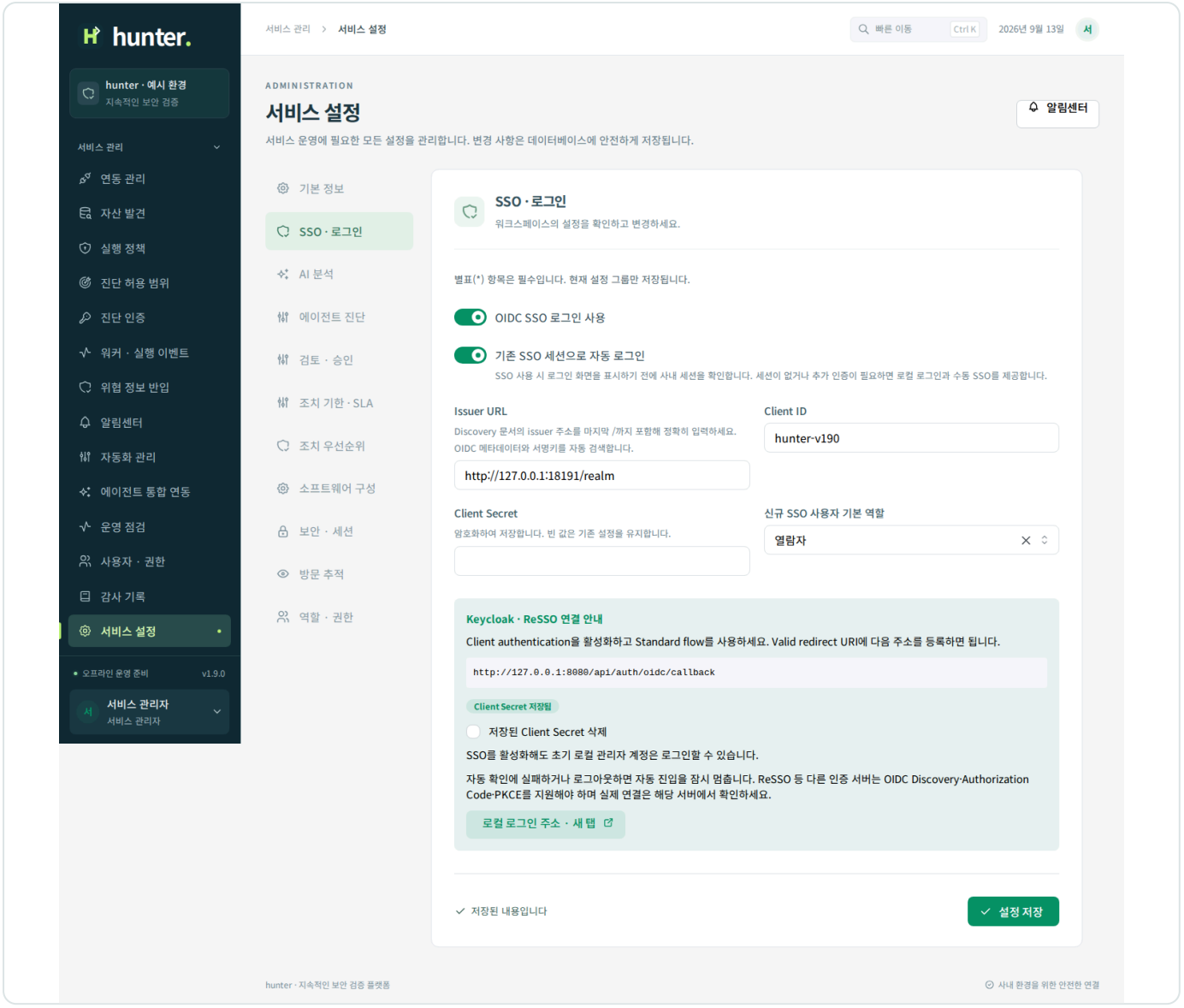
정확한 필드 위치는 Keycloak 버전에 따라 다를 수 있습니다. 리다이렉트 URI는 와일드카드 대신 실제 Hunter 주소로 제한합니다. 생성된 Client Secret은 관리자 설정의 비밀 입력에만 저장합니다.

6.2 Hunter 설정

1. 기본 정보의 공개 주소를 `https://hunter.internal`로 저장합니다.
2. SSO·로그인에 Issuer `https://keycloak.internal/realms/company`를 입력합니다.
3. Client ID와 Client Secret을 입력합니다.
4. 신규 SSO 계정 기본 역할을 선택합니다. 일반적으로 열람자부터 시작합니다.
5. OIDC 사용을 켜고 필요하면 **기존 SSO 세션으로 자동 로그인**(`auto_login`)을 켭니다. 자동 옵션은 기본 꺼짐이며 관리자가 명시적으로 켠 경우에만 `prompt=none` 자동 확인을 시작합니다. 설정에 `auto_login`이 없거나 OIDC 사용이 꺼져 있으면 꺼진 것으로 취급하고, 주소에 `mode=auto`를 붙여도 서버가 평범한 로그인 화면으로 돌려보냅니다.
6. 별도 브라우저 세션에서 기존 IdP 세션의 자동 진입과 세션이 없는 경우의 명시 로그인을 검증합니다.
7. 생성된 사용자 역할을 필요 범위로 조정합니다.

Hunter는 Issuer에서 discovery 메타데이터와 서명키를 찾고 state, nonce, PKCE와 ID 토큰 검증을 사용합니다. Hunter 서버와 브라우저 모두 필요한 사내 Keycloak 주소에 접근할 수 있어야 합니다. 시스템 시간이 크게 어긋나면 토큰 검증에 실패할 수 있습니다.

SSO subject는 로컬 사용자명과 별도로 식별합니다. 임의로 같은 이메일이나 사용자명을 가진 계정에 관리자 권한을 자동 결합하는 방식으로 운영하지 않습니다. 로컬 관리자는 SSO 장애 시 별도 관리 접근 경로로 유지할 수 있습니다.



6.3 자동 진입·억제·복구

Hunter는 유효한 자체 세션이 있으면 인증 서버 discovery 없이 원래 내부 화면으로 이동합니다. 자체 세션이 없고 자동 진입이 허용되면 최상위 브라우저 이동으로 `prompt=none`, `response_mode=query`를 요청합니다. 사내 IdP 세션과 필요한 동의가 이미 있으면 로그인 폼 없이 업무 화면으로 돌아갑니다. 일반 경로·검색 조건·해시는 최대 4096바이트의 안전한 내부 복귀 주소로 보존하며 외부 주소, API·로그인 경로 또는 경로 우회 입력은 `/dashboard`로 대체합니다.

`login_required`는 기존 인증 세션이 없는 경우,
`interaction_required`·`consent_required`·`account_selection_required`는 추가 조작이 필요한 경우입니다. Hunter는 공급자 오류 원문을 노출하지 않고 자체 한국어 안내와 로컬·명시 SSO 로그인 선택을 제공합니다. 성공뿐 아니라 오류 callback에서도 브라우저 state와 암호화한 DB 흐름의 만료·한 번 사용·현재 설정 지문을 확인합니다. 자동 진입은 서명·issuer·audience·nonce·PKCE 및 현재 사용자 역할을 우회하지 않습니다.

자동 시도는 브라우저별 암호화 HttpOnly 쿠키로 10분 재시도를 억제하고, 브라우저 탭의 `sessionStorage`에도 시도 표시를 남깁니다. 사생활 보호 모드처럼 저장소를 읽지 못하는 경우는 "이미 시도했다"로 취급해 자동 진입을 시작하지 않습니다 — 그때 로컬·명시 SSO 로그인은 그대로 사용할 수 있습니다. 명시 로그아웃은 24시간 자동 진입을 억제하고 IdP의 전역 세션은 종료하지 않습니다. 세션 폐기 DB 작업이 실패하면 503으로 안내하고 현재 브라우저 세션을 유지하므로 성공으로 취급하지 말

고 다시 시도합니다. 명시 SSO 로그인은 재시도를 시작할 수 있고 로컬·SSO 성공은 억제를 해제합니다. 저장된 설정을 읽는 `/api/auth/config`는 사용자별 억제 상태를 반영하므로 `no-store`를 유지합니다.

SSO 장애 복구 주소는 `/login?local=1`입니다. IdP 서버에 브라우저가 연결조차 하지 못하면 callback 자체가 없어 Hunter로 자동 복귀하지 못할 수 있습니다. 브라우저 주소창에 실제 Hunter의 로컬 복구 주소를 입력합니다. 관리자에게는 이 주소와 로컬 관리자 복구 방법을 운영 가이드에 함께 배포합니다. 자동 진입은 숨은 iframe의 타사 쿠키에 의존하지 않지만 IdP 세션·브라우저 정책·망 접근 조건까지 보장하는 기능은 아닙니다.

6.4 ReSSO 연결

공식 ReSSO 저장소의 OIDC 소스와 호환 문서에서 Realm Discovery, Authorization Code·PKCE S256·RS256, query 응답과 기존 세션의 `prompt=none` 재사용을 확인했습니다. 조사 기준 커밋은 `f508c7901ad4d0a5437aa87be12710fa1fa37192`입니다. **실제 운영 ReSSO 계정 연동 검증은 미수행**이며 소스의 규격 확인과 구분합니다.

1. ReSSO 관리자에서 사용할 Realm의 외부 HTTPS issuer를 확인합니다. 예: `https://sso.internal/realms/company`.
2. 해당 Realm에 Hunter용 confidential client를 등록하고 `https://hunter.internal/api/auth/oidc/callback`을 정확한 redirect URI로 지정합니다.
3. Hunter 기본 정보의 공개 주소를 저장한 뒤 OIDC issuer·client ID·client secret과 신규 계정 기본 역할을 입력합니다. issuer는 후행 슬래시 유무까지 discovery가 반환하는 문자열과 완전히 일치해야 합니다.
4. OIDC와 자동 진입을 켭니다. 같은 브라우저의 ReSSO 세션이 유효하면 자동 확인이 code를 반환하고, 세션이 없으면 명시 로그인 화면으로 돌아오는지 확인합니다.
5. 서버·브라우저의 사내 망 접근, 내부 CA·시계, 비활성 사용자·역할 정책과 로컬 복구 경로를 조직 환경에서 확인합니다.

ReSSO의 공개 discovery는 `/realms/{realm}/.well-known/openid-configuration` 형태이며 인증·토큰·서명키 주소는 `/realms/{realm}/protocol/openid-connect/` 아래에 있습니다. 기존 SSO 세션을 조회하지 못하는 DB 오류는 `login_required`와 별개인 `server_error`이며 운영 장애를 인증 해제로 오판하지 않습니다. ReSSO 소스·호환 근거

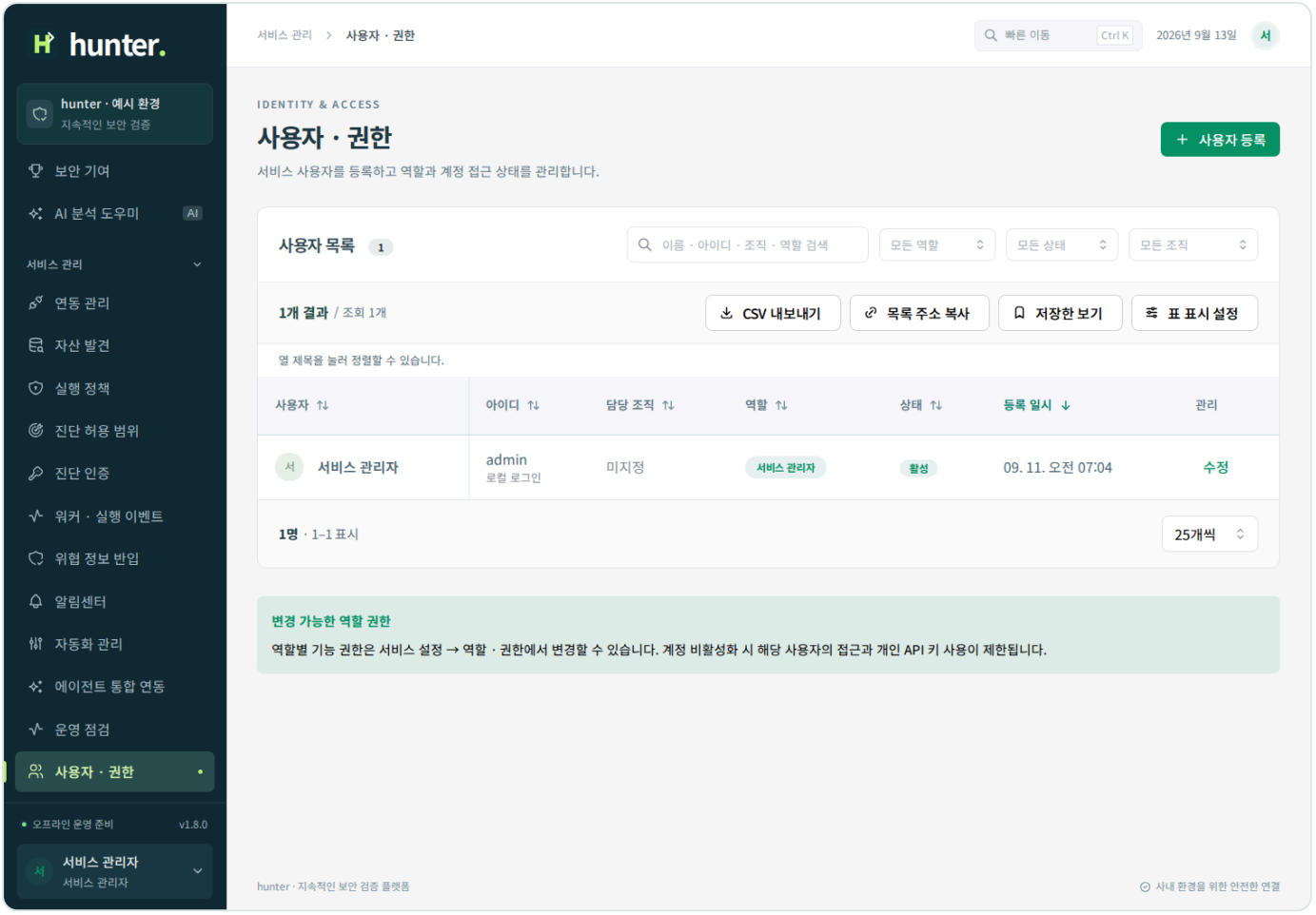
다른 OIDC 제공자도 같은 Discovery·Code·PKCE·서명·`prompt=none` 조건을 확인합니다. OIDC Core, Discovery, Keycloak 공식 브라우저 안내를 참고하세요. 공급자 고유 SAML·전용 쿠키·독자 토큰 규격을 자동 변환하지 않습니다.

7. 사용자와 역할 권한

7.1 사용자 관리

서비스 관리 → 사용자 · 권한에서 사용자명, 표시 이름, 역할과 비활성화 여부를 관리합니다. 새 로컬 계정에는 12~72바이트의 초기 비밀번호를 지정합니다. 기존 사용자 수정 시 빈 비밀번호는 기존 값을 유지합니다.

사용자 목록의 검색창은 이름·아이디·조직·역할을 검색합니다. 역할·활성 상태·조직 필터를 함께 적용하고 열 제목으로 정렬한 뒤 페이지를 이동할 수 있습니다. **조건 초기화**는 검색·필터·정렬·페이지 조건을 기본 상태로 돌립니다. 조건은 URL에 보존되므로 새로고침과 뒤로가기 후에도 해당 조건을 확인할 수 있습니다.



사용자를 비활성화하면 해당 계정의 사용과 API 키 접근이 제한됩니다. 마지막 활성 관리자를 비활성화하거나 관리자 권한을 제거할 수 없습니다. 조직 내 퇴직·이동 절차와 계정 비활성화를 연결할 때 개인 키도 함께 확인합니다.

7.2 로그인 남용 방어

로컬 로그인은 서버가 확인한 연결 IP마다 1분 동안 최대 120회 시도를 허용하고, 사용자명과 IP 조합에는 기존 15분·10회 제한을 적용합니다. 비밀번호 검증 작업은 프로세스당 최대 4개를 동시에 처리합니다. 초과 요청은 429로 거부하여 무작위 사용자명으로 비밀번호 해시 연산을 무제한 유발하지 못하게 합니다.

사내 리버스 프록시 뒤에서는 여러 사용자의 접속이 같은 프록시 IP로 보일 수 있습니다. 이 경우 IP 한도를 함께 적용하므로 반복되는 429 오류를 조사할 때 실제 연결 경로를 확인합니다. 임의 forwarded 헤더를 받아 제한을 우회하게 하지 않습니다.

7.3 권한 목록

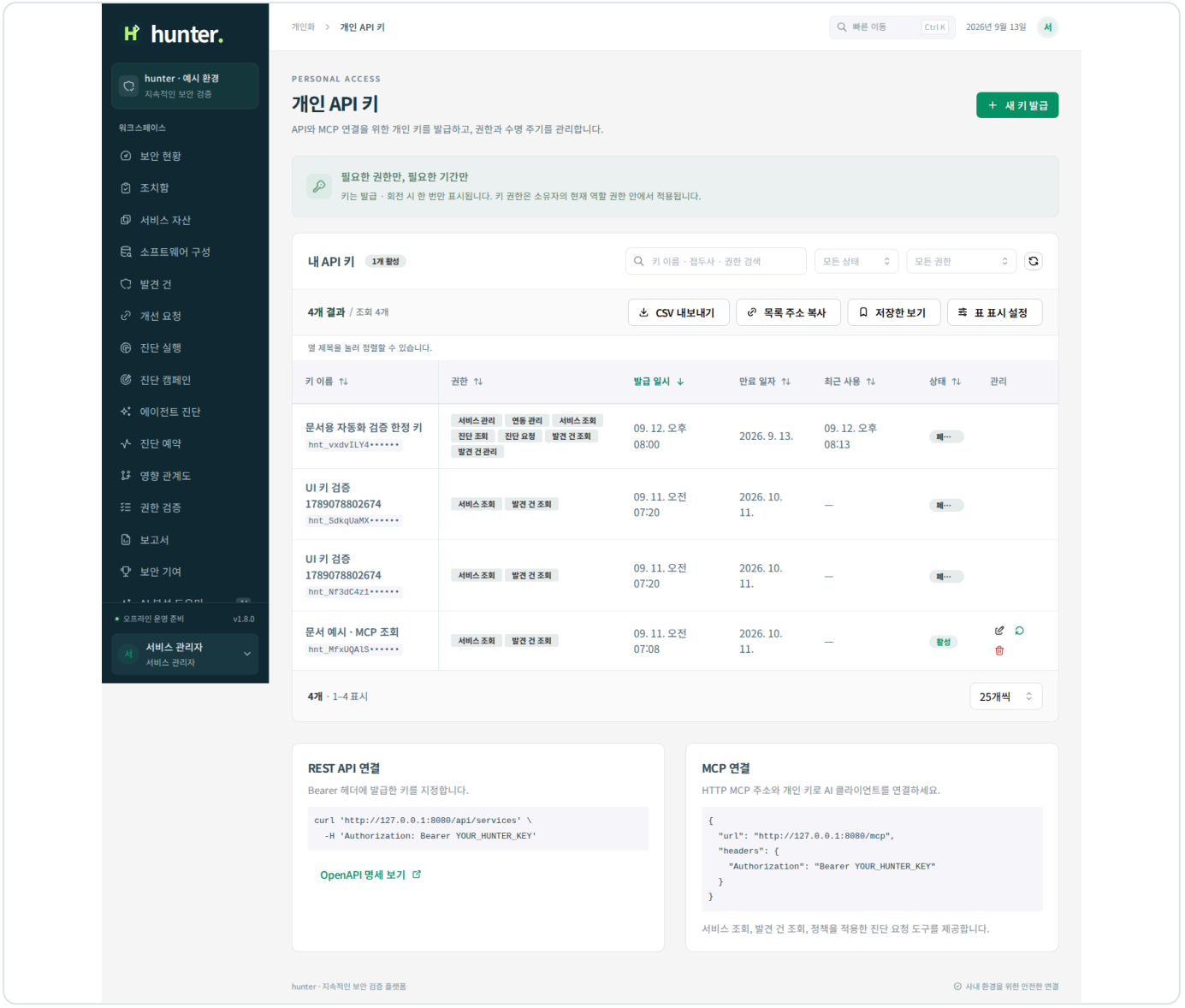
권한	기능
services:read	서비스와 연결된 업무 자료 조회
services:write	서비스·권한 시나리오 등 관리
findings:read	발견 건 조회
findings:write	발견 건 등록·수정·결과 수입
scans:read	진단 작업 조회
scans:write	진단 요청·취소
scans:approve	선택적 승인 흐름의 검토
integrations:manage	연동 설정과 자산 수집
admin:manage	서비스 전반 관리
audit:read	감사 기록 조회
ai:use	AI 분석 사용
agents:read	허용된 서비스의 에이전트 실행·이벤트 조회
agents:write	에이전트 실행 생성·중지·새 실행으로 재시도

관리자 역할은 전체 관리 권한을 유지합니다. 다른 역할은 서비스 설정에서 조정합니다. 역할 변경은 새 키를 발급하지 않아도 현재 계정과 개인 키의 실제 권한에 반영됩니다. 데이터 소유 범위는 기능 권한과 별도로 적용됩니다.

사용자 관리의 팀 값과 서비스의 팀 값으로 조직 접근 범위를 연결합니다. 팀장도 전체 조직의 데이터를 자동으로 열람하지 않으며 자신이 소유하거나 같은 팀에 속한 서비스 범위를 따릅니다. 복잡한 조직 계층·상속 ACL이 필요한 경우 별도 정책 확장을 검토합니다.

7.4 개인 키 운영 원칙

키는 개인화 페이지에서 소유자가 발급·수정·회전·폐기합니다. 관리자는 서비스 전체의 최대 유효 기간과 역할 권한을 설정합니다. 서버는 키 원문을 다시 보여주지 않습니다.



회전은 원자적으로 기존 키를 폐기하고 새 키를 발급합니다. 기존 연동이 즉시 끊기므로 전환 시점을 계획합니다. API 계정 권한을 축소하면 기존 키의 권한도 그 범위 안으로 줄어듭니다. 감사와 최근 사용 일시를 확인하여 미사용 키를 정리합니다.

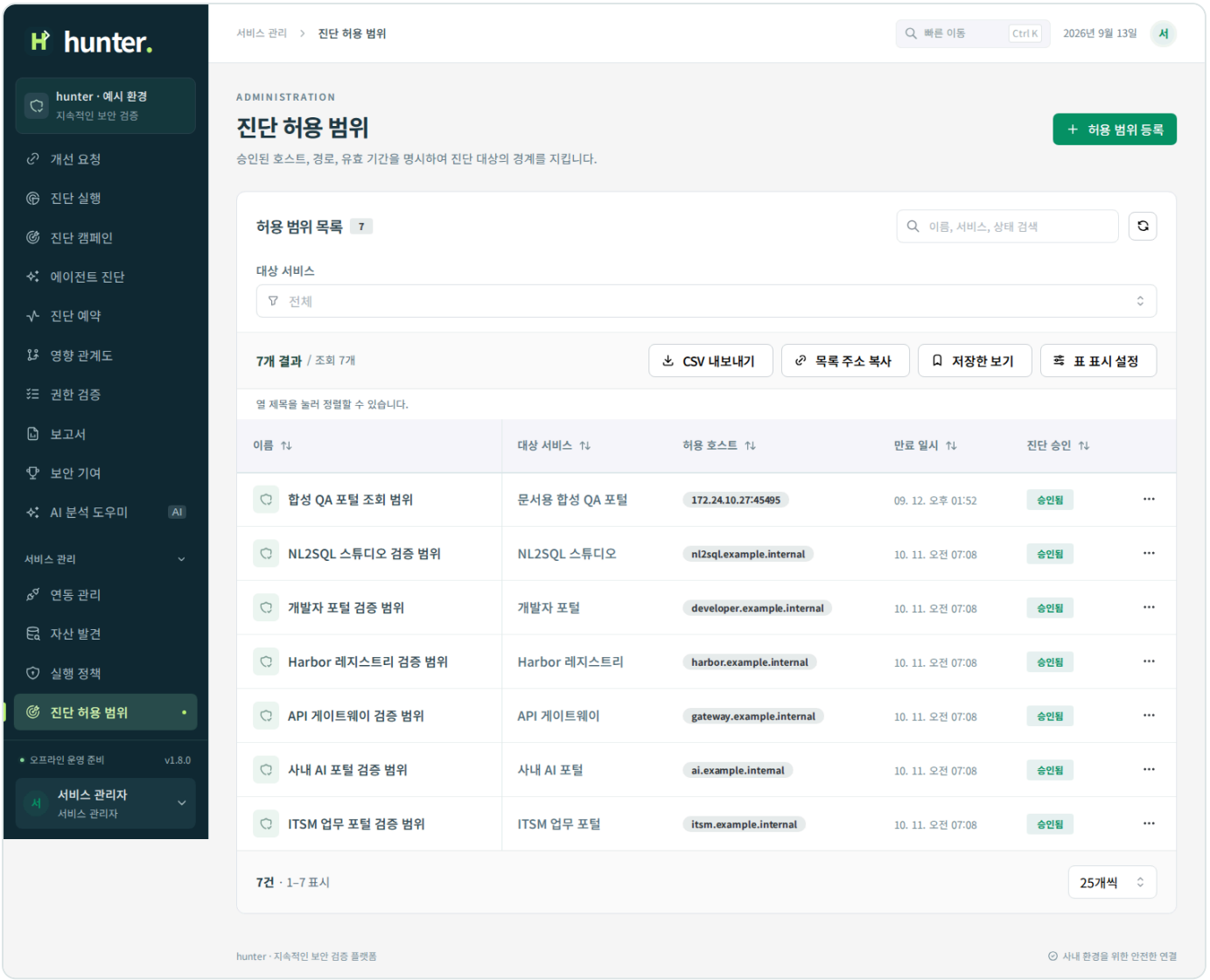
8. 서비스 승인과 진단 허용 범위

8.1 서비스 승인

서비스 URL과 환경, 담당자를 확인한 뒤 서비스의 진단 승인 상태를 설정합니다. URL뿐 아니라 환경·망·조직·담당자·중요도·대상·저장소·이미지 또는 소유자 변경 시 기존 승인이 해제되므로 변경된 대상을 재확인합니다. 단순 자산 등록이나 discovery 후보 생성만으로 진단은 실행되지 않습니다.

8.2 허용 범위

관리자 → 진단 허용 범위에서 서비스마다 범위를 등록합니다.



항목	설정 원칙
대상 서비스	실제 승인한 서비스
허용 호스트	명시적인 호스트·포트, 전체 와일드카드 지양
허용 경로	읽기 전용의 필요한 접두 경로

항목	설정 원칙
허용 CIDR	DNS가 해석할 수 있는 승인 IP 대역 제한
만료 일시	승인 기간의 종료 시각
최대 RPS	대상과 공유 백엔드가 감당할 요청률
최대 요청 수	한 작업의 총 요청 예산
시간 제한	작업이 실행될 수 있는 최대 시간
승인 여부	담당 조직의 진단 허가를 확인한 후 활성화

요청량을 작게 시작하고 진단 전후 대상 시스템의 실제 지연·오류를 확인합니다. RPS 1이 모든 운영계에서 안전함을 보장하지 않습니다. DNS 결과, 리다이렉트와 경로 검사에서 거부된 요청은 허용 범위를 무조건 넓히기보다 실제 필요한 경로인지 먼저 확인합니다.

9. 실행 정책과 긴급 중지

관리자 → 실행 정책에서 기본 통제를 관리합니다. 활성화된 정책의 제한은 진단 요청에 적용됩니다. 허용 메서드는 지원되는 읽기 전용 GET·HEAD 범위에서 사용하고, 삭제·결제·발송·승인 같은 업무 경로를 차단합니다.

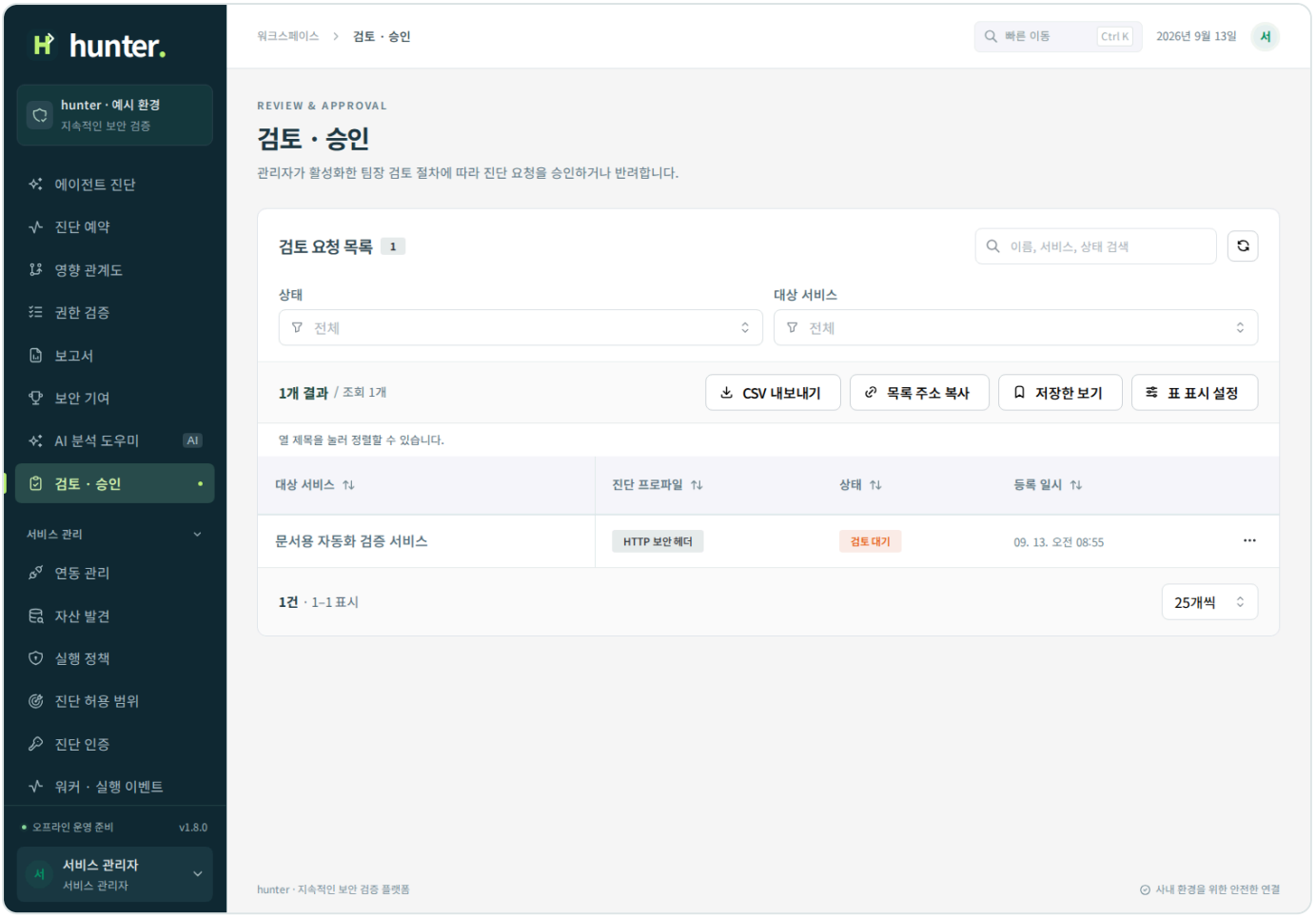


운영계에 임의 능동 공격 프로파일을 제공하지 않습니다. 관리자가 더 큰 숫자를 입력해도 실제 구현된 프로파일과 서버의 상한을 넘는 엔진이 생성되지 않습니다. UI의 JSON 입력과 API로 정책을 저장하고, 사내 Git 저장소에서 JSON 변경 이력을 별도로 관리할 수 있습니다. YAML·Rego 실행 엔진을 내장한 것은 아닙니다.

긴급 중지는 신규 작업과 진행 중 진단을 중단하는 운영 통제입니다. 원인을 기록하고 범위·서비스 상태를 점검한 뒤 해제합니다. 네트워크 워커의 요청 예산과 응답 오류·지연 제한을 적용하며, 모든 사내 모니터링 제품의 CPU·DB 지표를 자동 구독하지는 않습니다. 조직의 모니터링 경보는 API 연동으로 중지 요청을 연결할 수 있습니다.

10. 선택적 검토·승인 프로세스

서비스 설정의 **검토·승인 → 팀장 검토·승인 프로세스 사용**으로 켜거나 끕니다. 기본값은 비활성화입니다.

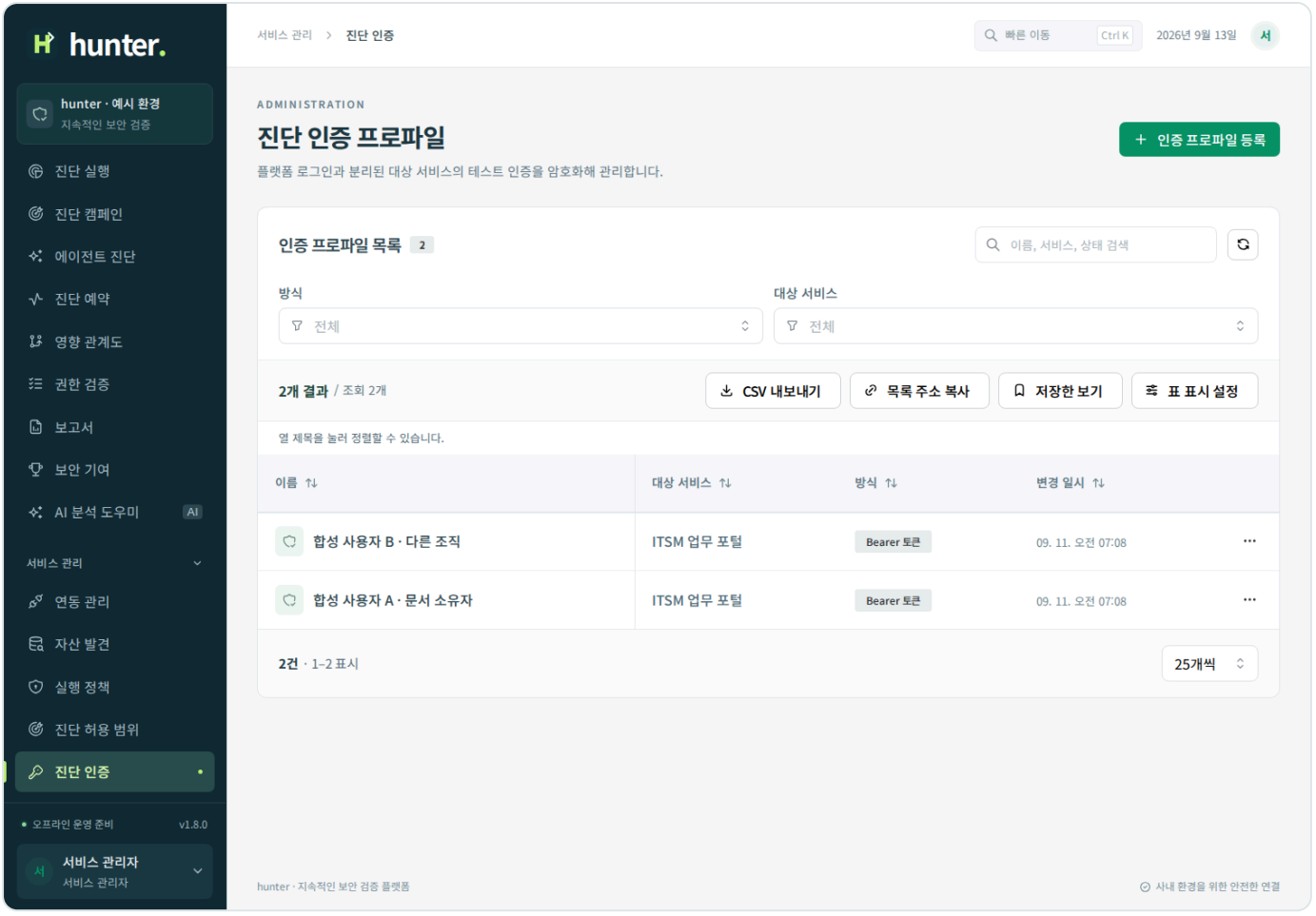


상태	사용자 경험
비활성화	승인 메뉴와 업무 단계 제외, 동일한 실행 정책 확인 후 진단
활성화	진단 요청이 검토 대상으로 생성되고 권한 있는 검토자가 승인·반려
승인 후 범위 만료	실제 실행 전 정책 검사에서 거부
실행 중 긴급 중지	작업을 취소하고 중단 상태 기록

팀장 검토 설정과 대상의 법적·업무상 진단 허가는 별개입니다. 승인 옵션을 끄는 것으로 임의 주소나 외부 서비스에 진단할 권한이 생기지 않습니다. 위험 수용·오탐 처리도 활성화 시 팀장 또는 관리자 판단을 요구합니다.

11. 진단 대상 인증 프로파일

관리자 → 인증 프로파일에서 진단 대상 서비스의 테스트 인증 정보를 관리합니다. Hunter 플랫폼 로그인과 테스트 대상 인증은 서로 다릅니다.



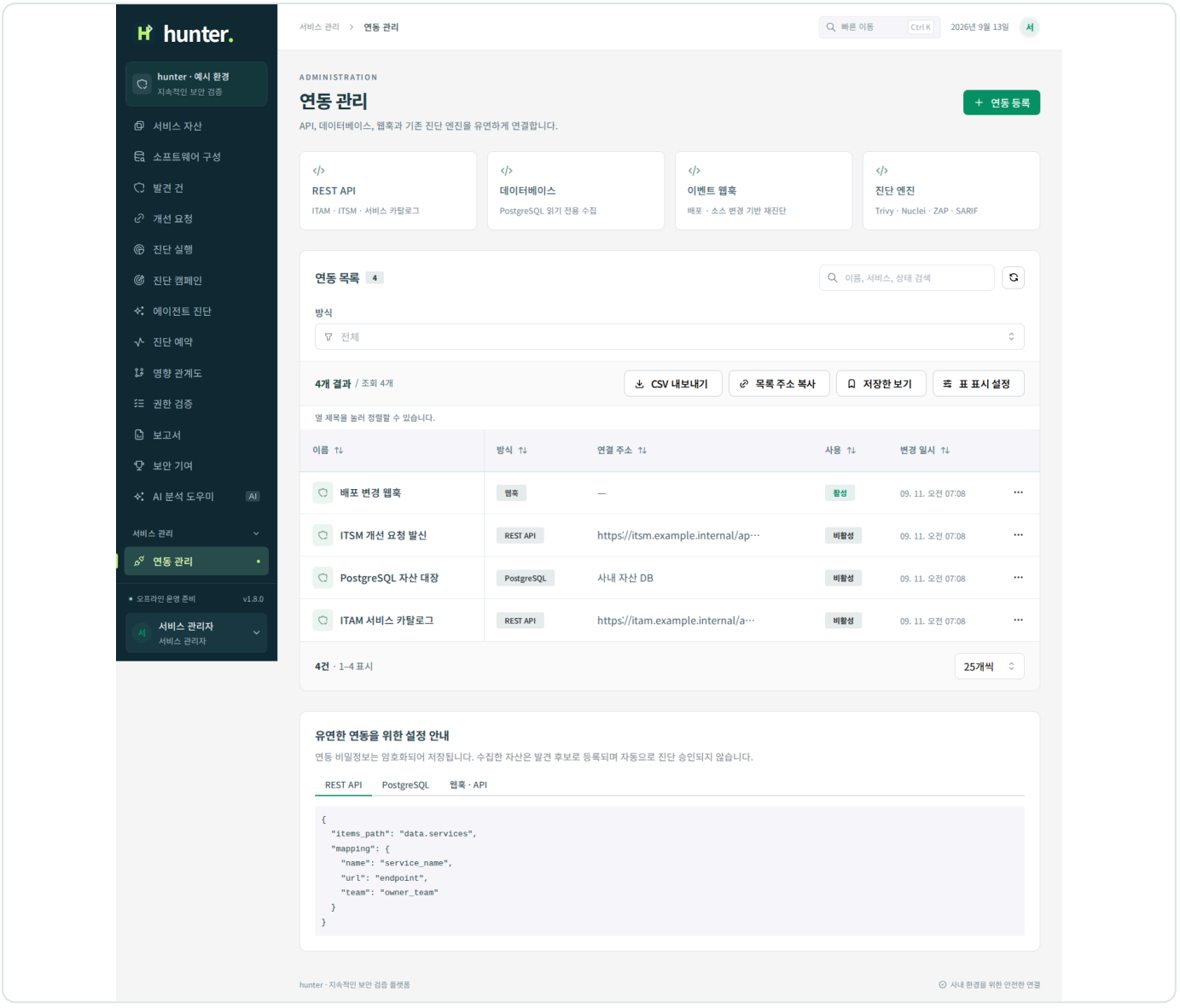
지원 방식은 Bearer, Basic, 사용자 지정 헤더입니다. 프로파일마다 대상 서비스를 지정하고 별도의 테스트 계정을 사용합니다. 비밀값은 암호화하여 보관하고 일반 조회에서 원문을 노출하지 않습니다.

권한 시나리오에는 같은 서비스에 연결된 서로 다른 두 프로파일이 필요합니다. 비교 계정이 자기 합성 데이터에 정상 접근하는 기준 경로와 식별 문자열도 정의해야 인증 만료와 인가 차단을 구분할 수 있습니다. 합성 데이터 접근이 가능한 정상 역할과 접근하면 안 되는 비교 역할을 지정합니다. 쿠키 기반 대상 인증이 필요하면 승인된 테스트 쿠키를 사용자 지정 헤더로 제공하되, 자동 로그인·세션 갱신·브라우저 상태 파일 관리 기능으로 오해하지 않습니다.

12. 자산 연동과 자동발견

12.1 연동 유형

관리자 → 연동 관리에서 이름, 유형, 주소, 비밀정보와 JSON 설정을 등록합니다. 연결 테스트로 접근 가능성을 확인한 다음 동기화를 실행합니다.



유형	사용 목적	제한
REST API	ITAM·서비스 카탈로그 자산 수집	등록한 API와 필드 매핑에 따른 가져오기
PostgreSQL	사내 자산 테이블·뷰 수집	별도 읽기 전용 계정과 조회 SQL
웹훅	변경 이벤트와 외부 시스템 호출 연결	Hunter 권한 검사와 기존 승인 범위 적용
스캐너 결과	승인된 도구 결과 수입	도구 바이너리를 직접 설치·실행하지 않음

12.2 REST 필드 매핑 예시

```
{
  "items_path": "data.services",
  "mapping": {
    "name": "service_name",
    "url": "endpoint",
    "team": "owner_team"
  }
}
```

원본 JSON 구조에 맞는 목록 경로와 필드 매핑을 설정합니다. 외부 필드명이 바뀌면 매핑을 수정하고 소수 데이터를 먼저 확인합니다. 이름·URL·환경·조직을 변환하는 전용 사내 API 어댑터를 둘 수도 있습니다.

12.3 PostgreSQL 연동 예시

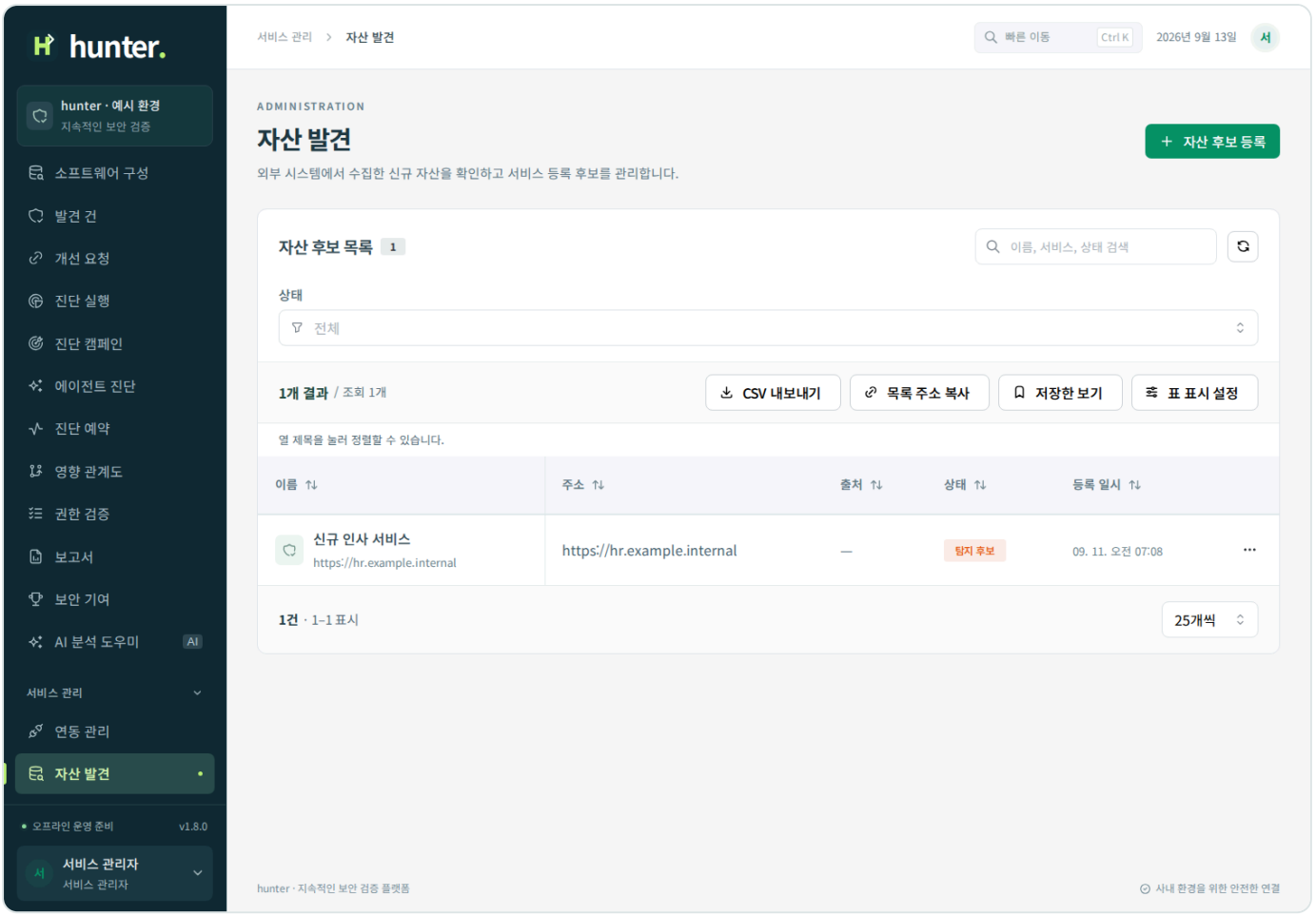
PostgreSQL 연동의 비밀정보 입력에 DSN을 넣으면 암호화하여 저장합니다. 계정은 필요한 뷰만 읽을 수 있도록 제한하고 운영 핵심 테이블 전체 권한을 부여하지 않습니다.

```
{
  "query": "SELECT name, url, team FROM hunter_service_catalog LIMIT 500",
  "mapping": {
    "name": "name",
    "url": "url",
    "team": "team"
  }
}
```

SELECT 쿼리, 읽기 전용 트랜잭션, 5초 시간 제한과 최대 500행을 적용합니다. 이 제한과 별개로 원본 DB의 계정 권한을 최소화합니다. Oracle·MSSQL·MySQL 전용 드라이버를 번들한 것은 아닙니다. 이러한 시스템은 사내 REST 어댑터, PostgreSQL 중계 뷰 또는 가져오기 API로 연결합니다.

12.4 발견 후보 검토

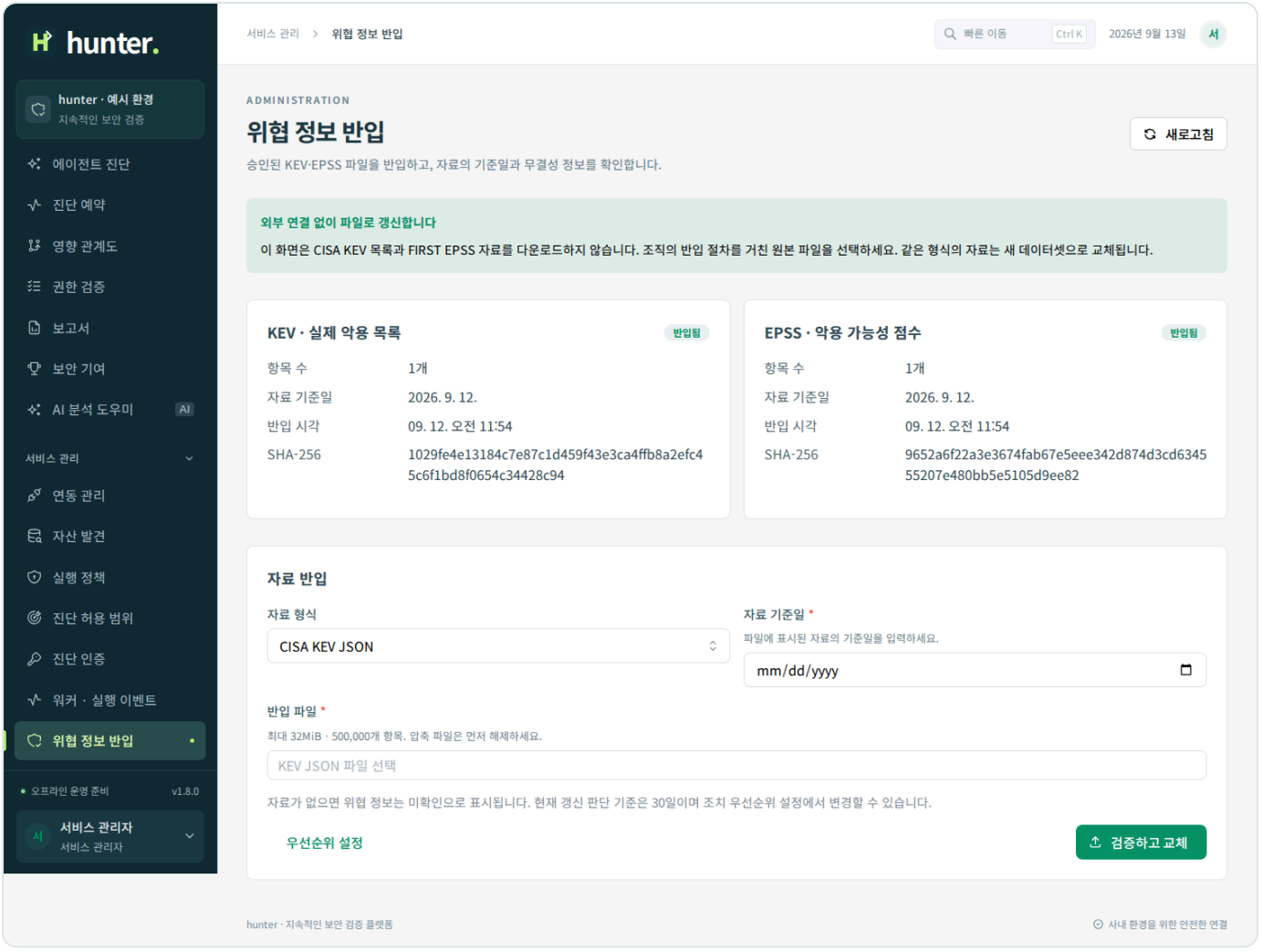
동기화한 자산은 **자동발견 후보**에서 확인합니다. 신규 서비스인지, 담당 조직과 URL이 정확한지 검토한 뒤 서비스 자산으로 등록합니다. 후보 발견 자체가 네트워크 진단 승인이 되지 않습니다.



ITAM, DNS, Ingress, Route, Harbor, GitLab 등은 그 정보를 제공하는 사내 API·DB와 연결합니다. 각 제품에 대한 완성된 전용 인증·페이징·이벤트 변환 커넥터가 있다고 가정하지 않습니다.

12.5 KEV·EPSS 자료를 폐쇄망에 반입

관리자 → 위협 정보(`/admin/intelligence`)에서 반입합니다. 관리자 권한이 있는 세션 또는 개인 키만 자료를 교체할 수 있습니다. Hunter는 실행 중 외부 피드를 자동 다운로드하지 않습니다.



1. 인터넷 구간에서 조직이 승인한 원본 파일을 확보하고 반입 절차로 전달합니다. 압축된 EPSS 파일은 먼저 CSV로 풉니다.
2. 형식을 **KEV JSON** 또는 **EPSS CSV**로 선택합니다.
3. 실제 자료의 기준일을 `YYYY-MM-DD`로 입력합니다. 현재보다 미래 날짜를 사용할 수 없습니다.
4. 파일을 선택하거나 본문을 붙여넣습니다. 본문은 32 MiB 이하, CVE는 최대 500,000개입니다. JSON API 포장 요청에는 최대 64 MiB 제한이 적용됩니다.
5. 반입 완료 후 기준일·반입일·건수·SHA-256을 확인하고 조치함에서 해당 CVE가 연결되는지 확인합니다.

KEV에는 `vulnerabilities` 배열과 `cveID`가 필요합니다. `count`가 있으면 실제 건수와, `dateReleased`가 있으면 입력 기준일과 일치해야 합니다. EPSS CSV는 `cve`, `epss` 열이 필수이고 `percentile`은 선택입니다. 값은 0~1 범위의 유한한 숫자여야 합니다. CSV 주석이나 행에 기준일이 있으면 화면 입력과 일치해야 합니다.

반입은 형식별 자료 전체를 한 트랜잭션으로 교체합니다. 잘못된 행·중복 CVE·기준일 오류가 있으면 기존 정상 자료를 유지합니다. 기존보다 오래된 날짜는 HTTP 409로 거부합니다. 같은 날짜의 재반입은 가능하므로 실제 파일의 해시와 근거를 확인하세요. SHA-256은 반입 내용을 식별하며 원본 공급자 서명이나 사실성을 검증하지 않습니다.

API 예시 파일은 실제 운영 피드가 아닌 형식을 설명하는 합성 자료입니다.

```
{
  "format": "epss",
  "source_date": "2026-09-12",
  "content": "cve,epss,percentile\nCVE-2026-12345,0.15,0.91\n"
}
```

```
curl 'https://hunter.internal/api/intelligence/import' \
  -H 'Authorization: Bearer YOUR_ADMIN_KEY' \
  -H 'Content-Type: application/json' \
  --data-binary @intelligence-import.json
```

반입 파일 자체의 날짜를 현재 날짜로 바꾸어 오래된 자료를 최신으로 표시하지 않습니다. 조회한 KEV 포함 여부가 `false`라면 반입 목록에 없다는 뜻이며, `null`은 자료 또는 유효한 CVE를 확인하지 못했다는 뜻입니다. EPSS `null`은 실제 0과 다릅니다.

12.6 SBOM 반입 운영

사용자는 **소프트웨어 구성**에서 현재 접근 가능한 서비스의 SBOM을 반입합니다. 조회는 `services:read`, 반입·삭제는 `services:write`가 필요하며 연결된 발견 건을 보려면 `findings:read`도 필요합니다. 개별 문서 작성자가 아니라 현재 부모 서비스 권한으로 열람·비교·영향 집계를 검사합니다.

문서 이름은 UTF-8 기준 200바이트까지입니다. 화면의 바이트 수와 오류를 확인하며 한글·이모지를 포함한 이름이 한도를 넘으면 전송 전에 줄입니다. 빈 이름에는 서비스명 기반 기본값을 사용하며 서버도 UTF-8 문자 경계를 지켜 200바이트로 제한합니다.

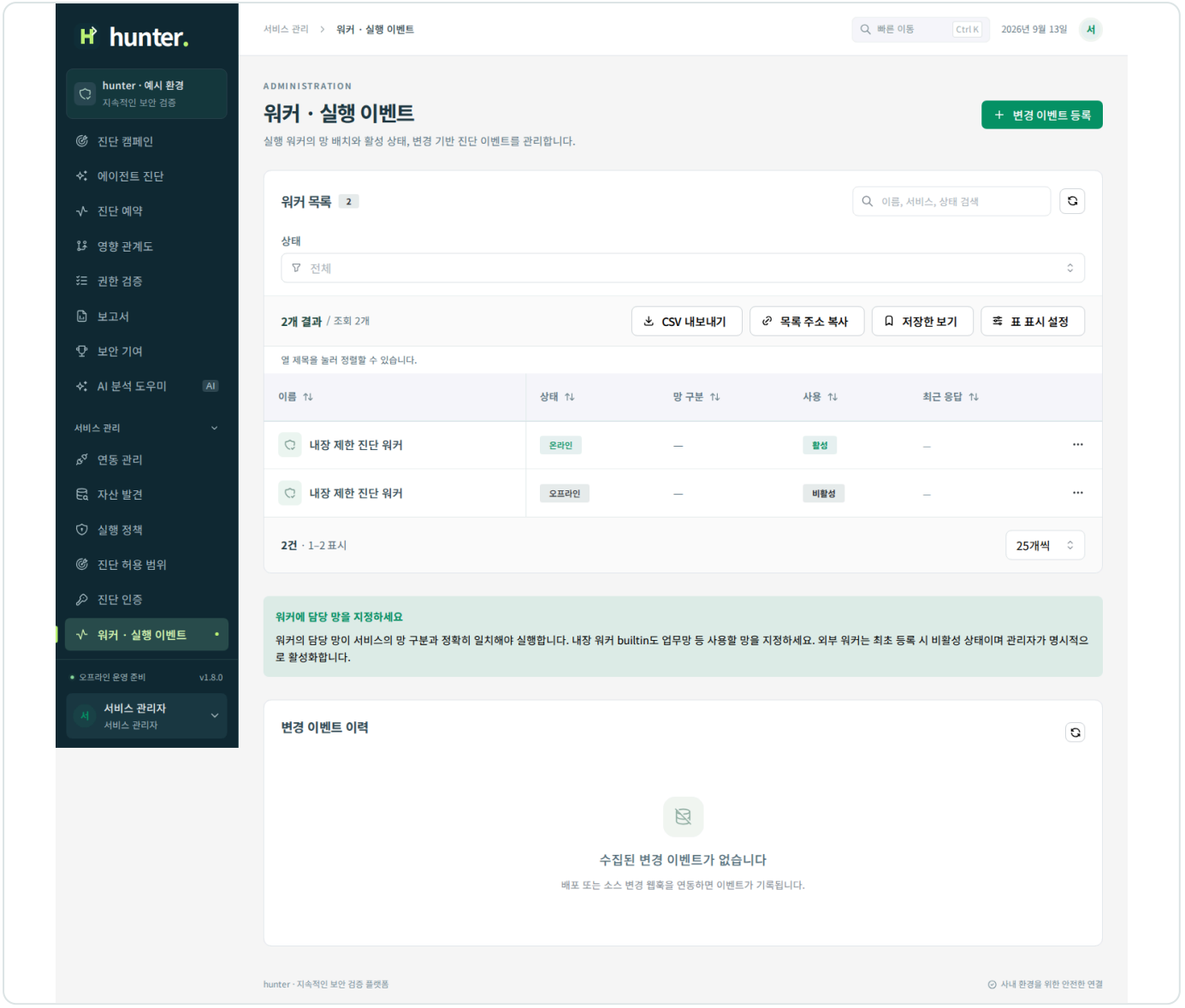
지원 형식은 CycloneDX 1.4·1.5·1.6 JSON, SPDX 2.2·2.3 JSON입니다. 본문 8 MiB·구성요소 1~10,000개·중첩 64단계·구성요소별 라이선스 50개를 제한하며, 입력 의존 관계는 미등록 참조까지 포함해 100,000개 이하입니다. 빈 문서·중복 참조·지원 필드의 잘못된 타입은 거부하고 이전 최신 명세를 유지합니다. purl 기본 구조·버전 일치·인코딩·자격 정보 qualifier를 검사하지만 전체 표준 스키마 검증기는 아닙니다. XML·태그 값 형식·SBOM 생성·취약점 DB 자동 분석은 현재 범위가 아닙니다.

동일 서비스에 같은 JSON 바이트가 이미 있으면 기존 문서를 재사용합니다. 주의 메시지를 확인하고 서로 다른 배포본을 같은 서비스에 보관해 비교하세요. 임의의 공급자 속성과 파일을 그대로 저장하지 않고 필요한 구성요소·관계 메타데이터를 정규화합니다. 같은 패키지·버전의 서로 다른 라이선스는 별도 행으로 보존합니다. 문서 `bom-ref` 변경만으로 메타데이터 변경으로 세지 않으며 여러 버전 변경은 임의로 짝짓지 않고 추가·제거로 표시합니다. 이름·버전이 서로 다른 purl이나 구성요소 식별자에 걸쳐 모호하면 발견 건을 `이름@버전`으로 연결하지 않습니다. 새로운 문서 반입·삭제·패키지 제거만으로 발견 건 상태가 해결로 바뀌지 않습니다.

13. 워커, 진단 예약과 변경 이벤트

13.1 망별 워커

관리자 → 워커·실행 이벤트에서 워커의 상태, 최근 생존 시각, 담당 망과 활성 여부를 관리합니다.



제어 서버의 기본 워커 또는 별도 망의 워커를 사용할 수 있습니다. 워커 전용 실행은 같은 서비스 이미지를 사용하며 HTTP 관리 포트를 열지 않습니다. 같은 PostgreSQL과 같은 네 가지 환경변수로 실행합니다.

```
docker run -d --name hunter-worker-dmz \
  --env-file .env \
  --read-only --tmpfs /tmp:rw,noexec,nosuid,size=64m \
  --cap-drop ALL --security-opt no-new-privileges:true \
  hunter:v1.25.0 --worker-only --worker-id worker-dmz
```

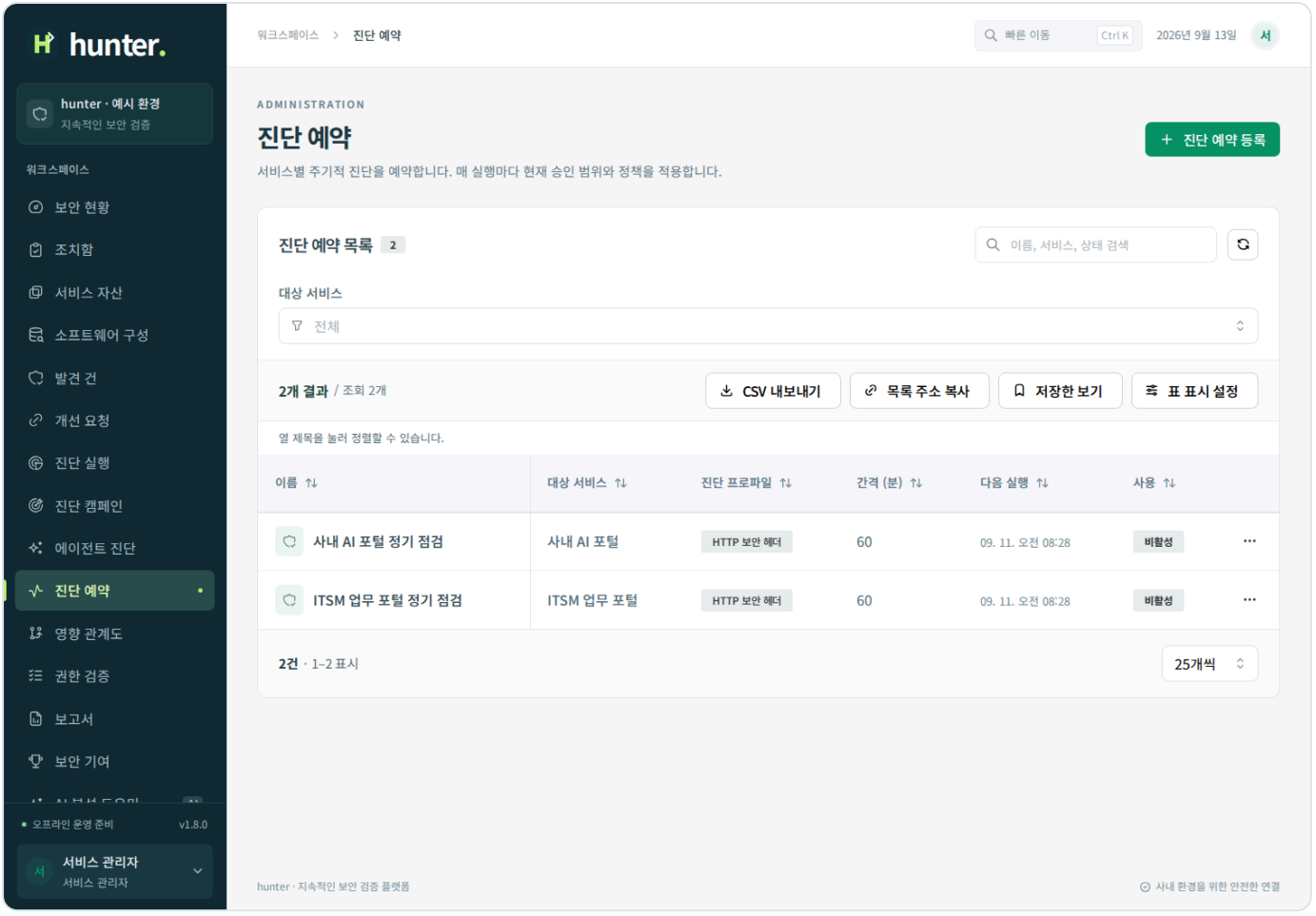
워커 ID는 안정적이고 고유한 값을 사용합니다. 새 외부 워커는 자동 등록되지만 기본 비활성 상태이므로 관리자가 담당 망을 지정하고 활성화해야 합니다. 망 이름은 서비스의 망 값과 **정확히 일치**해야 합니다. 별표 와일드카드는 지원하지 않습니다. 기본 워커의 빈 망 값은 분류되지 않은 서비스만 대상으로 합니다.

각 망의 실제 방화벽·라우팅 정책으로 워커가 승인된 대상과 PostgreSQL에만 접근하도록 구성합니다. 같은 DB에 접근할 수 없는 완전 분리망 사이를 자동 연결하지 않습니다. DB 자격 증명이 있는 워커는 신뢰된 실행 구성요소이므로 일반 사용자에게 워커 실행 호스트의 관리 권한을 제공하지 않습니다.

Go 전용 HTTP transport, 요청 예산과 정책 검사를 사용하며 외부 스캐너의 임의 프로세스를 실행하지 않습니다. 작업 임대·생존 확인과 취소 처리는 PostgreSQL에서 관리합니다. 관리자가 워커를 비활성화하면 신규 실행을 제한하고 실행 상태도 재검사합니다.

13.2 주기적 예약

진단 예약에서 서비스, 프로파일, 범위, 시나리오(필요한 경우), 실행 간격, 첫 실행 시각과 활성 여부를 저장합니다. 간격은 5~10,080분입니다.



제어 서버의 스케줄러가 예약을 처리하고 실제 워커는 같은 작업 큐에서 가져갑니다. 매 실행마다 현재 계정·API 키 권한과 서비스 승인, 유효 범위 및 정책을 확인합니다. 같은 예약 회차를 중복 생성하지 않고 장애 후 놓친 과거 회차를 대량 재실행하지 않습니다. 팀장 검토가 켜져 있으면 예약 진단에도 동일한 흐름을 적용합니다.

13.3 변경 이벤트

배포, Git 변경, 이미지 변경, IAM 변경 이벤트를 기록하고 기존 승인 서비스에 진단을 요청합니다. 웹훅 호출에는 연동 관리 권한이 필요하며 진단까지 요청하려면 scans:write 권한도 필요합니다.

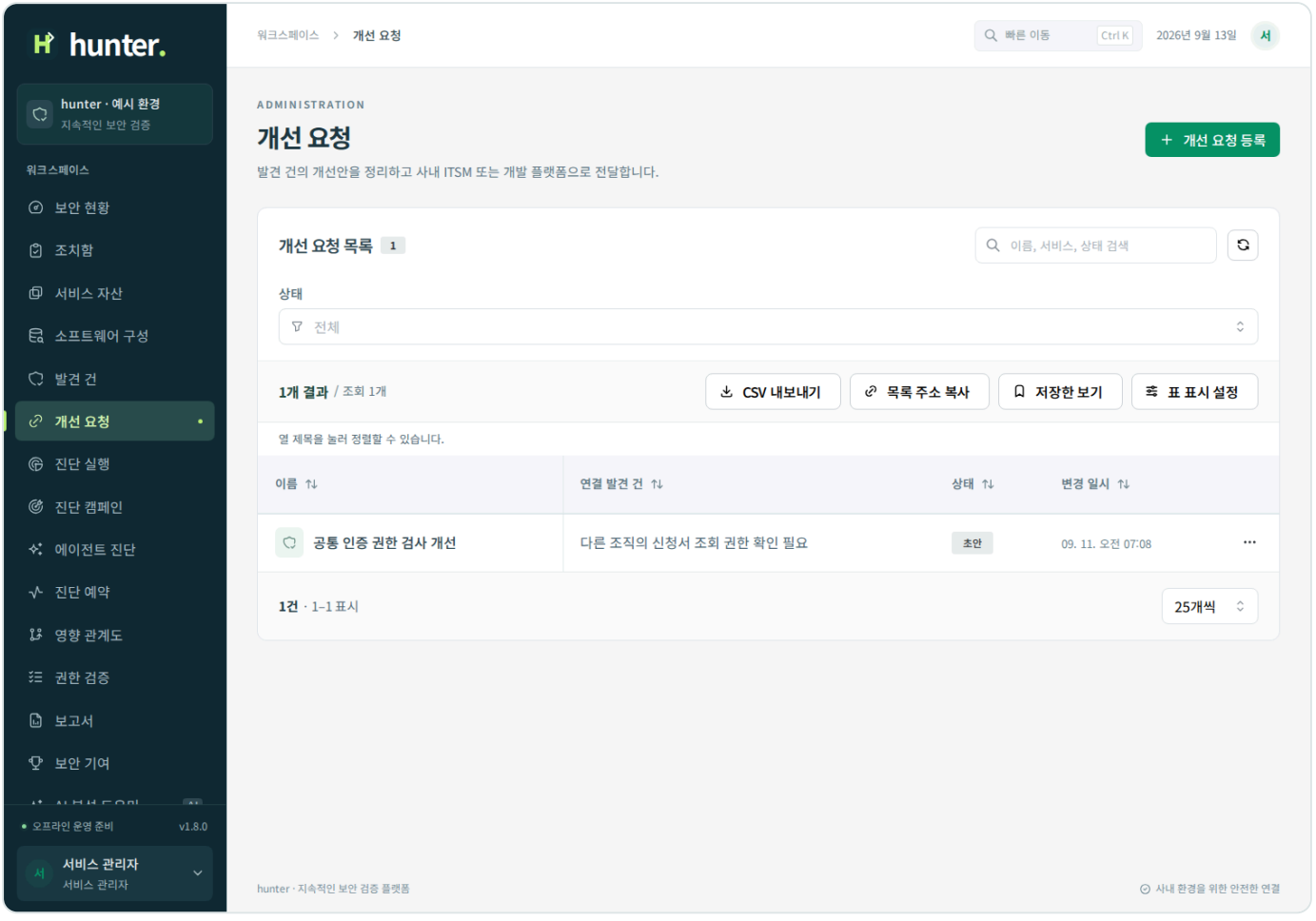
이벤트가 Git 변경이라고 해서 변경 파일 SAST 엔진이 자동 실행되는 것은 아닙니다. 실제 실행은 선택한 프로파일과 현재 정책에 따릅니다.

13.4 개선 요청을 ITSM·개발 플랫폼으로 발송

REST 연동에 direction을 outbound로 설정하고 외부 API에 맞는 JSON template을 작성합니다. 연동 비밀값은 외부 API의 Bearer 인증에 사용합니다.

```
{
  "direction": "outbound",
  "template": {
    "title": "{{finding.title}}",
    "description": "{{finding.description}}",
    "suggested_fix": "{{finding.remediation}}",
    "patch": "{{remediation.patch}}",
    "hunter_reference": "{{remediation.id}}"
  }
}
```

개선 요청에서 발견 건과 이 연동을 선택하고 초안을 작성한 후 명시적으로 발송합니다. 서버는 설정한 주소로 POST를 수행합니다. 티켓·PR API에 필요한 저장소, 브랜치, 프로젝트 필드 등은 조직의 API 문서에 맞춰 템플릿에 넣습니다.



발송은 Hunter 개선 ID를 기반으로 Idempotency-Key를 제공합니다. 상태가 sending·sent·uncertain이면 자동으로 재전송하지 않으며, 불확실한 응답은 외부 시스템에서 생성 여부를 확인해야 합니다. 외부 API도 멱등성 키를 지원하는지 확인하세요.

성공 응답의 외부 ID·URL은 설정한 응답 필드에 맞게 연결합니다. 자동 병합·배포는 수행하지 않습니다.

13.5 캠페인 운영과 재실행

캠페인은 최대 20개 서비스·프로파일·시나리오 조합을 하나의 작업으로 관리합니다. 생성·시작에는 `services:read`, `scans:read`, `scans:write`가 필요하고 모든 대상의 현재 서비스 접근을 검사합니다. 관리자의 대상 승인·유효 범위·선택적 팀장 승인·긴급 중지와 기존 망별 워커를 그대로 사용합니다.

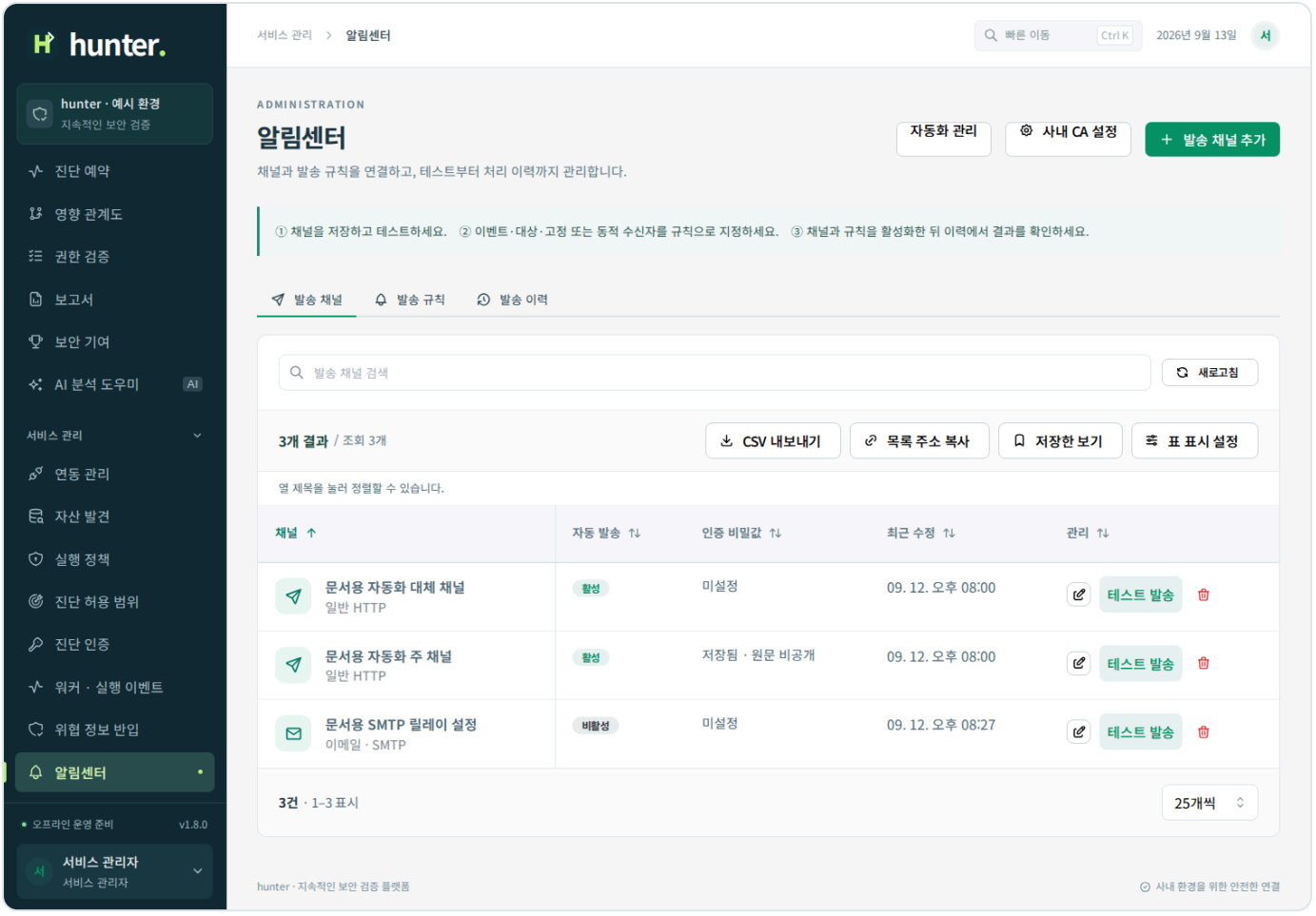
시작 전 정책 준비를 마친 뒤 DB 트랜잭션에서 캠페인 잠금, 현재 부모 권한·긴급 중지 확인, 전체 진단·큐·승인·연결 저장을 처리합니다. 동시 요청이나 응답 재시도로 같은 캠페인이 중복 실행되지 않습니다. 이미 시작한 캠페인은 기존 결과를 돌려주므로 새 검증에는 새 캠페인을 만듭니다. 개별 진단을 취소해도 캠페인의 연결 이력은 유지합니다.

비교는 같은 서비스·프로파일·시나리오 구성과 같은 실행 조건의 내장 완료 진단에 한정합니다. 정책·범위·인증·신뢰 CA·엔진 버전이 바뀌면 비교 불가입니다. 외부 결과 반입·이전 버전·실패·취소·스냅샷 없는 실행도 비교하지 않습니다. 비교용 관측 결과는 증거·비밀값 없이 실행별로 고정 보존하며 건당 최대 5,000개입니다. 반복 검증은 기존 캠페인의 **같은 대상으로 새 캠페인**에서 현재 접근 권한을 다시 조회하고 새 초안을 검토해 등록할 수 있습니다. 이전 진단 ID·결과·실행 상태는 복사하지 않으며 별도의 시작이 필요합니다.

새 배포 후 기준과 동일한 진단을 실행하고 신규·반복·변경·미관측을 검토합니다. 미관측은 해결이 아니며 기존 지원 재검증 절차를 통해 해결을 확정합니다. 이 기능의 결과만으로 외부 스캐너의 실행 완전성이나 모든 업무 권한의 안전을 주장하지 않습니다.

13.6 알림센터와 발송 채널

서비스 관리 → 알림센터(`/admin/notifications`)에서 발송 채널, 발송 규칙과 전달 이력을 관리합니다. 관리자 알림센터 API는 `admin:manage`가 필요합니다. 개인 업무 알림과 서명 콜백은 별도 인증·권한을 사용합니다. 관리자 권한을 가진 개인 API 키도 현재 역할·키 범위 검사를 통과해야 합니다. 일반 사용자가 자기 수신 채널을 직접 등록하는 개인 알림 설정은 제공하지 않습니다.



알림 설정은 추가 환경변수 없이 PostgreSQL에 저장합니다. 채널 설정·인증 비밀값, 규칙의 수신자·메시지와 발송 대기 본문은 암호화합니다. 관리자는 규칙 편집에서 고정 수신자를 확인할 수 있으며 이력에는 마스킹한 수신자를 표시합니다. 인증 비밀값은 다시 반환하지 않고 **저장됨** 여부만 표시합니다.

1. **발송 채널** 탭에서 **발송 채널 추가**를 선택합니다.
2. 이메일·문자·카카오톡·일반 HTTP 중 유형을 고릅니다. 문자와 카카오톡은 조직이 계약한 공급 API 또는 사내 게이트웨이의 요청 규격을 사용합니다.
3. 연결 주소, 인증과 메시지 매핑을 저장합니다. 기본 채널과 규칙은 비활성화 상태이므로 실제 운영 전에 각각 활성화 여부를 확인합니다.
4. 저장한 채널의 **테스트 발송**은 입력한 대상에게 실제 전달 요청을 생성합니다. 비활성 채널도 명시적인 시험 발송은 가능하며 테스트 요청자의 현재 관리자 권한·키 상태를 발송 전에 확인합니다. 템플릿 미리보기와 구분해 조직이 승인한 시험 주소·번호를 사용합니다.
5. **전달 이력**에서 대기·시도·접수 또는 오류를 확인한 뒤 운영 규칙을 활성화합니다.

채널은 최대 200개, 규칙은 최대 500개입니다. 이름은 제어 문자 없이 UTF-8 기준 200바이트까지입니다. 기존 채널·규칙의 PUT 수정에는 조회한 `updated_at`을 `expected_updated_at`으로 전달해야 합니다. 누락·잘못된 시각은 400, 동시 변경은 409로 거부하므로 최신 자료를 확인하고 다시 편집합니다.

채널·규칙을 수정하거나 삭제하면 해당 설정으로 만들어진 **발송 대기·재시도 대기** 항목을 취소합니다. 이미 발송 중이거나 접수된 메시지를 회수하는 기능은 아닙니다. 채널에 연결된 규칙 또는 발송 중인 알림이 있으면 채널 삭제를 거부합니다. 먼저 연결

규칙을 정리하고 이력을 확인하세요.

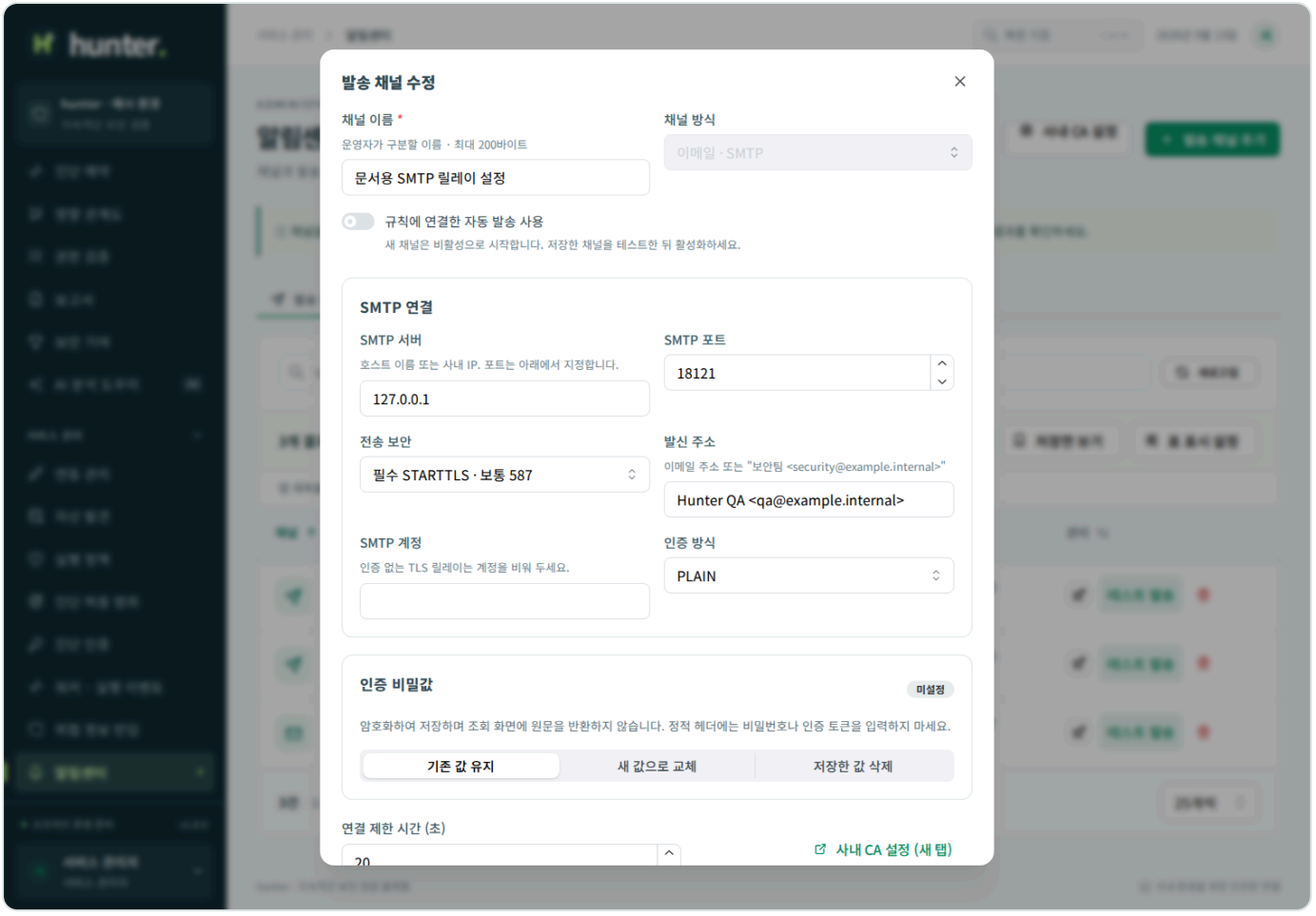
이메일 · SMTP

항목	입력과 동작
호스트·포트	프로토콜 없이 호스트명/IP와 1~65535 포트. 조직의 릴레이 주소 사용
보안	`tls` : 연결 즉시 TLS, `starttls` : STARTTLS 필수. `none` : 인증 정보 없는 사내 릴레이 전용
인증	PLAIN 또는 LOGIN. 인증 사용자와 비밀번호는 TLS에서 사용
발신 주소	릴레이가 허용하는 이메일 주소. 한 메시지의 수신자는 이메일 주소 하나
인증서	TLS 1.2 이상·호스트 검증. 서비스 설정의 사내 신뢰 CA 적용
시간 제한	연결·응답 확인을 포함한 1~30초, 기본 20초

통상 Implicit TLS는 465, STARTTLS는 587을 사용하지만 조직의 실제 릴레이 설정을 우선합니다. 필수 STARTTLS를 지원하지 않거나 인증서가 올바르지 않으면 실패하며 평문 인증으로 전환하지 않습니다. `none`에서 사용자 이름·비밀번호가 있으면 저장을 거부합니다.

저장된 인증을 없애려면 비밀값의 명시적 삭제를 선택합니다. 빈 비밀번호를 다시 저장하는 동작은 기존 비밀 유지이므로 무인증 릴레이로 전환할 때 사용자 이름과 비밀값을 모두 정리하세요.

제목과 본문은 한글 메일 형식으로 인코딩하며 SMTP 접수 응답을 확인합니다. SMTP 접수만으로 배달 실패·스팸함 분류·읽음을 알 수 없습니다. 별도 사내 게이트웨이가 제공하는 전달 결과는 13.13절의 서명 콜백으로 연결할 수 있으며 읽음은 별도입니다. 발신 도메인과 릴레이의 메일 정책은 해당 메일 시스템에서 관리합니다.

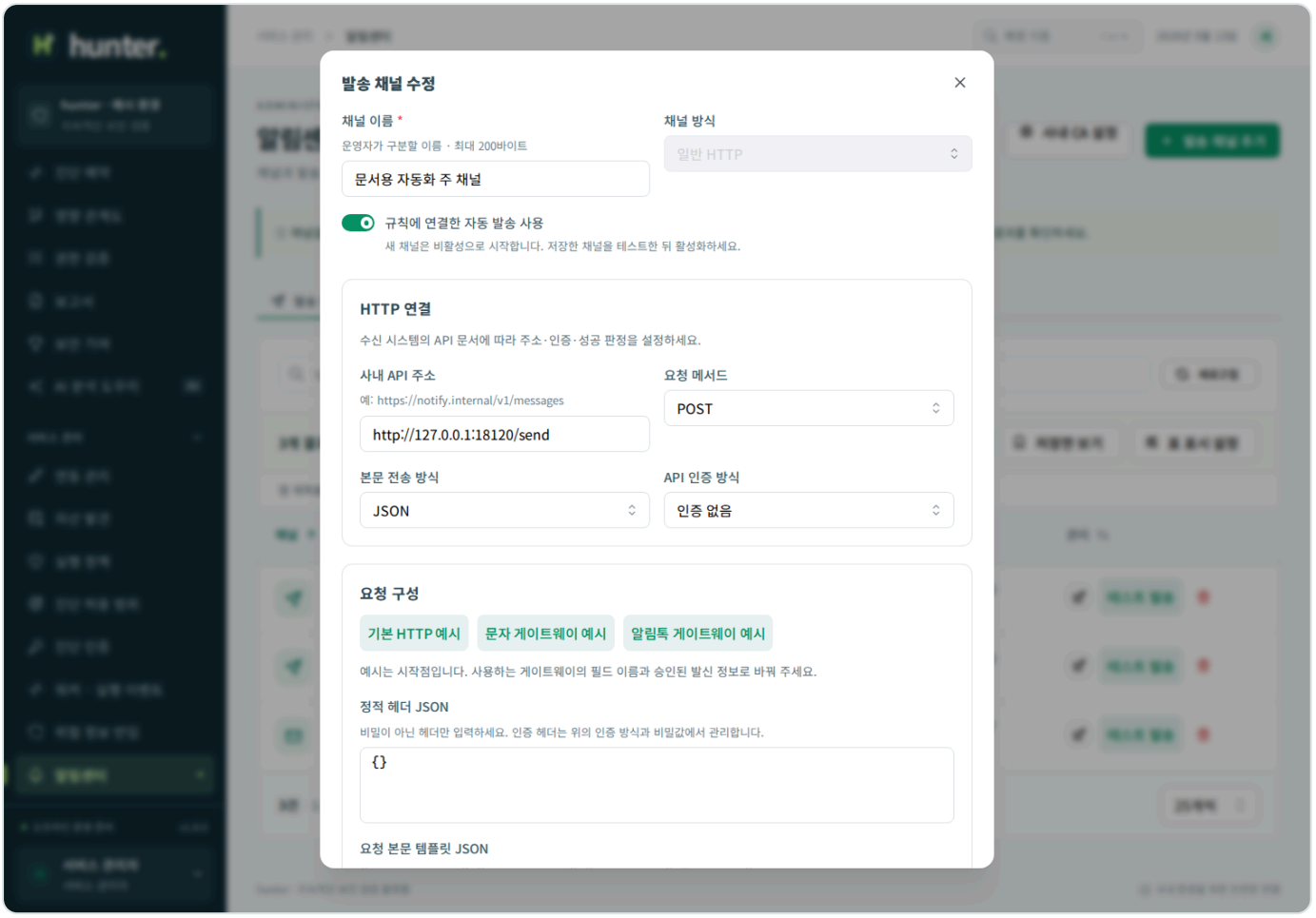


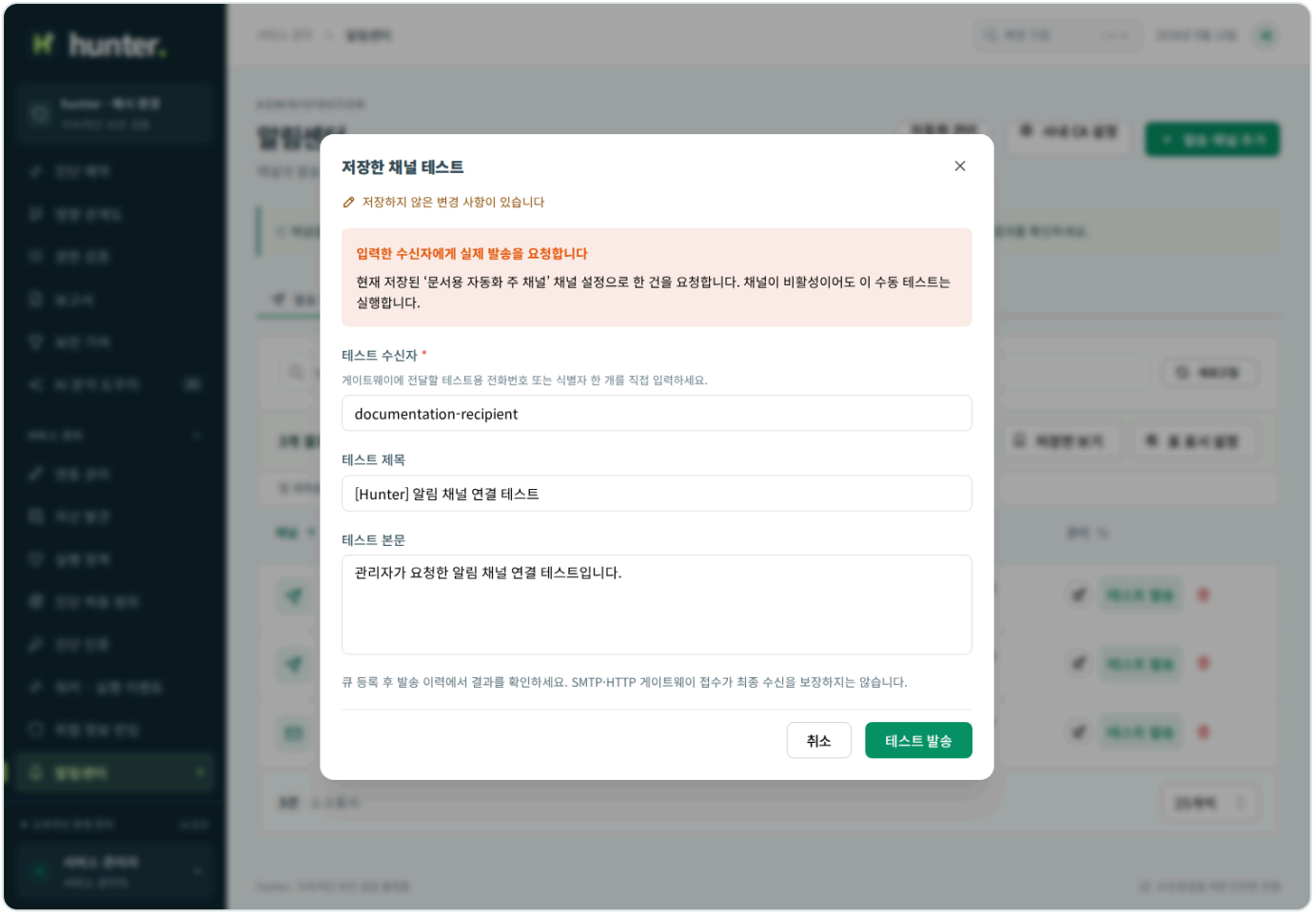
문자·카카오톡·일반 HTTP

항목	입력과 동작
API 주소	변수를 넣지 않는 고정 HTTP(S) URL. 사내 HTTPS와 신뢰 CA 사용 권장
메서드·본문	POST 또는 PUT. JSON은 중첩 객체·배열, Form은 문자열 값으로만 구성
인증	없음, Bearer, Basic, 사용자 지정 인증 헤더, 비밀 JSON 다중 헤더, NCP HMAC 서명
일반 헤더	최대 30개 문자열 값, 전체 16 KiB. 인증 토큰·쿠키는 일반 헤더에 넣지 않음
인증 비밀값	별도 입력에 저장하며 조회 시 원문 반환 안 함. 비밀 다중 헤더는 JSON 문자열 객체
본문 템플릿	JSON 객체 64 KiB까지, 생성한 요청 본문 256 KiB까지
성공 판정	점으로 구분한 `success_path` 와 문자열·숫자·참거짓 `success_value` 를 함께 설정
접수 ID	`id_path` 에 응답 필드 경로 지정. 배열은 `results.0.id` 처럼 번호로 접근
중복 방지	공급자가 실제 지원하는 경우에만 지원 여부 활성화 및 헤더 이름 입력

성공 경로를 생략하면 HTTP 2xx를 접수로 판단합니다. 200 응답 안에 업무 오류가 들어오는 API는 반드시 성공 필드와 값을 지정하세요. 성공 필드가 없거나 응답을 해석할 수 없으면 **결과 확인 필요**로 남깁니다. 응답 전문이나 인증 헤더는 전달 로그에 저장하지 않으며 정규화한 코드·안내와 허용된 접수 ID만 남깁니다.

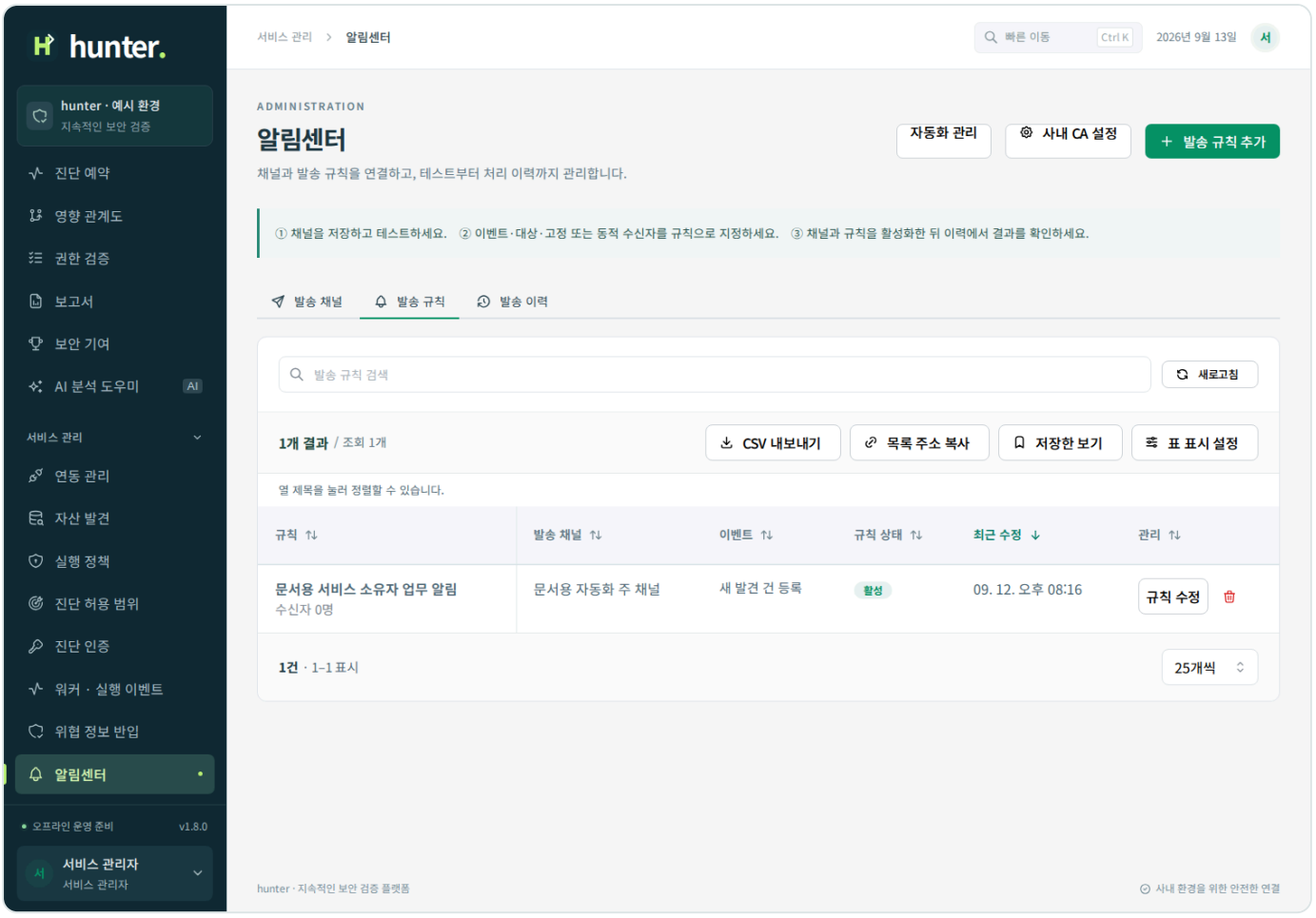
중복 방지 헤더에는 전달 ID에 기반한 동일 식별자를 보냅니다. 헤더를 보낸다는 이유만으로 공급자가 중복을 막는 것은 아닙니다. `idempotency_supported`는 실제 API 계약이 이를 보장할 때만 켭니다. 임의 셸 실행, 자바스크립트 본문 생성, URL 변수 치환과 OAuth 토큰 자동 갱신은 제공하지 않습니다.





13.7 발송 규칙과 템플릿

발송 규칙 → 발송 규칙 추가에서 저장된 채널과 이벤트, 필터, 고정 수신자, 제목·본문을 지정합니다. 고정 수신자는 규칙당 최대 100명이며 중복 주소는 저장을 거부합니다. 동적 수신자 소스가 없으면 최소 한 명이 필요합니다. 동적 소스는 13.11절에서 설명합니다. SMTP는 이메일, 문자·카카오톡은 8~16자리 전화번호, 일반 HTTP는 최대 200바이트의 수신 식별자를 사용합니다. 공급자가 요구하는 국가번호 표기는 별도 확인하세요.



이벤트	의미
`finding.created`	새 발견 건 등록
`finding.updated`	발견 건의 제목·심각도·상태·담당자·기한·CVE·구성요소 변경
`finding.due`	수동 기한 또는 활성 SLA의 기한이 지난 미조치 발견 건. 같은 유효 기한에 UTC 날짜별 한 번
`scan.completed`	진단 완료
`scan.failed`	진단 실패 또는 판단 불가
`approval.pending`	검토·승인 대기 생성. 승인 기능을 켠 업무에서 사용
`finding.due_soon`	활성 영업일 달력으로 계산한 기한 예고
`finding.unacknowledged`	지정 사용자가 기한까지 업무 확인을 하지 않은 발견 건
`team.weekly`	설정 요일·시각의 조직 주간 요약

서비스 필터는 최대 100개, 조직 필터는 최대 100개, 심각도는 다섯 단계 중 선택합니다. 필터가 비어 있으면 해당 조건으로 제한하지 않습니다. 알림 규칙이 팀장 승인 기능을 켜거나 실제 진단을 생성하지 않습니다. 이벤트가 발생하기 전 활성화한 규칙에 대해 동작하며 이전 전체 이력을 소급해 일괄 발송하는 기능이 아닙니다.

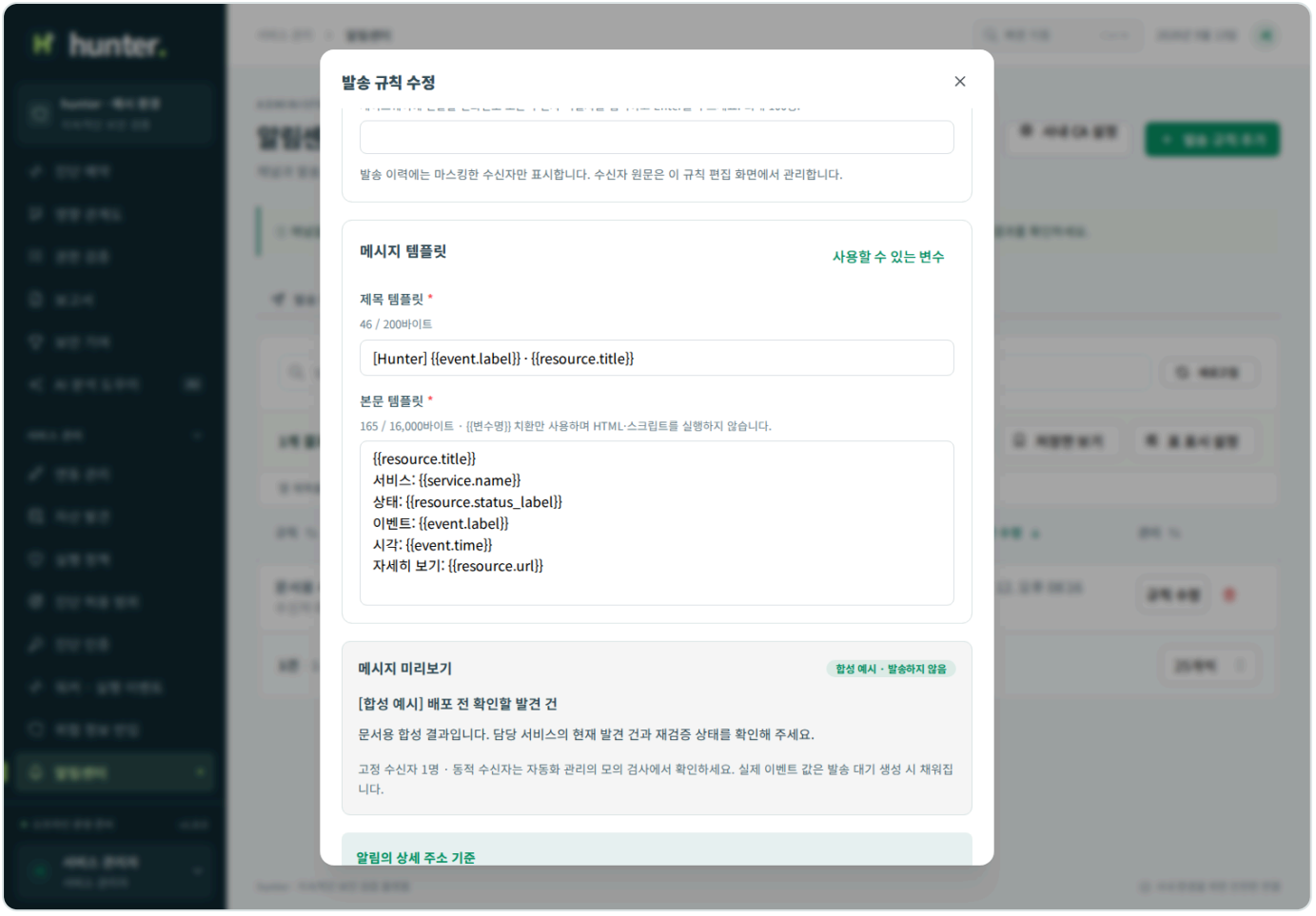
필터 종류 간에는 모두 만족해야 하고 한 종류의 여러 값은 하나와 일치하면 됩니다. 진단·승인 자체에는 발견 건 심각도가 없으므로 심각도 필터를 지정한 규칙과 일치하지 않습니다. 이벤트 종류에 맞춰 규칙을 나눕니다. 기한 알림은 해결·오탐과 만료 전 위험 수용을 제외하며 별도로 활성화하는 영업일 예고와 구분합니다.

제목 템플릿은 줄바꿈 없이 200바이트, 본문은 16,000바이트까지입니다. `{{service.name}}`처럼 지원 변수만 사용할 수 있습니다. 생성 결과도 마스킹과 바이트 한도를 적용하므로 공급자의 짧은 문자·승인 템플릿에는 필요한 요약만 넣습니다. 원본 증거·쿠키·인증 프로파일·AI 대화 전문은 템플릿 변수로 제공하지 않습니다.

변수 묶음	지원 변수
이벤트	`event.type`, `event.label`, `event.time`
서비스	`service.id`, `service.name`, `service.team`
공통 대상	`resource.id`, `resource.title`, `resource.status`, `resource.status_label`, `resource.url`
발견 건	`finding.id`, `finding.title`, `finding.severity`, `finding.severity_label`, `finding.status`, `finding.due_date`, `finding.assignee`, `finding.cve`
진단	`scan.id`, `scan.name`, `scan.status`
승인	`approval.id`, `approval.status`
주간 요약	`summary.total`, `summary.new`, `summary.resolved`, `summary.overdue`, `summary.period_start`, `summary.period_end`

다른 종류의 이벤트에는 해당 변수가 비어 있을 수 있습니다. 공통 알림에는 `resource.*`를 사용하고 발견 건 전용 문구는 발견 건 이벤트 규칙으로 분리하세요. **템플릿 미리보기**는 합성 값으로 제목·본문을 확인하며 외부로 발송하지 않습니다. 실제 사건의 비밀 원문을 입력해 시험하지 않습니다.

`event.label`, `resource.status_label`, `finding.severity_label`은 한국어 표시값입니다. `resource.url`은 기본 정보의 서비스 공개 주소로 만든 해당 업무의 상세 링크이며 로그인과 현재 권한이 필요합니다. 사내 사용자가 접근 가능한 공개 주소를 먼저 설정하세요.

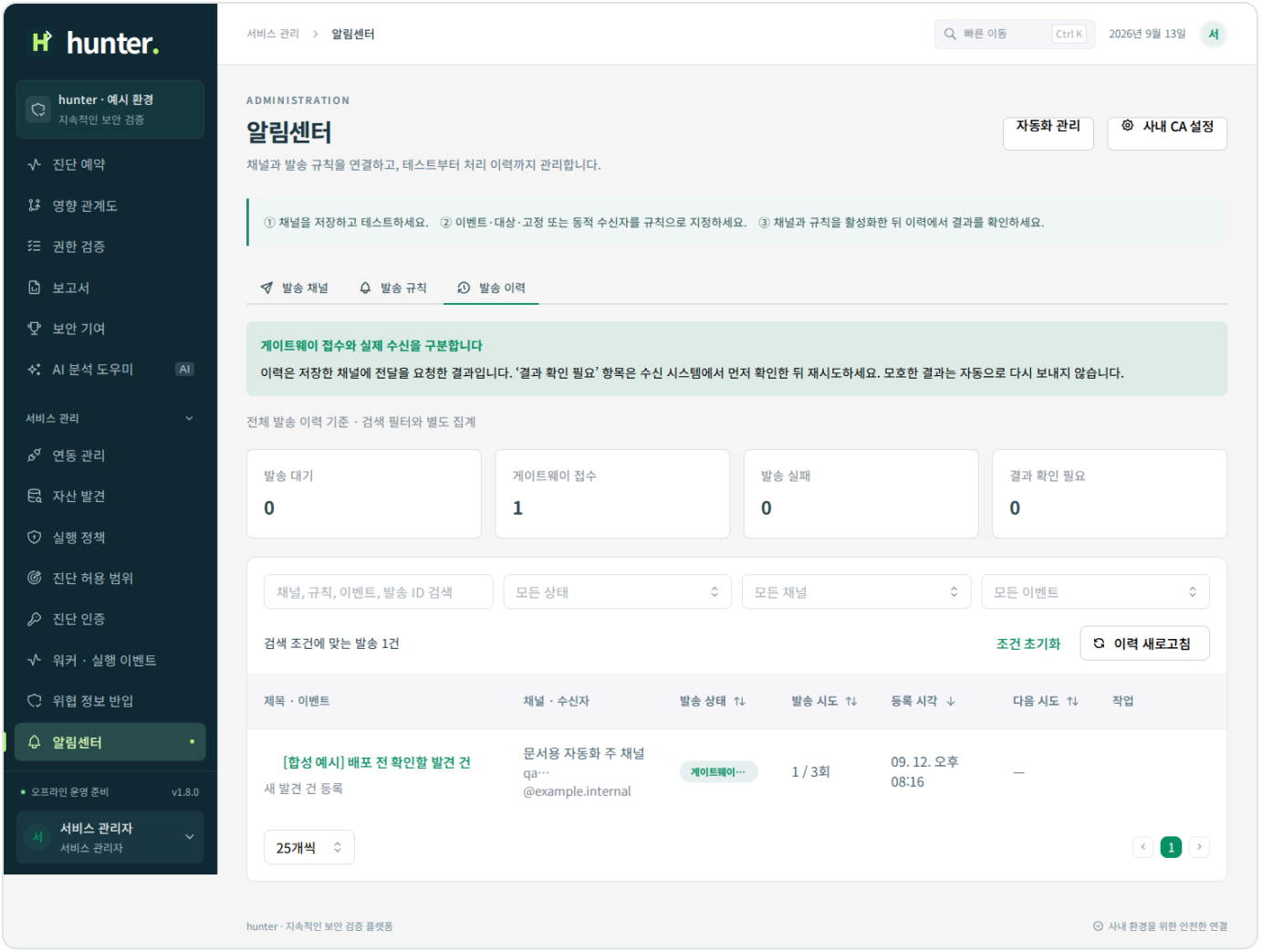


채널 HTTP 본문에는 위 변수 외에 `message.id`(전달 ID), `message.event_id`, `message.recipient`, `message.subject`, `message.body`를 사용할 수 있습니다. JSON 값 안의 변수를 치환한 뒤 JSON으로 인코딩하며 필드 이름에는 변수를 넣을 수 없습니다.

13.8 전달 이력과 오류 복구

발송은 PostgreSQL 대기열에서 처리하며 서비스 재시작 후에도 이력이 남습니다. 알림 처리는 웹·API를 제공하는 제어 서버에서 시작하며 `--worker-only` 진단 워커는 알림을 발송하지 않습니다. SMTP·메시지 API 연결은 제어 서버가 접근할 수 있어야 합니다.

전달 이력은 상태·채널·이벤트로 필터하고 전달 ID·채널명·규칙명·이벤트 종류를 검색합니다. 날짜·상태·시도 수로 정렬하고 상세에서 시도별 코드·안내·접수 ID를 확인합니다. 검색은 수신자 원문·본문·응답 원문을 대상으로 하지 않습니다. 상단 상태 요약은 전체 이력이며 목록의 검색 결과 수는 현재 조건에 해당하는 건수입니다.



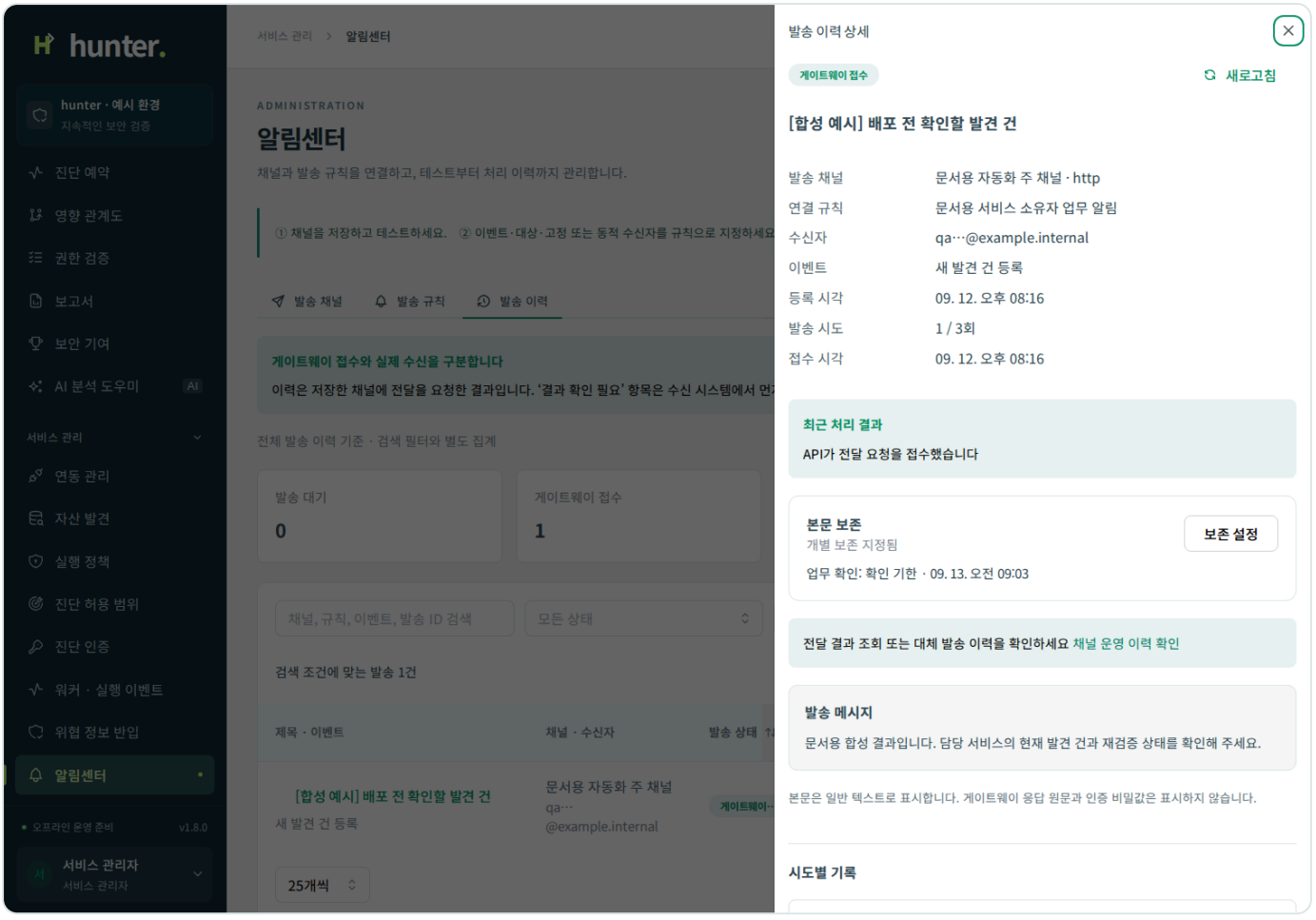
발송 전 현재 서비스·규칙·채널 조건을 다시 확인합니다. SLA를 끄거나 기한을 연장한 조치 알림, 승인 기능을 끄거나 이미 처리가 끝난 승인 대기 알림은 이전 대기 내용만 보고 발송하지 않습니다. 업무 긴급 중지는 진단 제어이며 알림 전체 중지 기능이 아니므로 필요한 채널·규칙을 별도로 비활성화합니다.

상태	운영자가 확인할 내용
발송 대기 (`queued`)	저장된 요청이 실행 순서를 기다림
발송 중 (`sending`)	채널에 요청 중. 취소가 이미 나간 요청을 회수한다고 해석하지 않음
게이트웨이 접수 (`sent`)	SMTP 또는 API가 요청을 접수. 최종 수신·읽음 보장 아님
재시도 대기 (`retry`)	안전하게 재시도할 수 있는 실패, 다음 시도 시각 확인
발송 실패 (`failed`)	요청 거부·설정 오류 또는 최대 시도 도달. 원인 확인 후 조치
결과 확인 필요 (`uncertain`)	전송 후 응답을 확인하지 못한 경우 등. 공급자 접수 여부부터 확인
취소됨 (`cancelled`)	대기 항목 취소 또는 설정 변경으로 실행 제외

자동 시도는 규칙당 1~5회로 제한하며 기본 3회입니다. 연결 전 실패, 명시적인 일시 제한 등의 재시도 가능한 경우만 처리합니다. 요청을 보낸 뒤 응답이 끊긴 경우나 서버 오류는 결과 불명일 수 있으므로 단순 실패로 자동 재발송하지 않습니다. 실제 중복 방지 계약을 설정한 HTTP 채널은 같은 식별자로 재시도할 수 있습니다.

수동 재시도는 접수 이력과 현재 채널·규칙 설정을 확인한 뒤 이유를 남깁니다. 결과가 불명확하면 중복 위험을 명시적으로 확인해야 합니다. 이미 접수된 항목을 “못 받았다”는 이유만으로 반복 발송하지 말고 릴레이·공급자 결과부터 확인하세요.

수동 재시도는 실패·결과 확인 필요 상태 중 전달 receipt·대체 요청이 없는 건에서만 가능하며, 결과 불명에는 앞뒤 공백을 제거한 8바이트 이상의 사유와 중복 위험 확인이 필요합니다. 현재 시도 수를 초기화해도 이전 시도 이력과 원래 전달 ID·본문·설정 기준은 유지합니다. 그 사이 채널·규칙이 변경됐다면 원래 요청을 새 설정으로 몰래 바꾸지 않고 취소하므로 새 테스트나 다음 이벤트로 확인합니다. 발송 중 처리가 중단되어 임대가 만료되면 결과 확인 필요로 남기며 자동으로 다시 보내지 않습니다. 해당 시도 시작 때부터 활성화한 결과 정책이 있으면 원래 전달 ID로 조회를 복구합니다. 발송 응답보다 먼저 도착한 올바른 서명 콜백도 해당 발송 시도에 연결합니다.



13.9 공급자 요청 매핑 예시

다음은 규격을 설명하는 예시입니다. 실제 주소·발신번호·채널 자격 정보·승인 템플릿은 조직에서 준비하며 공급 계정의 발송·과금·단말 도달까지 검증한 예시가 아닙니다. 공식 설계 근거에서 공급 계약의 차이를 확인할 수 있습니다.

일반 사내 HTTP 게이트웨이의 JSON 본문:

```
{
  "to": "{{message.recipient}}",
  "subject": "{{message.subject}}",
  "message": "{{message.body}}",
  "eventId": "{{message.id}}"
}
```

게이트웨이가 `{"accepted":true,"requestId":"req-001"}`로 응답한다면 성공 경로는 `accepted`, 값은 `true`, 접수 ID 경로는 `requestId`입니다. 제공자가 다른 응답을 사용하면 그 계약에 맞춰 변경합니다.

NCP 인증은 Access Key를 사용자 이름, Secret Key를 인증 비밀값에 넣고 JSON 본문을 사용합니다. 요청 URI·타임스탬프로 HMAC 서명을 만들므로 사내 서버의 시간이 맞아야 합니다. 문자 본문의 발신번호는 공급자에 등록된 값이어야 하며 UTF-8 입력 글자 수로 SMS 길이를 보장할 수 없습니다. 공급자의 EUC-KR 길이·이모지 정책과 SMS/LMS 유형을 확인합니다.

NHN 계열 알림톡처럼 별도 헤더를 쓰는 API는 사용자 지정 인증 헤더에 `X-Secret-Key`, 인증 비밀값에 실제 값을 지정할 수 있습니다. 본문에는 공급자의 발신 키·승인 템플릿 코드·수신 목록·치환값을 매핑합니다. 알림톡 심사·발신프로필 등록·공급자의 자체 대체 발송은 공급자에서 관리하며 Hunter가 자동 승인하거나 계약을 대신하지 않습니다. Hunter의 별도 대체 채널은 13.13절의 명시적 실패·한 단계 조건으로 동작합니다.

13.10 자동화 관리 시작하기

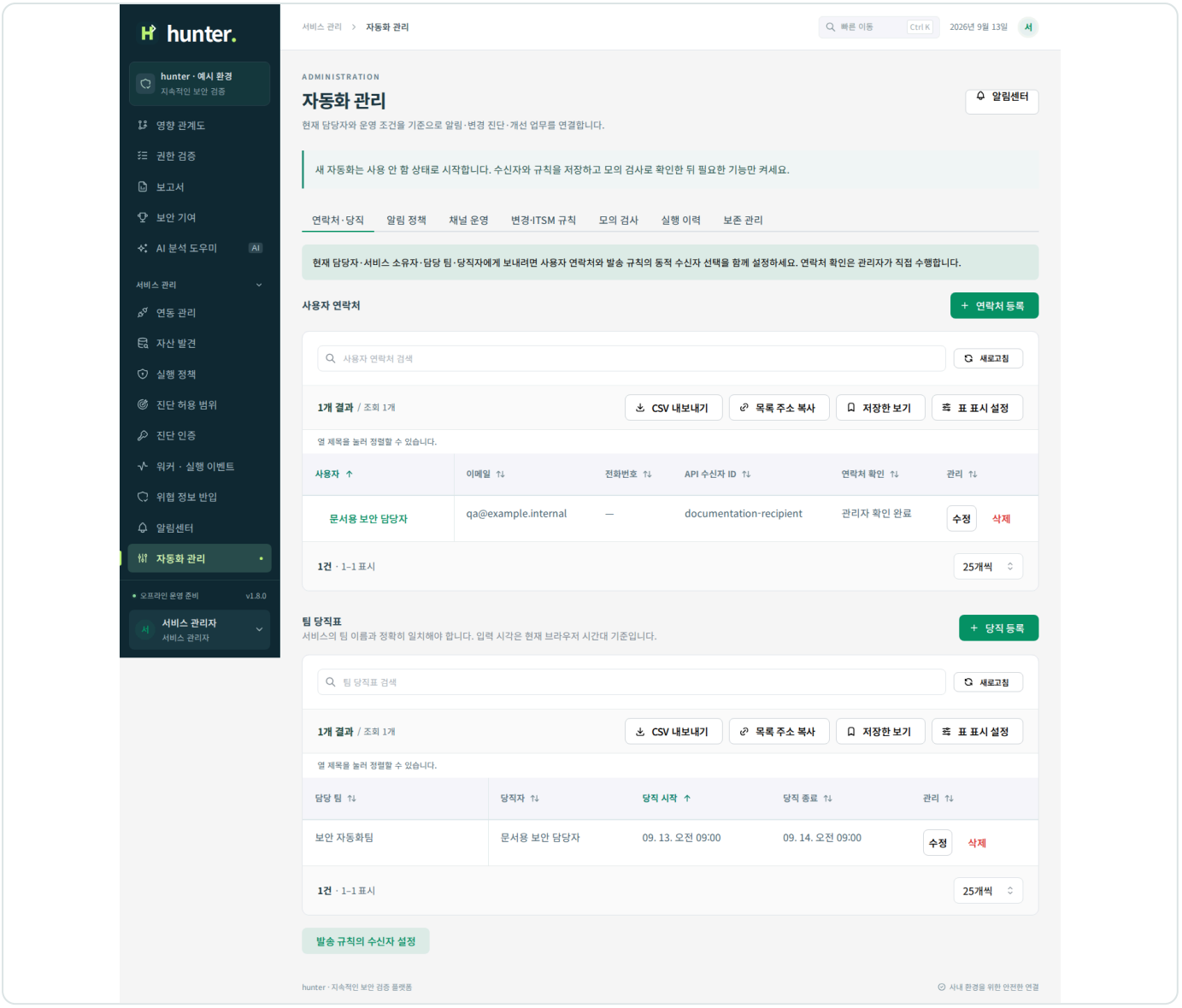
서비스 관리 → 자동화 관리(`/admin/automation`)에서 연락처·당직, 알림 정책, 채널 운영, 변경·ITSM 규칙, 모의 검사, 실행 이력, 보존 관리를 설정합니다. 알림 자동화·채널 운영·변경/ITSM 자동화는 각각 독립적으로 기본 비활성입니다. 한 설정을 켠다고 다른 설정이나 팀장 승인까지 켜지지 않으며 기존 고정 수신자 알림 규칙은 유지됩니다. 다만 이전 자동화 버전을 저장한 대기 건은 설정을 바꾸면 현재 기준 불일치로 취소될 수 있습니다.

운영 순서는 **연락처 확인 → 채널·규칙 설정 → 모의 검사 → 필요한 자동화 활성화 → 전달·업무 확인·실행 이력 점검**입니다. 변경 규칙의 미리보기는 진단을 만들지 않습니다. 반면 채널 테스트는 실제 발송 요청, ITSM 수동 동기화는 외부 GET과 로컬 변경, 배포 재검증은 허용된 실제 진단 요청입니다.

모든 관리자 설정은 `admin:manage`가 필요합니다. 개인 키는 관리자 역할이어도 해당 키 범위가 필요합니다. 알림 자동화와 채널 운영 API는 `{config, updated_at}`으로 조회하고 저장 시 `{config, expected_updated_at}`을 보냅니다. 변경·ITSM 설정은 평평한 설정 객체에 `expected_updated_at`을 추가합니다. 저장 충돌은 409로 처리하므로 입력을 유지한 채 최신 설정을 확인하세요. 비밀값은 재조회하지 않으며 빈값 유지·교체·명시적 삭제를 구분합니다.

새 기능도 같은 PostgreSQL과 네 환경변수로 운영합니다. 별도 메시지 브로커·외부 스케줄러·시간대 다운로드는 필요하지 않습니다. 발송·결과 조회·기한 예고·주간 요약·보존 작업·ITSM 폴링은 제어 서버에서 처리합니다. `--worker-only` 진단 워커에 새 발송 역할을 부여하지 않습니다.

13.11 연락처·당직과 동적 수신자



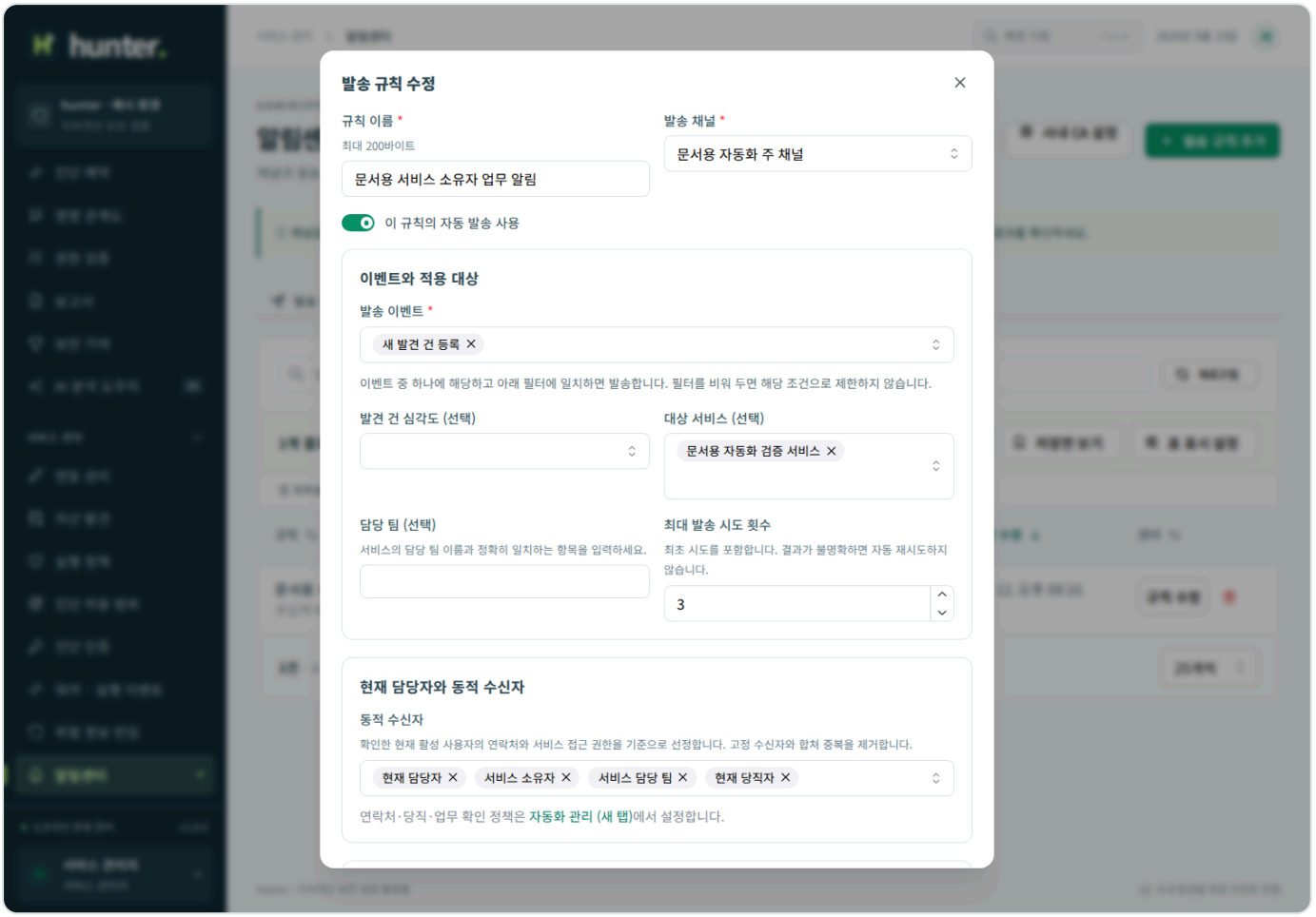
1. **연락처·당직**에서 활성 사용자의 이메일·전화번호·HTTP 수신 식별자를 등록합니다. 연락처와 당직은 각각 최대 500개입니다.
2. 실제 주소와 담당 사용자의 관계를 조직에서 확인한 후 **확인된 연락처**로 표시합니다. 이 표시는 관리자 확인 기록이며 Hunter가 OTP나 공급자 인증으로 주소 소유를 증명했다는 뜻은 아닙니다.
3. 당직은 조직·사용자·시작·종료 시각을 지정합니다. 기간은 최대 366일이며 해당 사용자의 연락처가 먼저 등록되어 있어야 합니다.
4. **알림센터 → 발송 규칙**에서 고정 수신자와 함께 동적 수신자 소스를 선택합니다. 동적 소스가 있으면 고정 수신자를 비워 둘 수 있습니다.

수신자 소스	선택 기준
`assignee` 담당자	발견 건 담당자 문자열과 정확히 일치하는 사용자 ID 또는 로그인 이름. 표시 이름의 유사 검색이나 외부 계정 자동 매핑 아님

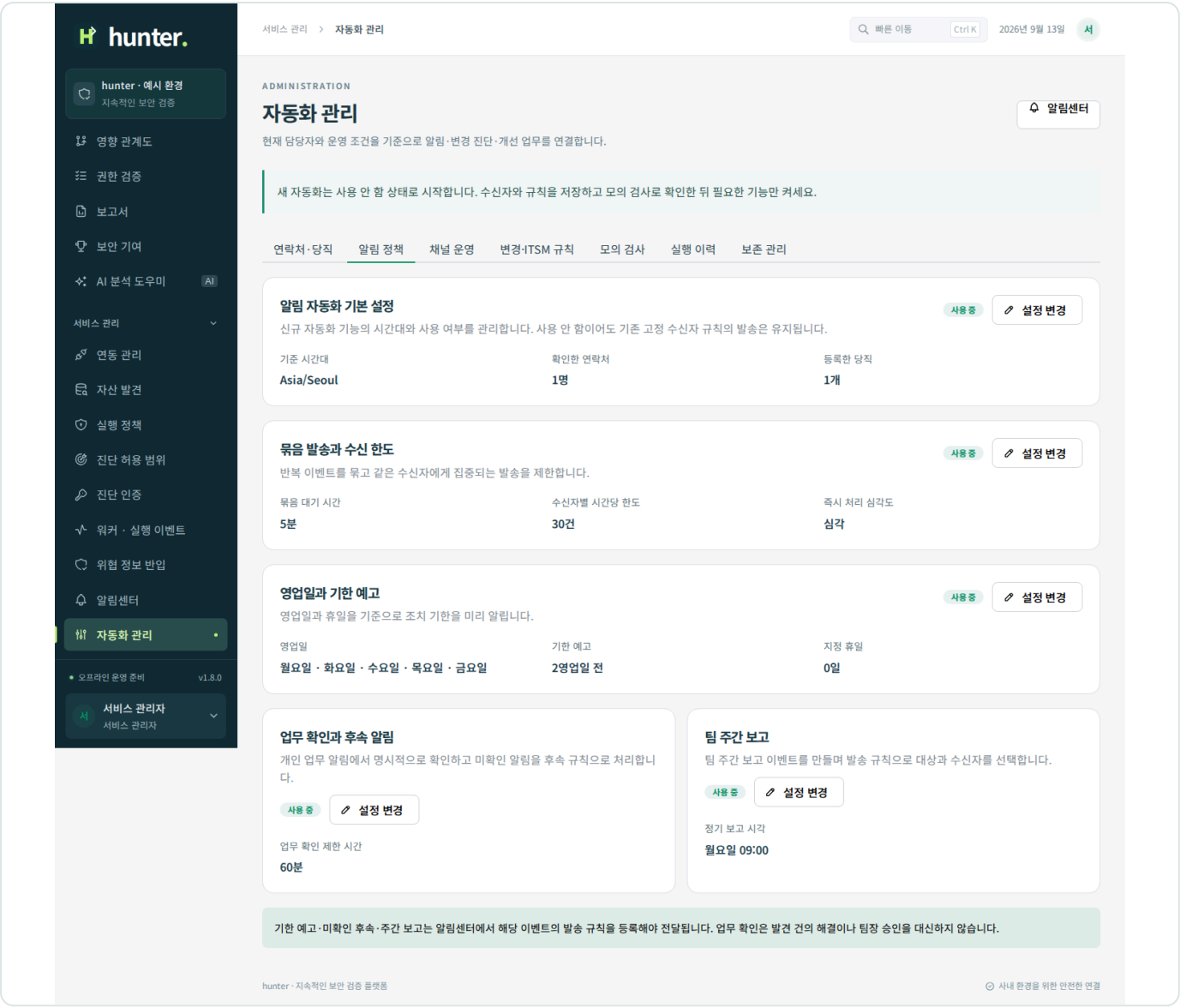
수신자 소스	선택 기준
`service_owner` 서비스 소유자	현재 서비스 등록 소유자
`team` 조직	현재 서비스 조직의 사용자 중 실제 자료 접근 권한이 있는 사람
`on_call` 당직	현재 조직·시각의 당직자 중 실제 자료 접근 권한이 있는 사람

발송 직전 현재 계정 활성 여부, 역할의 읽기 범위, 부모 서비스 접근, 연락처 확인 여부와 당직 기간을 다시 검사합니다. 다른 조직의 사용자나 권한을 잃은 사용자를 과거 담당자라는 이유로 계속 선택하지 않습니다. 묶음 알림은 포함된 모든 자료에 대한 현재 권한을 검사합니다.

고정·동적 수신자를 정규화해 합집합으로 만들며 규칙당 최종 100명까지입니다. 초과하면 일부에게만 보내지 않고 시도 0회 취소 이력에 한도 사유를 남깁니다. 같은 주소는 중복 발송하지 않습니다. 고정 주소만으로 생성한 전달은 사용자 ID가 연결되지 않아 개인 업무 알림·확인 대상이 되지 않습니다. 내 프로필 수정이 관리자가 등록한 연락처를 자동 갱신하는 기능은 아닙니다.



13.12 묶음·영업일·업무 확인·주간 요약



알림 정책에서 전체 알림 자동화와 필요한 하위 기능을 켭니다. 시간대 기본값은 `Asia/Seoul`이며 유효한 IANA 이름을 사용합니다.

설정	기본값과 허용 범위	운영 의미
묶음	꺼짐, 5분, 5~1440분	같은 규칙·이벤트·서비스·원인·수신자·시간 창의 최대 100사건을 한 전달로 모음
수신자별 시간당 한도	30건, 1~1000건	묶음 정책이 활성화된 일반 알림의 발송량 제한
긴급 예외	`critical`	지정 심각도는 묶음·시간당 한도 예외
영업일 기한 예고	꺼짐, 월~금, 2영업일	미래의 유효 기한이 설정한 1~30영업일 이내에 들어오면 예고
휴일	빈 목록, 최대 1000일	`YYYY-MM-DD`를 직접 등록. 공휴일 자동 수집 없음
업무 확인	꺼짐, 60분, 5~10080분	지정 사용자에게 확인 기한을 부여

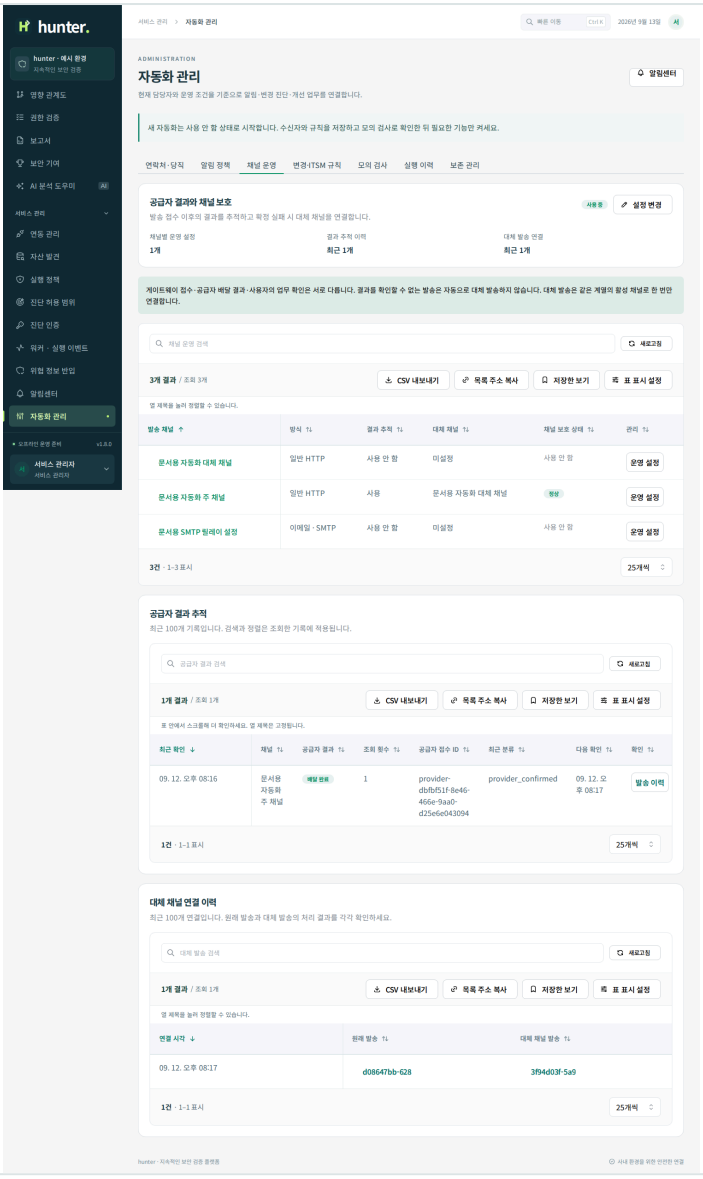
설정	기본값과 허용 범위	운영 의미
조직 주간 요약	꺼짐, 월요일 09시	설정 요일·시각 이후 현재 조직별 요약 사건 생성

신규 이벤트는 `finding.due_soon`, `finding.unacknowledged`, `team.weekly`입니다. 하위 설정만 켜고 해당 이벤트의 발송 규칙을 만들지 않으면 알림은 나가지 않습니다. 이미 지난 기한의 `finding.due`와 미래 영업일 예고는 서로 다른 규칙입니다. 수동 기한을 우선하고 SLA를 사용한 경우 현재 활성 상태와 일수를 다시 반영합니다.

업무 확인은 동적 수신자로 연결된 사용자의 **내 업무 알림**에서 수행합니다. 같은 건을 다시 확인해도 첫 확인 기록을 유지하며, 팀장 승인·반려나 발견 건 해결을 대신하지 않습니다. 기한을 넘긴 미확인 발견 건에는 별도의 사건을 한 번 생성하고 해당 규칙의 수신자에게 알립니다. 무한 반복 호출이나 다단계 전화 에스컬레이션 기능은 아닙니다.

주간 템플릿에 `summary.total`, `summary.new`, `summary.resolved`, `summary.overdue`, `summary.period_start`, `summary.period_end`를 사용할 수 있습니다. 동적 사용자는 현재 접근 가능한 서비스만 집계하며 요약에 기여한 서비스 범위를 보존해 이후 개인함 조회 권한도 다시 검사합니다. 고정 주소는 관리자가 지정한 조직 전체 요약을 받으며 사용자 개인함에 연결되지 않습니다. 조직 전체 자료를 받아도 되는 주소인지 규칙 저장 전에 확인하세요. **해결 수는 현재 해결 상태이며 기간 안에 변경된 발견 건 수**입니다. 상태 전환 전체 이력을 재생한 실제 해결 횟수나 MTTR로 해석하지 않습니다.

13.13 공급자 전달 결과와 채널 보호



채널 운영에서 기존 채널을 선택해 결과 조회, 서명 콜백, 대체 채널과 보호 정책을 등록합니다. 최대 200개 채널 정책을 저장할 수 있습니다. 먼저 공급자가 접수 ID와 개별 메시지 ID 중 무엇을 반환하는지, 어느 결과가 실제 전달 성공·실패를 뜻하는지 확인하세요.

HTTP 결과 조회는 기존 발송 API와 **같은 프로토콜·호스트·포트**에서만 허용합니다. GET 또는 조회용 POST, 상태 필드 경로, 전달·실패·대기 값을 지정합니다. 기본 주기는 60초(60~86400초), 최대 조회는 10회(1~100회)입니다. 응답은 64 KiB까지 읽고 본문 전문을 저장하지 않습니다. 공급자별 배치 조회·다음 페이지·결과 소비 확인 API가 필요한 경우 사내 어댑터에서 단일 건 조회로 정규화합니다.

주소 경로 또는 구조화한 query 값과 JSON 본문에서 `{{provider_id}}`, `{{delivery_id}}`를 사용할 수 있습니다. 호스트와 원시 query 문자열에 변수를 넣을 수 없으며 경로·query 식별자는 각각 안전하게 인코딩합니다. 기존 채널의 인증을 사용하며 상태 배열별 값은 최대 30개, query는 최대 30개, 조회 본문은 16 KiB까지입니다. HTTP 2xx 자체를 단말 전달 성공으로 매핑하지 말고 메시지별 결과 필드를 지정하세요.

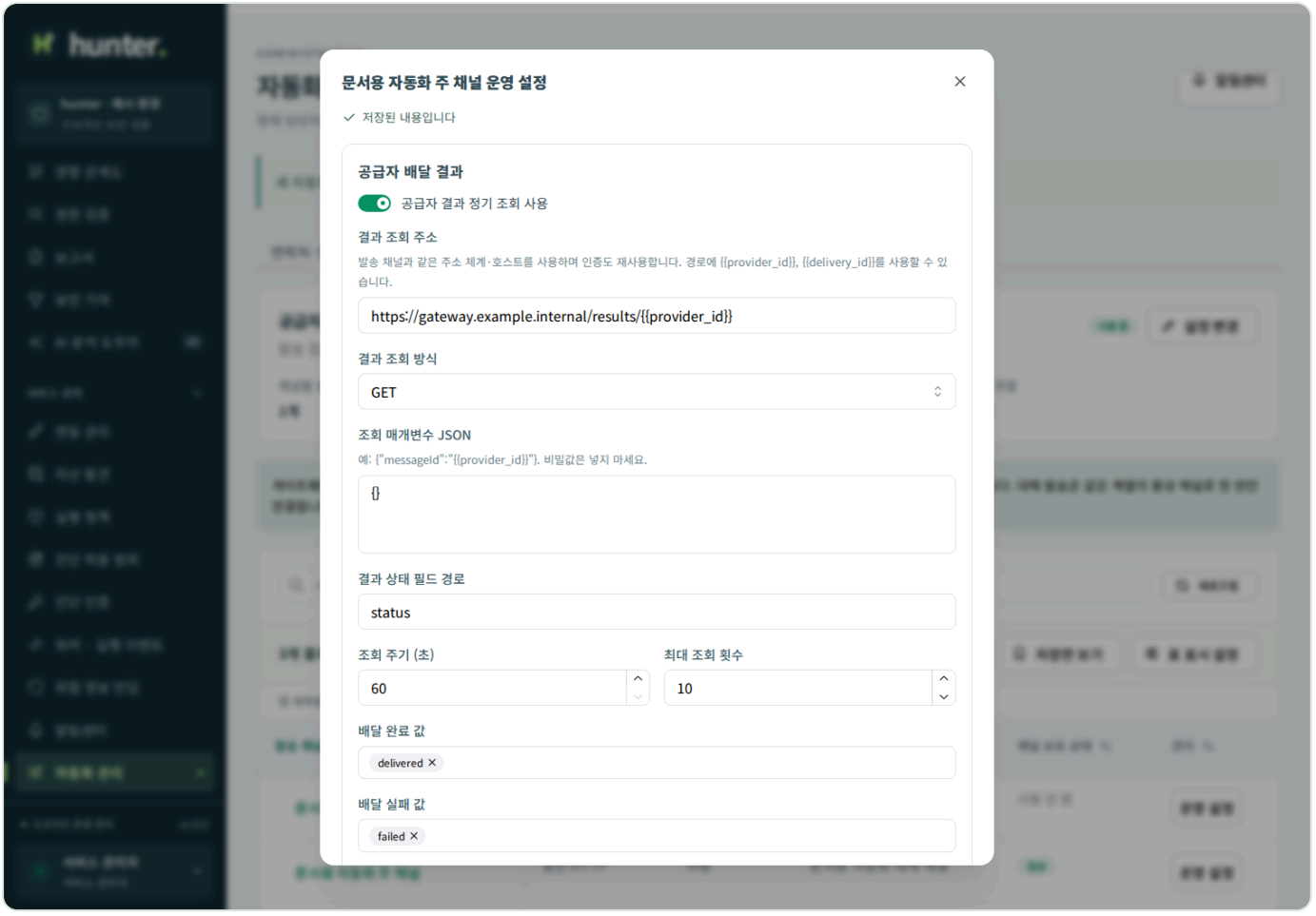
SMTP에는 표준 단일 건 HTTP 결과 조회가 없으므로 조회 API 설정을 켤 수 없습니다. 사내 메일 게이트웨이가 별도 전달 결과를 제공하면 Hunter 서명 콜백으로 정규화할 수 있습니다. 이는 SMTP 서버 접수만으로 읽음을 추정하는 기능이 아닙니다.

결과 상태	의미와 처리
`pending` 결과 대기	공급자 결과 확인 중. 발송 상태 `sent`와 별도
`delivered` 전달 확인	설정한 공급자 결과가 전달 성공을 나타냄. 사용자 읽음·업무 확인은 별도
`delivery_failed` 전달 실패 확인	명시적인 거부 또는 공급자 전달 실패. 설정한 대체 채널 검토 가능
`unavailable` 확인 불가	조회 한도·설정/식별 문제 등으로 확정 못함. 실패로 추정해 재전송하지 않음
`conflict` 결과 충돌	서로 다른 확정 결과 또는 접수 식별자 충돌. 관리자가 공급자 근거 확인

대체 채널은 다른 채널 중 같은 수신자 계열이어야 합니다. 문자↔카카오톡은 전화번호 계열, 이메일은 이메일 계열, HTTP 식별자는 HTTP 계열입니다. 순환 연결은 거부하며 원본 전달마다 **한 단계·한 번만** 만듭니다. 명시적으로 실패가 확인된 경우에만 현재 규칙·채널·수신자 접근을 다시 검사합니다. 대기·불명·충돌·단순 재시도 한도 소진을 전달 실패로 간주해 대체하지 않습니다. 이미 대체 요청이 있거나 receipt가 있는 같은 전달 ID는 수동 재발송도 허용하지 않습니다.

채널 보호 기본값은 연속 실패 5회(2~100회), 열림 대기 300초(30~86400초), 최소 간격은 API 생략 시 0초·화면 새 정책에서는 1초(0~3600초)입니다. 열림 동안 신규 처리를 늦추고 대기 후 기존 허용 요청 하나로 재개 여부를 확인합니다. 임의의 시험 수신자에게 자동 probe를 보내지 않습니다. **보호 해제**는 사유 8~1000바이트를 남겨 대기 제어를 초기화하며 과거 전달을 재발송하는 버튼이 아닙니다.

결과가 확정되지 않은 건의 **다시 조회**는 현재 설정과 기존 설정 버전이 일치할 때만 조회 횟수·시각을 재설정합니다. 메시지를 다시 보내지 않습니다. 설정·채널을 변경한 뒤 과거 receipt를 새 경로·상태값으로 재해석하지 않으며 확정·충돌 결과도 다시 조회로 덮어쓰지 않습니다. 운영 현황은 최근 채널 200개, receipt·대체 연결 각 100개를 표시하므로 전체 장기 통계로 합산하지 않습니다.



전달 결과 서명 콜백

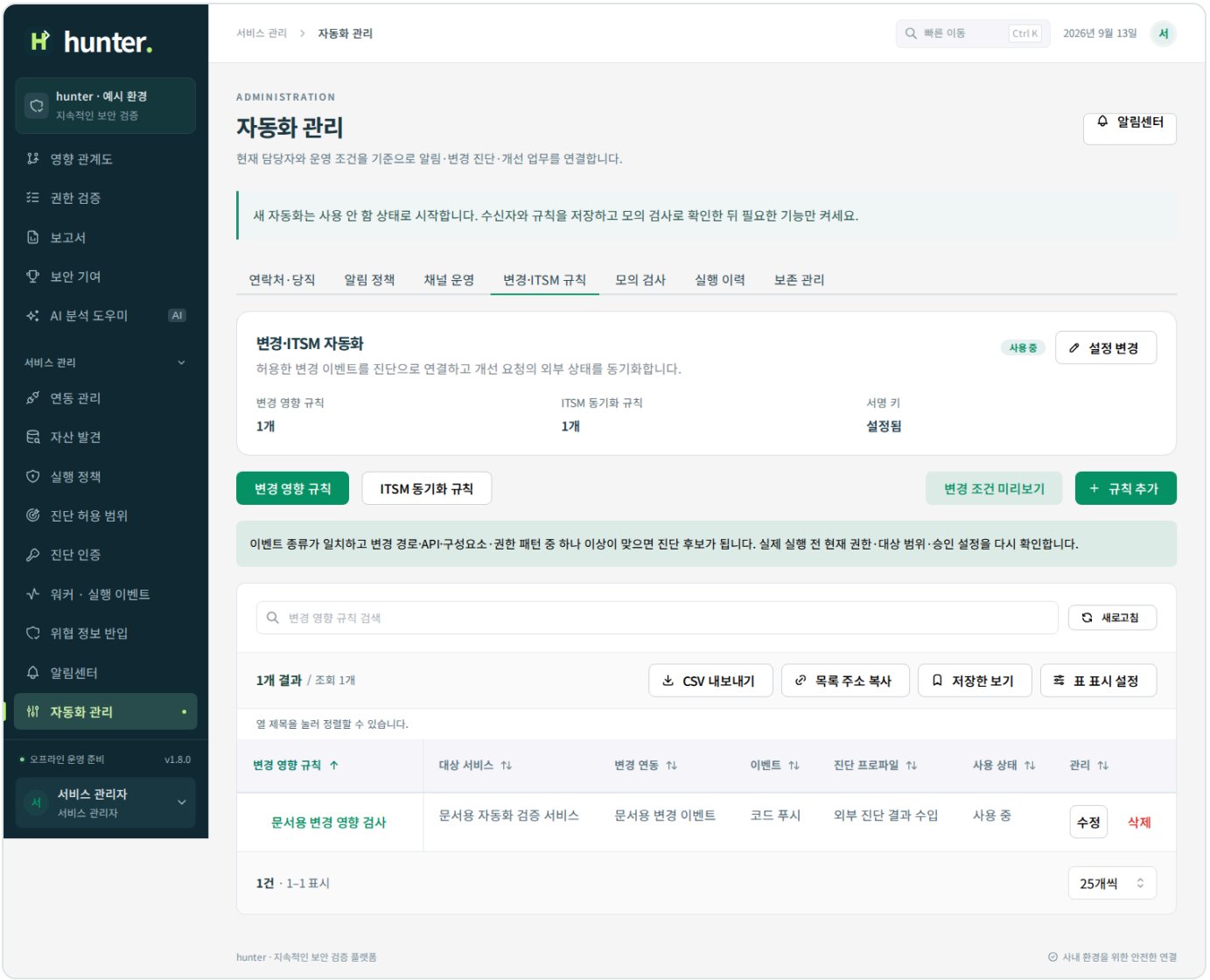
`POST /api/notification-receipts/{channelID}` 는 채널별 공유 비밀 32~1000바이트를 사용합니다. 일반 사용자 Bearer 대신 아래 서명을 검사합니다. 본문은 64 KiB 이하이며 정의되지 않은 필드를 거부합니다.

```
{
  "event_id": "gateway-result-001",
  "delivery_id": "HUNTER_DELIVERY_ID",
  "provider_id": "gateway-message-001",
  "status": "delivered",
  "occurred_at": "2026-09-12T09:00:00+09:00"
}
```

`X-Hunter-Timestamp` 는 Unix 초 단위 시각입니다. 현재 시각과 ±300초 이내여야 합니다. `X-Hunter-Signature` 에는 `HMAC-SHA256(secret, timestamp + "\n" + raw_body)` 의 **16진수만** 보냅니다. 전달 ID·채널·공급자 ID·설정 버전·시각을 검사하고 같은 이벤트 ID의 동일 내용은 중복 성공, 다른 내용은 409로 거부합니다.

이 엔드포인트는 **Hunter 사내 게이트웨이 계약**입니다. 문자·알림톡 공급자의 콜백 URL을 그대로 지정한다고 자동 호환되지 않습니다. 공급자 서명을 검증하는 중계기에서 필요한 결과만 정규화한 후 Hunter 방식으로 서명하세요. 비밀값·수신자 원문·공급자 응답 전문을 콜백 예제나 로그에 남기지 않습니다.

13.14 변경 영향별 진단 선택



변경·ITSM 규칙 → 변경 영향 규칙에서 웹훅 연동, 서비스, 이벤트와 실제 변경 항목 패턴을 지정합니다. 규칙은 최대 50개입니다. 이벤트는 `push`, `pull_request`, `merge`, `image`, `harbor_push`, `deploy`, `api_change`, `iam_change`, `prompt_change`, `manual` 중 선택합니다.

변경 그룹은 `paths`(파일 경로), `api_paths`(API 경로), `components`(SBOM·패키지 식별자), `permissions`(권한 영역)입니다. `*`는 슬래시 없는 문자열, `**`는 경로 구분을 포함한 문자열, `?`는 슬래시가 아닌 한 문자와 일치합니다. 문자 클래스나 백슬래시 패턴은 지원하지 않습니다. 규칙당 전체 패턴은 최대 100개·각 512바이트이며 **어느 그룹이든 한 패턴이 실제 변경 항목과 일치하면** 후보가 됩니다. 프로파일은 내장 HTTP, 권한 시나리오 또는 외부 반입용이며 시나리오·범위는 같은 서비스에 속해야 합니다.

미리보기에서 합성 변경 목록을 넣고 매칭 규칙, 허용 여부와 불가 사유를 확인합니다. 실제 웹훅은 현재 `integrations:manage`, `services:read`, `scans:read`, `scans:write`를 가진 개인 Bearer 키와 별도 HMAC 서명

이 모두 필요합니다. 설정 주체의 권한을 무제한 관리자 권한으로 대체하지 않습니다.

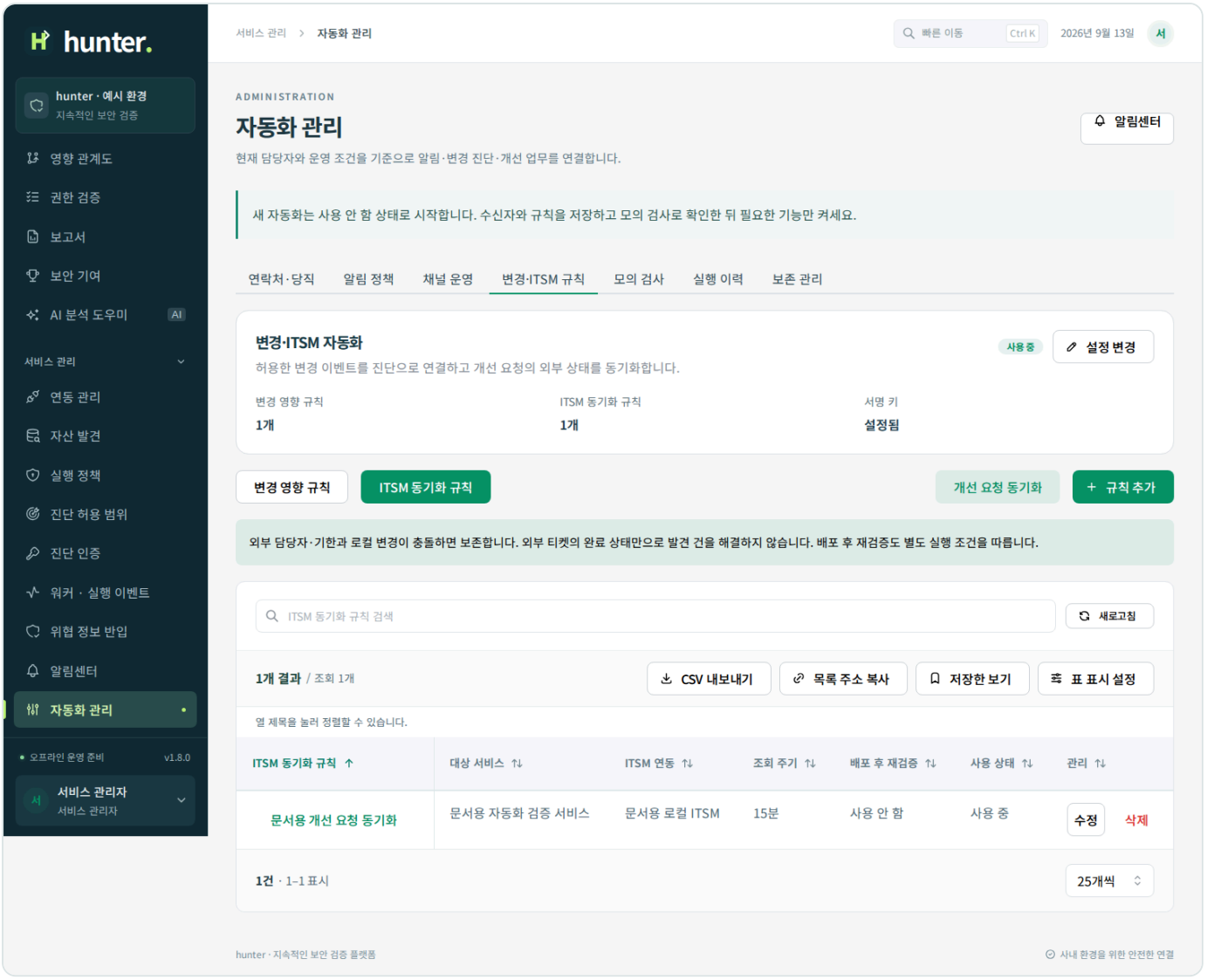
```
{
  "service_id": "SERVICE_ID",
  "event_type": "push",
  "reference": "pipeline-001",
  "changes": {
    "paths": ["src/auth/session.go"],
    "api_paths": ["/api/session"],
    "components": [],
    "permissions": ["session.read"]
  }
}
```

기존 `POST /api/integrations/{id}/webhook`로 원문 JSON을 보냅니다. `X-Hunter-Timestamp`와 `X-Hunter-Signature`는 위와 같은 타임스탬프+개행+원문 HMAC이며 변경·ITSM 설정의 전용 서명 비밀을 사용합니다. 이 경로는 16진수 앞의 `sha256=`도 허용합니다. 전체 본문 1 MiB, 실제 변경 값 총 1000개·각 512바이트, 참조 200바이트 한도입니다. GitHub·GitLab의 원본 페이로드·서명과 다르므로 CI 또는 승인된 중계기에서 정규화·재서명합니다.

같은 연동·서비스·참조의 동일 내용은 기존 실행을 돌려주며 내용을 바꿔 재사용하면 409입니다. 실제 변경 항목이 없는 호출을 변경 규칙으로 무조건 실행하지 않습니다. 선택한 규칙 간 같은 프로파일·범위·시나리오는 한 검사로 합치며 이벤트당 최대 20개를 요청합니다. 정책 준비 후 현재 계정·역할·팀·키·서비스·연동·설정 버전을 다시 검사하고 진단·이력을 한 트랜잭션으로 저장합니다. 워커도 실행 때 정책을 재검사합니다.

실행 이력에서 `completed`, `partial`, `blocked`, `no_match`와 매칭 근거·불가 사유·진단 ID를 확인합니다. 규칙 실행 완료는 생성한 진단이 모두 끝났다는 뜻이 아닙니다. `import-only`는 외부 결과 대기 건만 만들고 SAST·Trivy 등 외부 엔진을 실행하지 않습니다.

13.15 ITSM 조회·콜백 동기화



기존 **개선 요청**의 명시적 POST 발송에 성공해 외부 티켓 ID가 있는 건을 대상으로 합니다. **변경·ITSM 규칙 → ITSM 동기화 규칙**에서 REST 연동·서비스와 읽기 주소, 필드 매핑을 설정합니다. 규칙은 최대 50개이며 같은 서비스·연동에 하나만 둘 수 있습니다.

항목	입력과 동작
조회 주소	`https://itsm.internal/tickets/{{external_id}}` 처럼 토큰 하나. 연동 주소와 동일한 프로토콜·호스트·포트, GET만 허용
필수 필드	외부 ID·상태·변경 시각의 점 경로
선택 필드	담당자·기한·배포 참조·배포 확인
조회 주기	5~10080분, 기본 15분. 다음 조회 시각과 짧은 작업 임대로 중복 폴링 제한
시각 형식	외부 변경 시각과 기한은 시간대가 포함된 RFC3339. 날짜만 주는 공급자는 중계기에서 변환
완료 상태	최대 20개. 외부 상태 메타데이터이며 발견 건 상태로 직접 매핑하지 않음

항목	입력과 동작
배포 재검증	기본 꺼짐. 완료 상태+배포 확인 참값+배포 참조가 모두 있을 때 현재 정책으로 요청

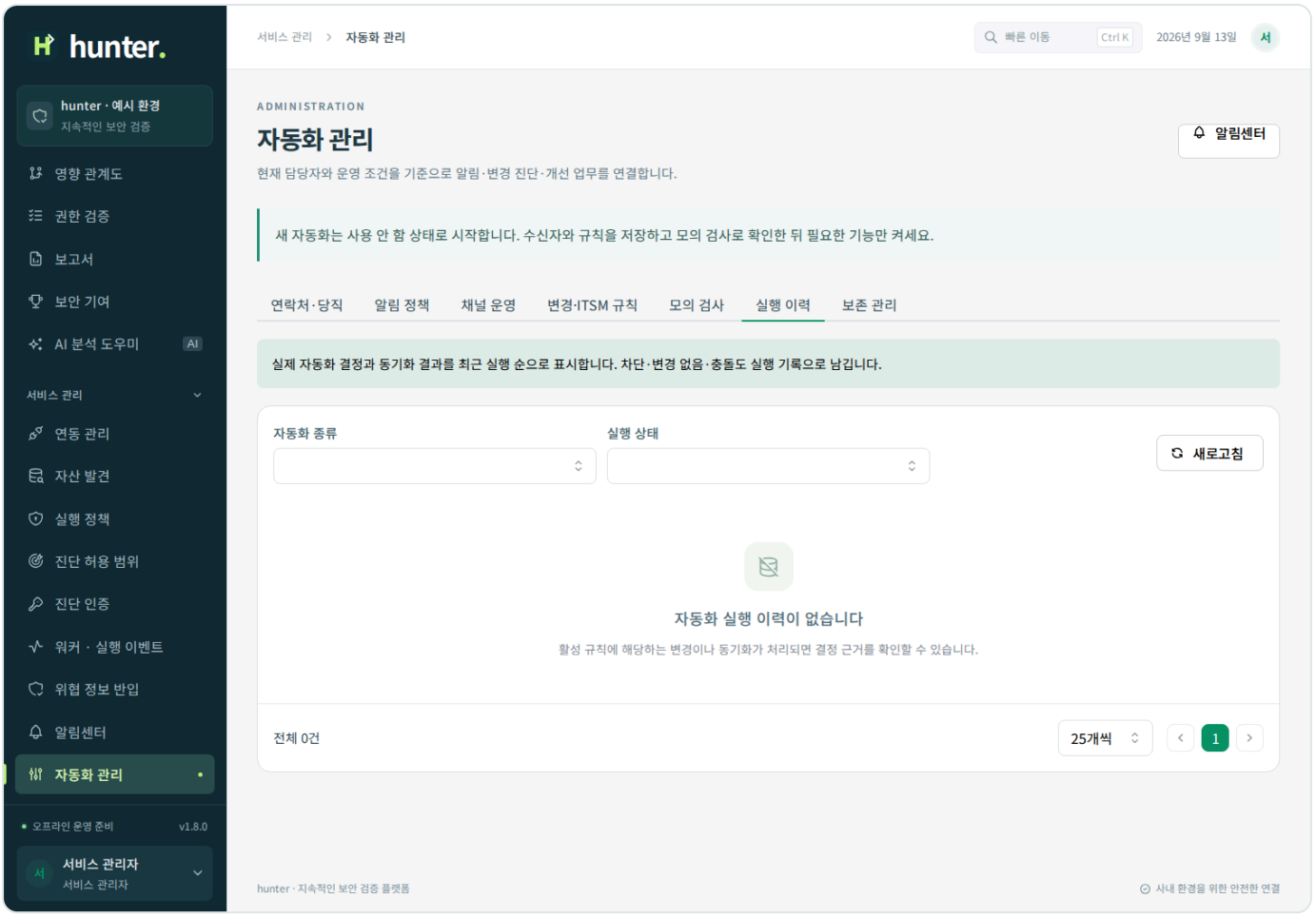
연동의 암호화된 Bearer 비밀로 조회하고 리다이렉트를 따르지 않습니다. 응답은 1 MiB·10초 이내이며 인증·응답 전문은 실행 이력에 남기지 않습니다. 외부 ID는 단일 안전 식별자, 담당자는 최대 200바이트 문자열입니다. 외부 담당자와 Hunter 계정의 변환은 조직이 매핑한 문자열에 따릅니다. 모든 ITSM 공급자의 사용자·날짜 형식을 자동 변환하지 않습니다.

수동 동기화에는 개선 요청 ID와 조회한 `updated_at`을 `expected_updated_at`으로 전달합니다. 기준값은 외부 발송 성공 당시의 로컬 담당자·기한부터 저장하며 동기화 성공 후 갱신합니다. 로컬이 그 기준값을 유지했다면 첫 조회라도 외부 변경을 반영합니다. 외부 담당자·기한이 기준과 달라지고 로컬도 따로 바뀌었으면 충돌로 남기며 입력을 덮어쓰지 않습니다. 외부 값을 적용하기로 결정한 경우 `accept_external:true`, 확인 당시 발견 건의 `expected_finding_updated_at`, 충돌 결과의 `expected_external_updated_at`을 함께 명시합니다. 버튼을 누를 때 새 revision을 자동 조회해 동의를 대신하지 않습니다. 현재 로컬 또는 외부 시각이 바뀌었거나 외부가 같은 시각으로 내용을 바꿨다면 원래 동기화 기록의 해시 대조로 409를 반환합니다. 최신값을 다시 확인한 뒤 명시적으로 대체해야 합니다. 외부 시스템이 같은 수정 시각으로 다른 내용을 반환하면 그 시각의 기록은 덮어쓸 수 없으므로 공급자나 중계기의 버전 정보를 먼저 바로잡습니다. 이전 버전에서 발송해 기준값이 없는 티켓도 로컬의 비어 있지 않은 다른 값을 자동 덮어쓰지 않습니다.

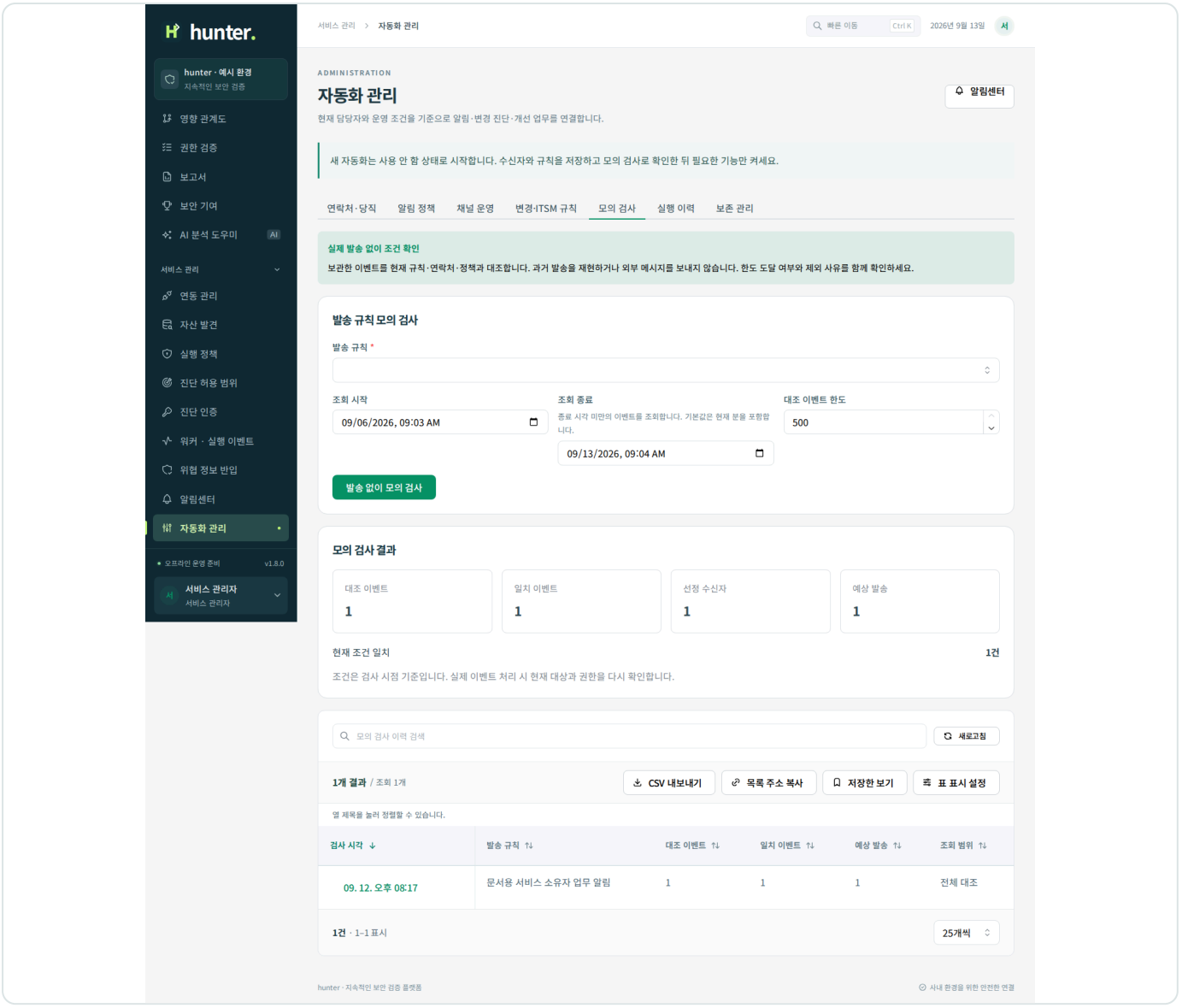
서명 콜백은 `POST /api/integrations/{id}/tickets/callback`에 `{"remediation_id":"ID","ticket":{...}}`로 전달합니다. 현재 Bearer 권한과 변경 규칙과 동일한 Hunter HMAC을 모두 검사합니다. 동일 외부 변경 시각·정규화 내용은 멱등 처리하고 같은 시각의 다른 내용은 409입니다. 과거 외부 버전은 새 상태를 덮어쓰지 않습니다.

외부 완료만으로 발견 건을 해결하거나 진단을 만들지 않습니다. 배포 확인이 있고 옵션이 켜져 있을 때에만 원래 지원되는 내장 HTTP 발견 건의 재검증을 요청합니다. 유효 범위·현재 사용자/키·정책·선택적 승인을 통과해야 하며 불가 사유는 이력에 남습니다. 같은 배포 참조는 외부 변경 시각이 달라져도 중복 재검증하지 않습니다. 해결 판정은 기존 실제 재검증 결과에 따릅니다.

자동 폴링은 설정을 저장한 현재 사용자의 역할·팀·키를 다시 검사합니다. 키 회전·폐기·만료나 역할 변경으로 권한이 사라지면 새 유효 설정 주체로 검토·저장하세요. 실행 이력 조회에는 관리자 권한 외에 `integrations:manage`, `services:read`, `findings:read`, `scans:read`가 모두 필요합니다. 이력은 종류·상태·서버 페이지를 지원하며 기본 최신순이고 임의 정렬·본문 검색은 제공하지 않습니다.


hunter.
hunter · 예시 환경
지속적인 보안 검증
영향 관계도
권한 검증
보고서
보안 기여
AI 분석 도우미
AI
서비스 관리
연동 관리
자산 발견
실행 정책
진단 허용 범위
진단 인증
워커 · 실행 이벤트
위협 정보 반입
알림센터
자동화 관리
오프라인 운영 준비
v1.8.0
서비스 관리자
서비스 관리자
서비스 관리 › 자동화 관리
빠른 이동 Ctrl K
2026년 9월 13일
서
ADMINISTRATION
자동화 관리
현재 담당자와 운영 조건을 기준으로 알림·변경 진단·개선 업무를 연결합니다.
알림센터
새 자동화는 사용 안 함 상태로 시작합니다. 수신자와 규칙을 저장하고 모의 검사로 확인한 뒤 필요한 기능만 켜세요.
연락처·당직
알림 정책
채널 운영
변경·ITSM 규칙
모의 검사
실행 이력
보존 관리
실제 자동화 결정과 동기화 결과를 최근 실행 순으로 표시합니다. 차단·변경 없음·충돌도 실행 기록으로 남깁니다.
자동화 종류
실행 상태
새로고침
자동화 실행 이력이 없습니다
활성 규칙에 해당하는 변경이나 동기화가 처리되면 결정 근거를 확인할 수 있습니다.
전체 0건
25개씩
1
hunter · 지속적인 보안 검증 플랫폼
사내 환경을 위한 안전한 연결

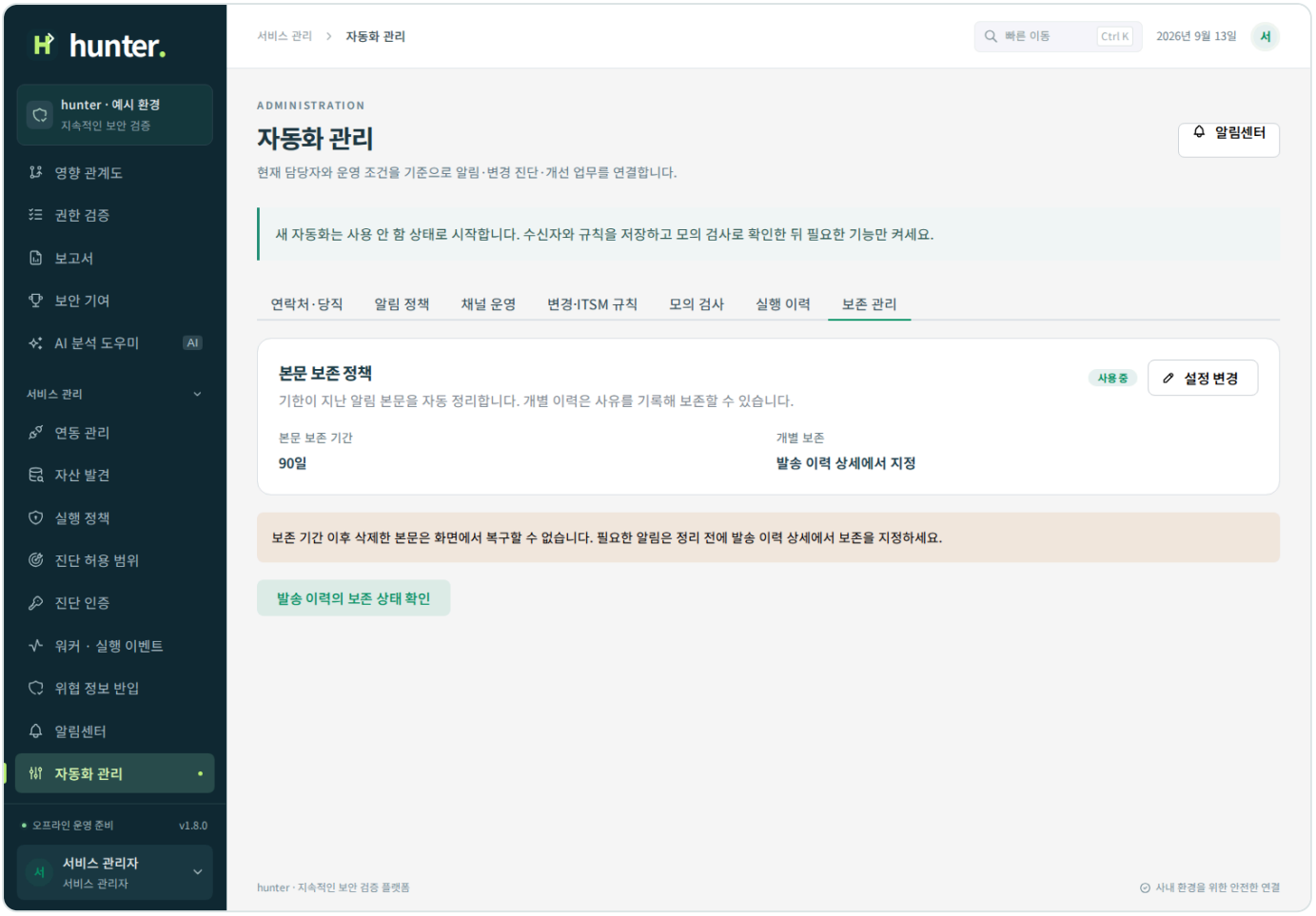
13.16 발송 없는 모의 검사



모의 검사에서 저장된 규칙, 시작·종료 시각, 검사 건수를 지정합니다. 기간은 최대 366일, 기본 500건·최대 1000개의 보관된 이벤트를 확인합니다. 결과에는 검사·일치 건수, 이벤트별 수신자를 합한 누적 대상 수, 예상 전달 수, 제외 사유와 최대 100개 샘플이 표시됩니다. 같은 사람이 여러 사건의 수신자이면 누적 대상 수에 반복 포함되므로 고유 사용자 수와 다릅니다. 최근 실행 결과 20개를 다시 볼 수 있습니다.

이 검사는 **현재 규칙·자료·담당자·권한**으로 과거 이벤트를 다시 평가하는 추정입니다. 당시 연락처나 삭제된 사건의 완전한 재생이 아니며 실제 공급자 접수·단말 전달까지 예측하지 않습니다. 새 메시지·진단·외부 티켓을 만들지 않고 수신자 주소 원문도 결과에 남기지 않습니다. 조건이 맞지 않거나 자료가 사라졌거나 수신자가 없으면 해당 사유를 확인하고 운영 규칙을 조정합니다.

13.17 보존 기간과 알림 본문 파기



보존 관리에서 전체 알림 자동화와 보존 정책을 켜고 본문 보존 일수를 지정합니다. 기본 90일, 1~3650일을 허용합니다. 적격 종결 상태 `sent`, `failed`, `cancelled`를 작은 배치로 처리합니다. 대기·발송 중·재시도·결과 불명, 업무 미확인, 미정 전달 결과, 활성 대체 연결과 보존 고정 건은 파기하지 않습니다.

전달 이력 상세에서 **보존 고정** 또는 해제를 선택할 때 8~1000바이트의 사유를 남깁니다. 이미 파기한 본문은 고정하거나 복원할 수 없습니다. 업무상 보존이 필요한 건은 기한 전에 고정하고 관리자 감사 기록과 함께 관리하세요.

파기는 암호화된 본문·수신 정보·시도 상세와 종결 receipt의 공급자 접수 ID를 제거하고 ID·상태·콜백 해시·중복 방지 표식·묶음 및 대체 연결을 유지합니다. 모의 검사 결과도 같은 보존 일수가 지난 기록을 정리합니다. 이후 상세에는 본문 파기 안내와 시각이 표시됩니다. 개인함에는 파기한 본문이 나타나지 않습니다. 이 정책은 백업, 별도 복제본, 수신자의 메일함과 외부 공급자 보관본을 소급 삭제하지 않습니다. 조직의 보존 정책에 맞춰 백업·게이트웨이도 별도로 관리합니다.

13.18 자동화 API 빠른 참조

기능	API
연락처·당직·알림 정책·보존	`GET/PUT /api/notification-automation`
모의 검사·최근 결과	`POST /api/notification-automation/simulate`, `GET /api/notification-automation/simulations`

기능	API
개인 업무 알림·확인	`GET /api/my-notifications`, `POST /api/my-notifications/{id}/ack`
보존 고정	`POST /api/notification-deliveries/{id}/hold`
채널 운영·현황	`GET/PUT /api/notification-operations`, `GET /api/notification-operations/status`
보호 해제·결과 재조회	`POST /api/notification-operations/channels/{id}/reset`, `POST /api/notification-operations/receipts/{id}/refresh`
전달 결과 서명 콜백	`POST /api/notification-receipts/{channelID}`
변경·ITSM 설정	`GET/PUT /api/workflow-automation`
변경 미리보기·실행 이력	`POST /api/workflow-automation/preview`, `GET /api/workflow-automation/runs`
수동 ITSM 동기화·콜백	`POST /api/workflow-automation/sync`, `POST /api/integrations/{id}/tickets/callback`

정확한 필드·권한은 실행 서비스의 `/api/openapi.json`을 확인합니다. 개인 업무 알림은 `services:read`와 실제 대상의 현재 읽기·부모 권한을 검사합니다. 관리자 API와 서명 전용 콜백의 인증 방식을 혼용하지 않습니다. 공식 근거와 채택 범위에 공급자 계약과 자동화 경계가 정리되어 있습니다.

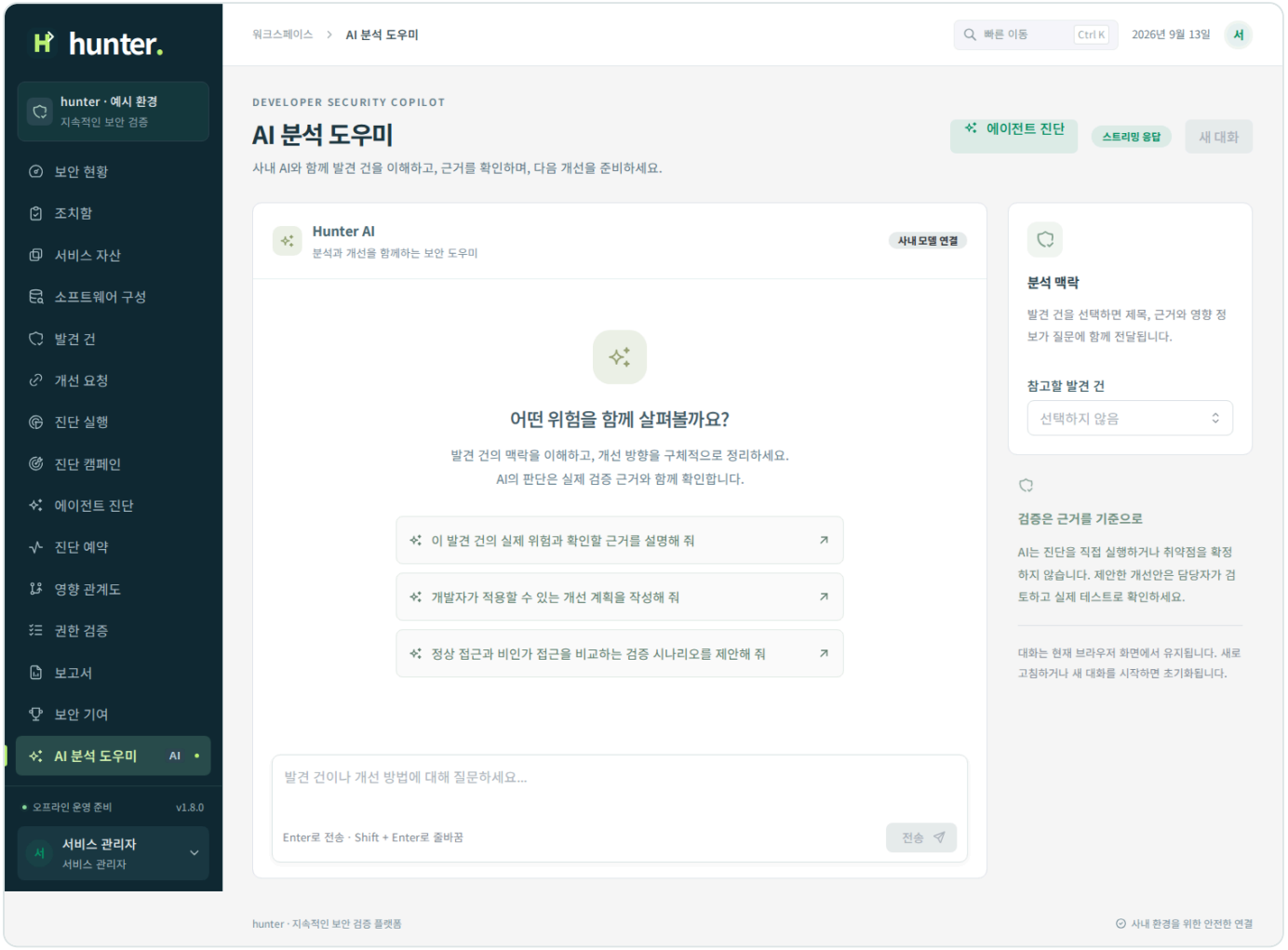
14. AI 설정과 스트리밍

14.1 사내 AI 연결

서비스 설정 → AI 분석에서 다음을 설정합니다.

항목	예시
Base URL	http://llm.internal:8000/v1
모델	사내 서버에 등록된 실제 모델 ID
API 키	사내 서버가 요구하는 키, 비밀값으로 저장
최대 출력 토큰	8192 등 모델이 지원하는 실제 한도
컨텍스트 창	입력과 출력을 합산한 한도, 최대 262144
활성화	연결 준비 후 켜기

요청은 OpenAI 호환 `/chat/completions`로 전송하며 `stream: true`를 기본으로 사용합니다. 화면에는 한 공급자의 정상 완료·권한 검증을 마친 답을 SSE 조각으로 전달합니다. 실패한 일부 답이 다른 공급자의 답에 섞이지 않도록 최초 표시가 늦어질 수 있습니다. 프록시와 사내 AI gateway에서 스트리밍을 유지하고 응답 버퍼링을 끕니다.



14.2 256K 처리의 의미

최대 출력 토큰과 컨텍스트 창 설정은 각각 최대 262,144까지 허용합니다. 실제 입력·출력 총합과 모델별 출력 상한은 AI 공급 서버의 정책을 따라야 합니다. 예를 들어 컨텍스트가 262,144여도 모델 최대 출력이 32,768이면 출력 값을 그 이하로 설정해야 합니다.

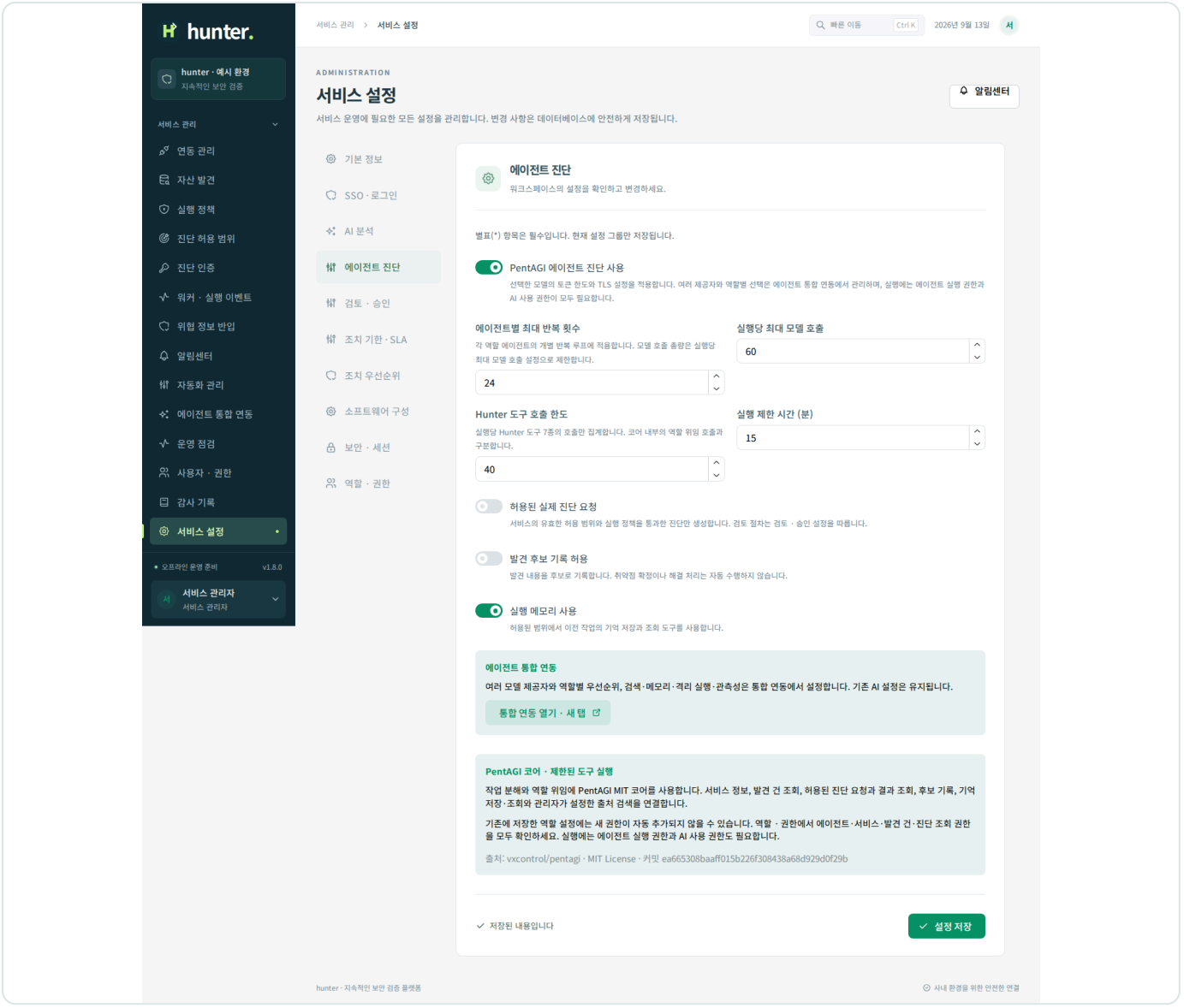
Hunter는 보수적인 UTF-8 바이트 기반 입력 예산으로 과도한 요청을 제한하며, 정확한 모델 토큰 계산과 최종 한도 검사는 공급 서버가 담당합니다. 긴 증거와 소스는 필요한 부분으로 나누고 비밀값을 제거한 뒤 전달합니다.

AI 분석 도우미는 분석 제안을 제공합니다. 에이전트 기능에서 도구를 사용하더라도 모델 출력이 실행 정책, 사용자 역할, API 키 권한이나 범위 승인을 변경하지 않습니다. 대상 문서와 응답에 포함된 지시문을 도구 실행 명령으로 신뢰하지 않습니다.

14.3 에이전트 코어 활성화

서비스 설정 → 에이전트 진단에서 기능과 실행 한도를 관리합니다. 먼저 AI 분석 설정 또는 에이전트 플랫폼의 모델 탭에 사내 모델과 한도를 저장합니다. 에이전트는 선택한 연결을 사용하므로 모델과 게이트웨이도 구조화된 도구 호출을 지원해야 합니다.

설정	기본값	의미
활성화 (`enabled`)	꺼짐	에이전트 실행 기능 허용
에이전트별 최대 반복 횟수 (`max_iterations`)	24	각 역할의 원본 체인 호출당 반복 상한 6~100. 재개 시 새 호출에 적용하고 전체 모델·도구·활성 시간은 누적
모델 호출 (`max_model_calls`)	60	한 실행의 모델 요청 상한, 설정 범위 5~200
Hunter 도구 호출 한도 (`max_tool_calls`)	40	한 실행의 여덟 Hunter 도구 호출 상한, 내부 역할 위임 제외, 설정 범위 1~200
제한 시간 (`timeout_minutes`)	15분	한 실행의 시간 한도, 설정 범위 1~60분
진단 허용 (`allow_diagnosis`)	꺼짐	에이전트의 진단 요청 도구 사용 허용
후보 등록 (`allow_candidates`)	켜짐	발견 후보 생성 허용
기억 기능 (`memory_enabled`)	켜짐	허용된 맥락 저장·검색 사용

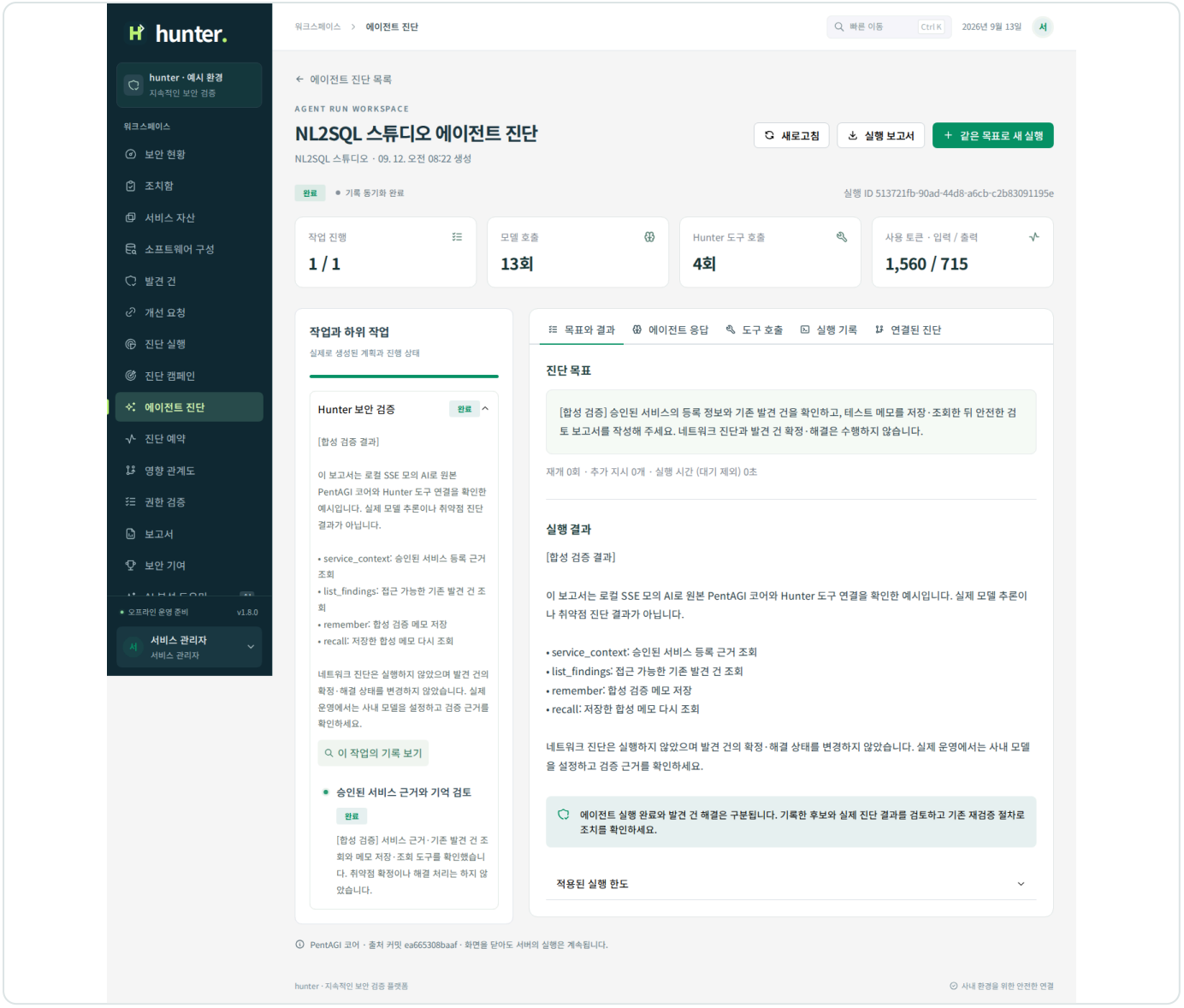


실행 기록에 발견 건과 진단 결과가 포함될 수 있으므로 목록·상세·이벤트 조회에는 `agents:read`, `services:read`, `findings:read`, `scans:read` 네 권한이 모두 필요합니다. 실행 생성에는 `agents:write`와 `ai:use`를 추가로 요구합니다. 역할과 개인 키의 현재 권한, 서비스 접근 범위를 함께 검사합니다. 기존 설치에서 역할 권한을 별도 저장했다면 새 권한과 관련 자료 조회 권한이 사용자에게 부여되었는지 확인합니다.

에이전트 생성 단계부터 서비스 승인과 유효 범위가 필요합니다. 사용자가 범위를 지정하지 않으면 서버가 해당 서비스의 유효한 승인 범위를 선택하며, 범위가 없으면 실행하지 않습니다. 진단 허용을 켜도 현재 역할·키 권한, 실행 정책과 긴급 중지 통제는 그대로 적용됩니다. 후보 등록은 취약점 확인이나 해결 상태의 자동 확정이 아닙니다. 기억 저장은 같은 PostgreSQL을 사용하며 별도 벡터 확장이나 Graphiti 서버 설치를 요구하지 않습니다. 메모리는 사용자·서비스별 100개까지 저장합니다. 에이전트 실행 목록은 접근 가능한 최신 1,000건을 표시하고 사용자당 진행 중인 실행은 최대 3개입니다.

14.4 원본 코어와 Hunter 연결 범위

고정한 PentAGI 원본의 계획·위임·실행·재시도·성찰·대화 요약 코어를 사용하고, 실제 행위는 서비스 조회·발견 건 조회·진단 요청·진단 결과 조회·후보 등록·기억 저장·기억 검색·참고 검색의 여덟 Hunter 도구로 연결합니다. 원본 스택을 자동 시작하지 않습니다. 검색·지식·모델·고정 격리 진단·관측성은 관리자 설정을 통해 Hunter의 별도 어댑터로 연결합니다. 기존 일반 PostgreSQL DSN과 네 환경변수, 서비스 이미지 하나로 배포합니다.



에이전트 목록과 상세 화면에서 작업, 도구 호출, 실시간 이벤트와 종료 이유를 확인합니다. 사용자의 중지 요청과 설정 한도는 실행을 제한하며, 중지는 이미 끝난 외부 요청이나 저장된 자료를 자동 복원하지 않습니다. 다시 시도는 이전 실행을 덮어쓰는 대신 새 실행 이력으로 관리합니다. 일시 중지·모델 연결 대기·입력 대기는 같은 실행 ID의 체크포인트에서 명시적으로 재개합니다. 종료된 실행과 프로세스 강제 종료를 자동 재실행하지 않습니다. 원래 키·현재 서비스·범위·정책과 누적 한도를 다시 검사합니다.

모델에 제공하는 서비스·발견 정보와 도구 결과는 비신뢰 입력으로 취급합니다. 모델 응답으로 사용자 권한을 확대하거나 진단 정책을 바꾸지 않습니다. 사내 게이트웨이가 응답을 버퍼링하지 않는지, 실패·취소·재시도에서도 현재 권한과 실행 한도가 적용되는지 운영 반영 전에 확인합니다.

코어 통합 출처와 라이선스에서 원본 커밋과 라이선스 근거를 확인할 수 있습니다. 이미지 안에는 `/usr/share/licenses/hunter/`에 라이선스 원문과 출처 목록을 포함합니다. Go·코어·폰트 고지는 `dependencies.json`, 프런트엔드 npm 고지는 `npm/manifest.json`과 `npm/components/`에 따로 기록합니다. Docker 빌드와 CI가 설치된 의존성의 고지를 수집하며, 필수 고지나 고정 출처 근거가 누락되면 빌드를 실패시킵니다.

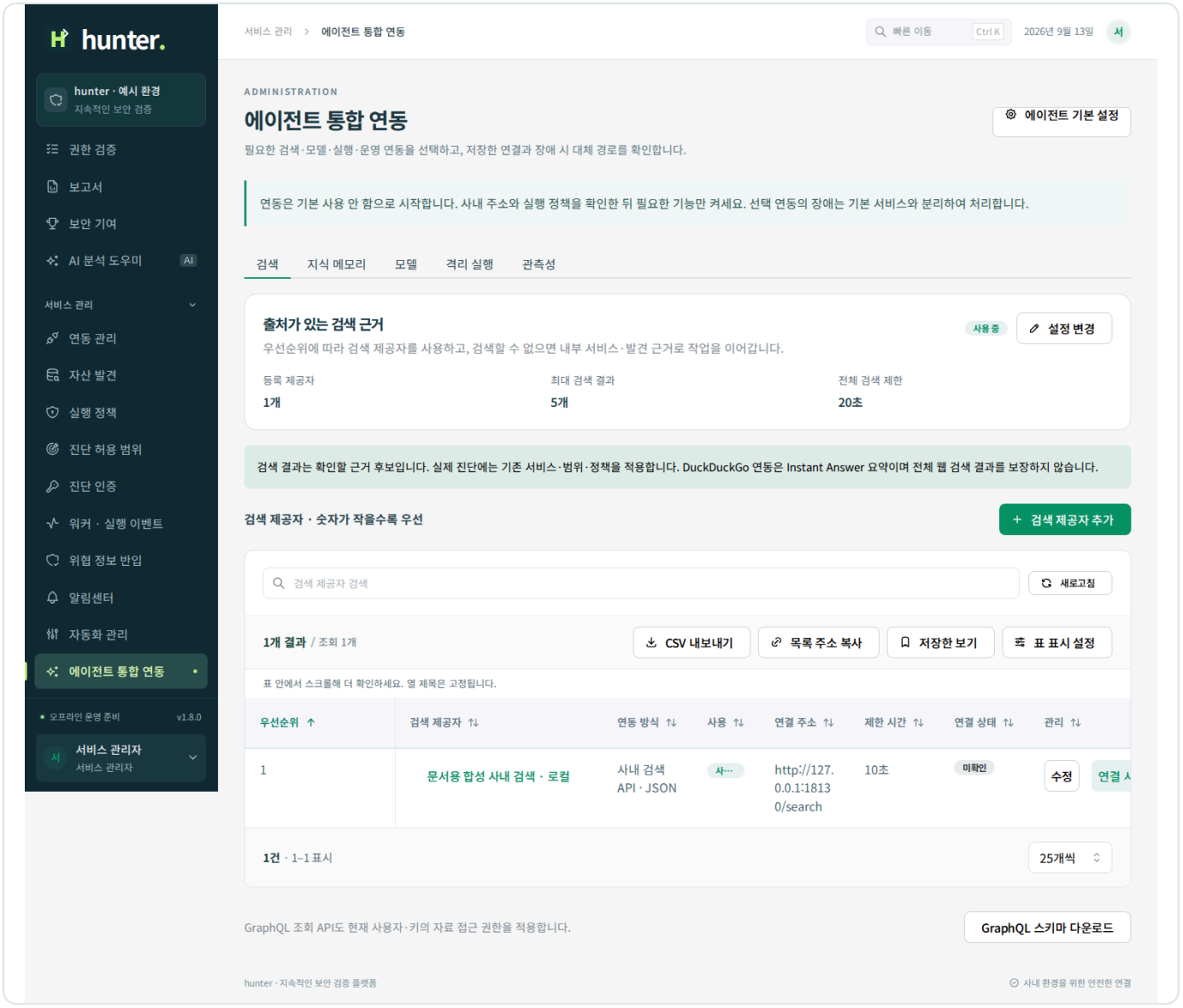
14.5 에이전트 연동 관리 공통 절차

서비스 관리 → 에이전트 통합 연동(`/admin/agent-platform`)의 **검색·메모리·모델·격리 실행·관측성** 탭에서 선택 기능을 구성합니다. 모든 관리 API에는 현재 `admin:manage` 가 필요합니다. 새 외부 연동은 기본 비활성이고, 일반 PostgreSQL과 기존 네 환경변수만으로 기본 서비스가 시작됩니다.

1. 조직이 허용한 사내 주소·중계 서버를 정하고 필요한 인증정보를 준비합니다. 외부 공급자를 선택했다면 해당 경로로 자료가 전달될 수 있습니다.
2. 이름과 안정적인 공급자 ID, 주소, 인증, 시간·시도 한도를 등록합니다. 비밀값은 조회 시 숨기고 DB의 전체 설정 JSON에 암호화합니다.
3. 기존 공급자의 비밀 입력을 비워 두면 유지합니다. 교체할 값을 새로 입력하거나 명시적인 삭제를 선택합니다. 다른 ID로 만들면 기존 비밀을 자동 복사하지 않습니다.
4. 설정을 저장한 후 **연결 시험**을 실행합니다. 검색 공급자와 임베딩·Graphiti 시험은 해당 연결의 개별 활성화가 필요합니다. 전체 기능 스위치가 있으면 운영 활성화와 개별 시험을 구분하세요. 시험은 실제 네트워크 요청이며 명시한 합성 입력을 사용합니다.
5. 최근 상태와 안전한 오류 분류·소요 시간을 확인합니다. 다른 관리자의 수정으로 409가 나오면 입력을 유지하고 현재 설정을 다시 확인합니다.
6. 필요한 연동의 활성화만 켭니다. 도구별 진단 권한이나 에이전트 전체 사용 허용은 별도 서비스 설정에서 관리합니다.

공통 장애 보호의 기본값은 연속 실패 3회·회복 대기 30초입니다. 설정 가능한 범위는 실패 1~20회·대기 5~3,600초입니다. 열린 연결은 회복 시각 이후 하나의 시험 요청만 보내고 정상 응답이면 회복합니다. 설정 버전이 바뀌면 이전 장애 결과를 새 설정에 덮어쓰지 않습니다. 상태에는 인증정보·요청·응답 원문을 남기지 않습니다.

14.6 검색 공급자와 내부 근거 복귀

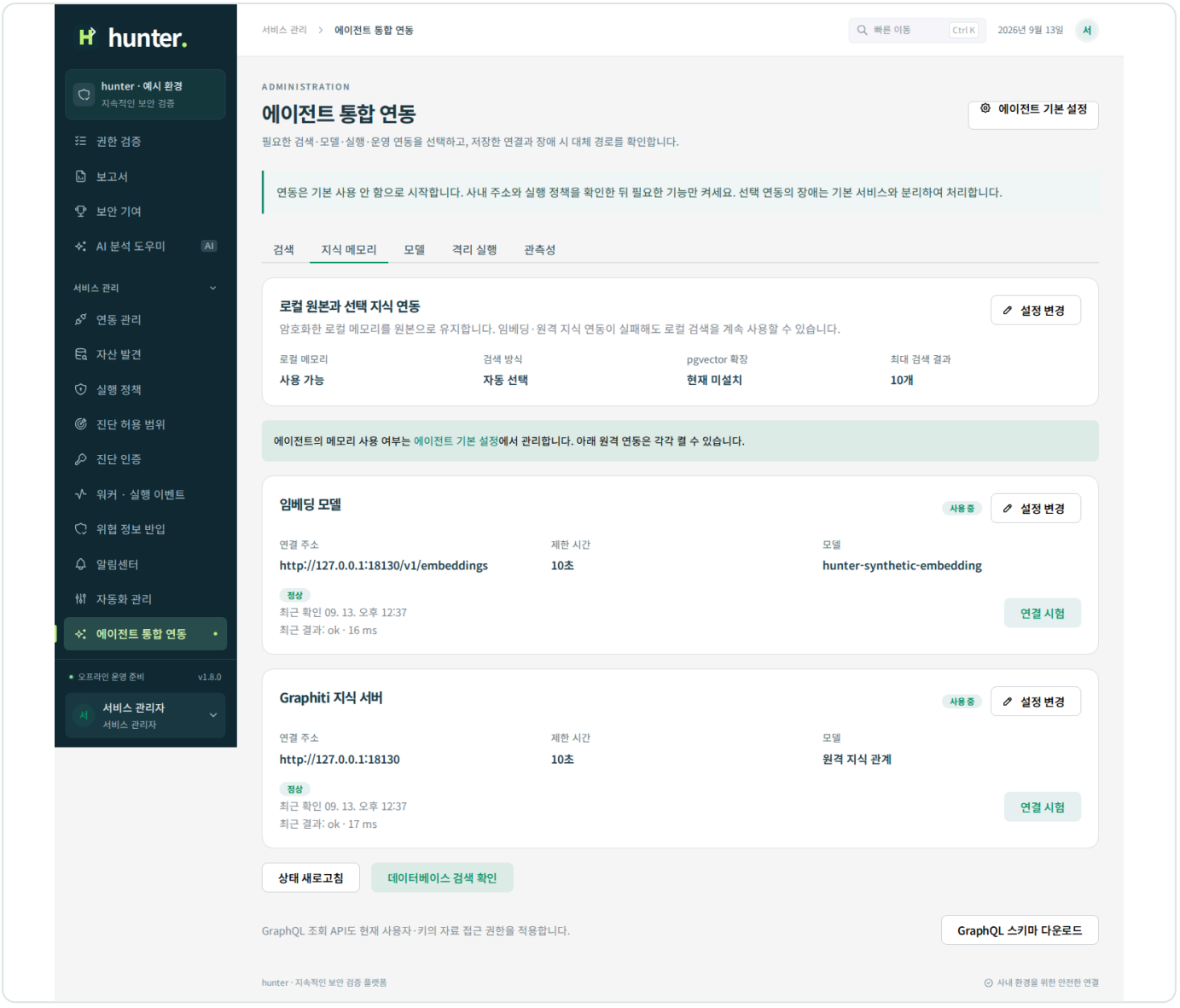


유형	필요한 설정과 의미
DuckDuckGo	Instant Answer 요약 API. 일반 웹 검색 결과 전체와 같지 않음
Google Custom Search	API 키·검색 엔진 ID `cx`, 조직이 허용한 검색 범위
Tavily	Search API 주소·키
Perplexity	Search API 주소·키. 대화 완성 API와 구분
SearXNG	자체 서버 검색 API, JSON 출력 지원 설정
HTTP JSON	사내 검색 GET/POST, 결과 배열·제목·URL·요약의 점 구분 필드 경로

공급자는 최대 8개이며 우선순위가 낮은 숫자부터 시도합니다. 결과는 기본 5개·최대 10개, 전체 검색 시간 기본 20초·최대 120초, 제공자별 1~30초입니다. JSON 매핑은 필드 경로이며 임의 코드나 셸 평가가 아닙니다.

시험 검색어도 실제 선택 서버로 전달됩니다. 검색 장애에는 다른 공급자를 시도하고 모두 불가하면 내부 서비스·발견 건·기억 조회로 복귀합니다. 반환한 자료는 출처가 있는 비신뢰 참고 데이터입니다. 검색된 페이지를 대상으로 자동 진단하거나 검색의 지시로 실행 권한을 늘리지 않습니다.

14.7 로컬 기억·임베딩·Graphiti·pgvector



기본 원본은 같은 PostgreSQL의 사용자·서비스별 암호화 메모리 최대 100개입니다. 원문은 기록별 최대 16KiB, 검색 결과는 최대 10개·각 본문 최대 8KiB이며 잘린 결과는 안내합니다. 별도 벡터 확장을 설치하지 않아도 동작합니다.

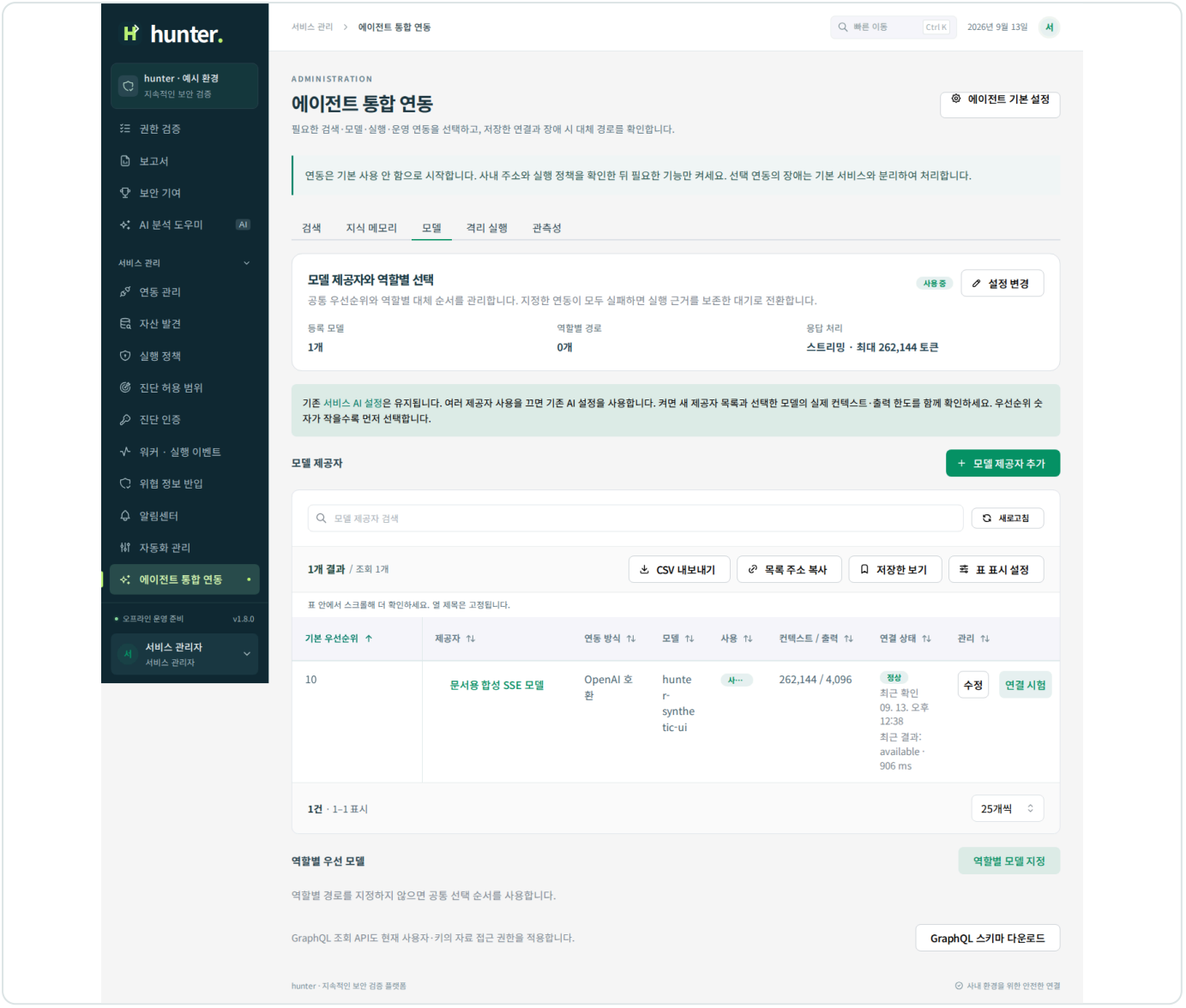
- **임베딩**: OpenAI 호환 `/embeddings` API의 주소·모델·키를 저장합니다. 기억 저장 시 본문, 검색 시 질의가 이 서버로 전달됩니다. 반환 벡터는 로컬에 암호화하여 보관합니다.
- **벡터 방식**: `auto`, `database`, `pgvector`를 선택합니다. 이미 설치한 pgvector를 사용하면 실제 매개변수화 거리 연산을 수행합니다. Hunter가 `CREATE EXTENSION`을 자동 실행하지 않으며 미설치·오류 시 Go 코사인 유사도와 키워드 검색으로 복귀합니다. 평문 벡터 테이블을 새 원본으로 만들지 않습니다.

- **Graphiti**: 표준 REST의 `/messages`와 `/search`에 연결합니다. 202는 비동기 접수이며 인덱싱 완료가 아닙니다. 연결 시험은 합성 그룹의 검색 계약 확인으로, 쓰기·전체 인덱싱 완료 검사가 아닙니다.

원격 그래프의 결과 문장은 반환하지 않습니다. 연결된 에피소드·식별자·본문 해시를 현재 로컬 기록 및 권한과 대조한 뒤 허용된 로컬 원문만 사용합니다. 임베딩 모델·주소·키를 바꾸면 이전 인덱스를 사용하지 않으며 새 기억 저장 시점부터 다시 연결합니다. 기존 메모리 전체를 자동 업로드하지 않습니다.

Graphiti에 이전에 전달한 에피소드의 자동 삭제는 제공하지 않습니다. 외부 서버의 접근·보존·삭제 정책을 별도로 설정하세요. 로컬 암호화나 Hunter의 권한 변경이 이미 외부에 전달된 사본까지 소급 삭제하는 것은 아닙니다.

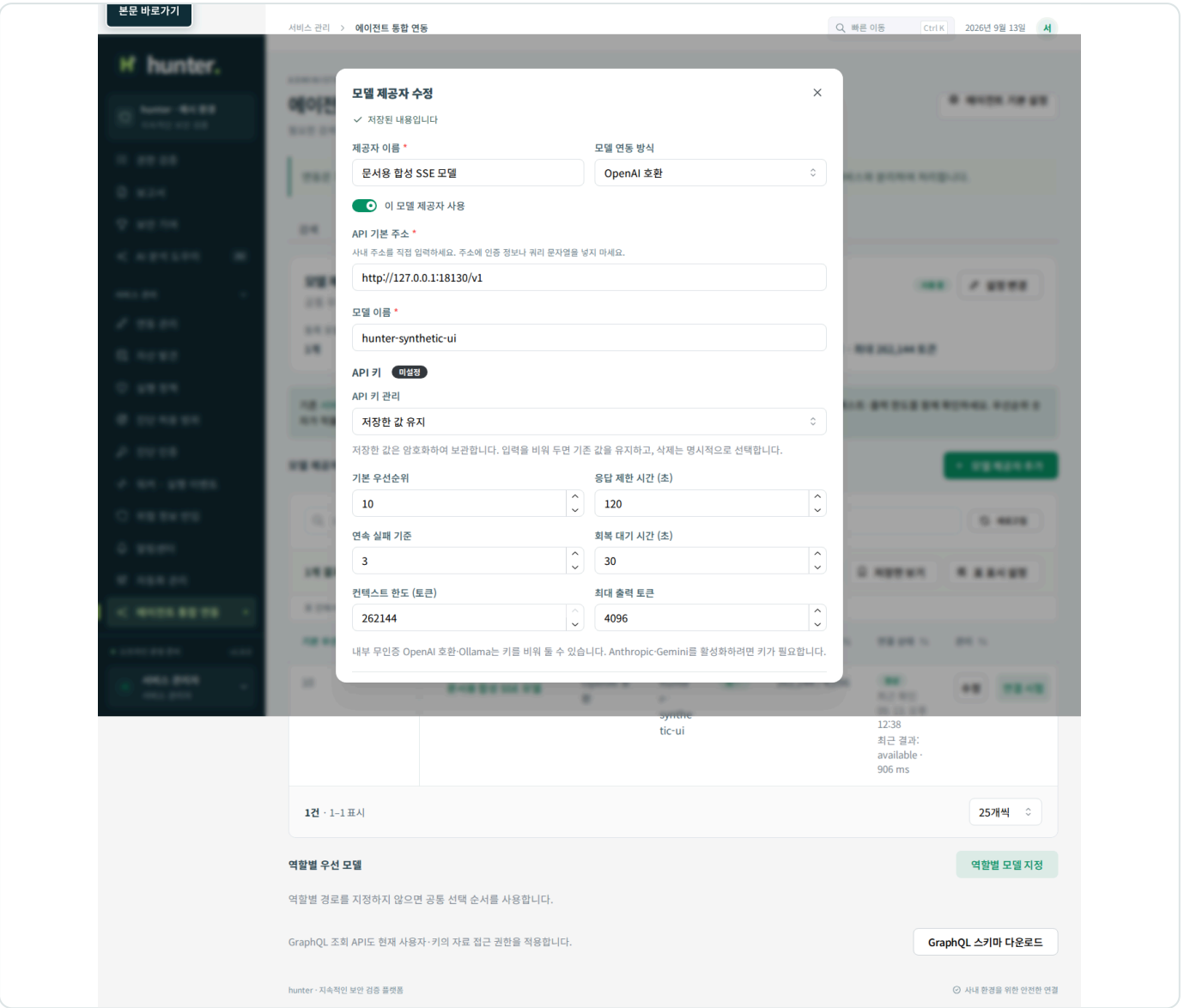
14.8 네이티브 모델과 역할별 대체 순서



유형	기본 주소 예시	사용하는 프로토콜
OpenAI 호환	`http://llm.internal:8000/v1`	`/chat/completions`, SSE·function tools
Anthropic	`https://api.anthropic.com/v1`	`/messages`, x-api-key·Messages SSE

유형	기본 주소 예시	사용하는 프로토콜
Gemini	`https://generativelanguage.googleapis.com/v1beta`	`streamGenerateContent`, x-goog-api-key·SSE
Ollama	`http://ollama.internal:11434`	`/api/chat`, NDJSON·native tool calls

공급자 최대 20개에 ID·이름·모델·활성 상태·주소·API 키·우선순위를 설정합니다. Anthropic·Gemini 활성 연결에는 API 키가 필요합니다. OpenAI 호환·Ollama는 무인증 사내 연결도 허용합니다. 주소 자체에 사용자 정보·인증 쿼리·fragment를 넣지 않습니다.



컨텍스트는 1,024~262,144, 출력은 1~컨텍스트, 제공자 요청 시간은 5~600초, 우선순위는 0~1,000입니다. 기본값은 컨텍스트 32,768·출력 4,096·시간 120초입니다. 에이전트 실행의 토큰·시간·모델 호출 상한도 함께 적용하며 대체 공급자 요청도 모델 호출 예산에 포함됩니다.

역할별 ID 목록을 지정하면 그 순서의 활성 제공자만 시도합니다. 해당 역할 목록이 없으면 `default`, 그것도 없으면 활성 제공자의 숫자 우선순위를 사용합니다. 역할은 `primary_agent`, `assistant`, `simple`, `simple_json`, `adviser`,

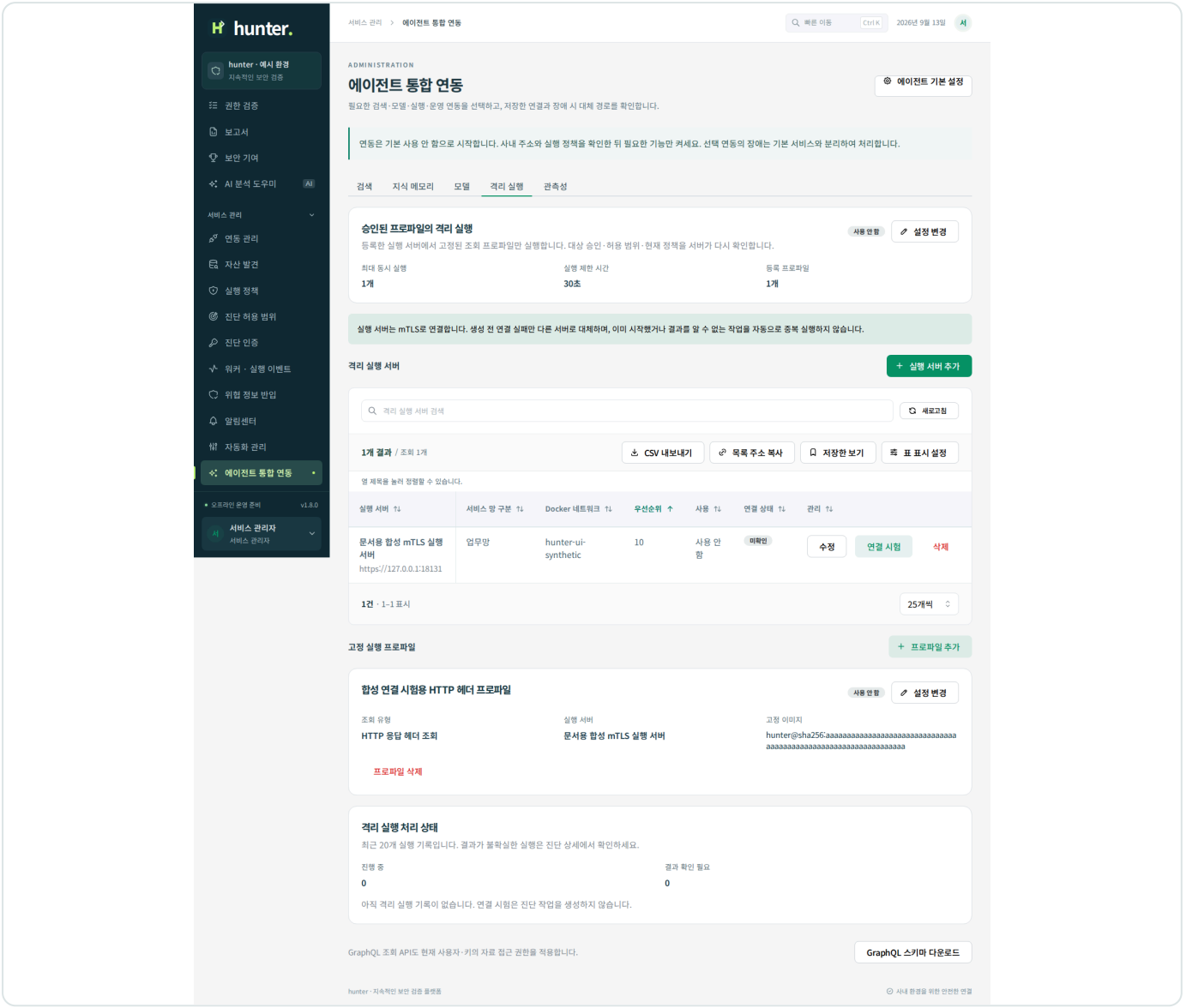
`generator`, `refiner`, `searcher`, `enricher`, `coder`, `installer`, `pentester`, `reflector`, `copilot` 입니다. 이름이 공격 역할이어도 실제 행위는 Hunter의 허용된 도구와 정책에 한정됩니다.

모델 연동 전체가 꺼져 있으면 기존 **서비스 설정 → AI 분석**의 활성 OpenAI 호환 연결을 사용합니다. 새 모델 연동을 켰는데 선택 가능한 제공자가 없으면 기존 연결로 자동 전환하지 않고 연결 불가로 표시합니다.

모든 업스트림 요청은 스트리밍입니다. 실패한 일부 응답을 다음 모델 답에 붙이지 않기 위해 **한 제공자의 정상 완료·도구 인자·현재 권한을 검증한 후에만** 답을 SSE 조각으로 확정합니다. 따라서 최초 텍스트 표시까지 기다릴 수 있습니다. 긴 한국어는 UTF-8 경계를 지켜 분할합니다. Gemini의 필요한 도구 호출 서명은 실행·제공자별로 암호화 보존하여 다른 제공자에 전송하지 않습니다.

모든 제공자가 불가하면 에이전트는 복구 가능한 연결 대기 상태로 남고, 일반 AI 도우미는 재시도 안내를 표시합니다. 실제 모델의 기능·컨텍스트·출력 제한은 해당 서버가 최종 검사합니다. 로컬 모의 프로토콜 검증은 실제 공급 계정·모델 품질 검증과 구분합니다.

14.9 원격 mTLS Docker의 고정 진단



선택한 전용 Linux Docker 서버의 HTTPS 주소, CA PEM, 클라이언트 인증서·비밀키, 별도 생성한 네트워크 이름을 등록합니다. mTLS가 필수이고 Unix Docker 소켓·평문 API·호스트 네트워크·기본 bridge를 사용하지 않습니다. 최대 서버 10개·프로파일 20개·동시 1~4개·진단 5~120초입니다.

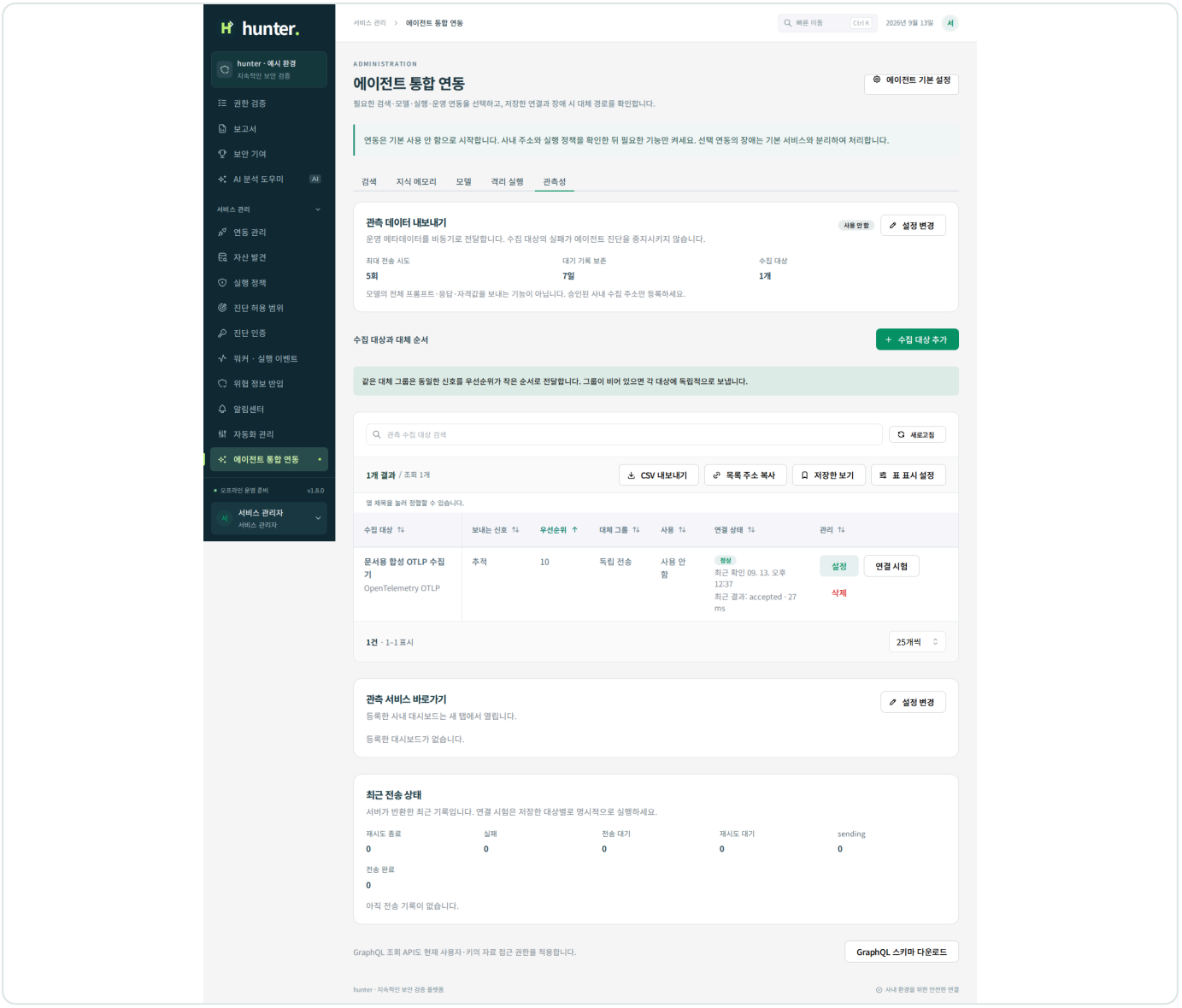
1. 실행 서버에 동일한 Hunter 서비스 이미지를 승인된 반입 절차로 미리 불러옵니다. 자동 image pull을 수행하지 않습니다.
2. 해당 이미지의 고정 `@sha256:` digest 또는 로컬 이미지 ID에 해당하는 digest 참조를 등록합니다. Hunter 라벨과 불필요한 이미지 환경변수·볼륨 여부를 검사합니다.
3. 서비스 망 분류를 현재 서비스·Hunter 워커의 망과 정확히 맞춥니다. 별도로 만든 Docker bridge/overlay 네트워크의 ASCII 이름을 지정하고 실제 허용 대상에만 통신하도록 조직 정책을 적용합니다.
4. **HTTP 헤더 (** `http_headers` **)**, **TLS 인증서 (** `tls_certificate` **)**, **TCP 연결 (** `tcp_connect` **)** 중 종류를 선택합니다. 임의 명령·인자를 입력하는 프로파일은 없습니다.
5. 저장한 서버의 연결 시험으로 mTLS·Linux Docker·네트워크와 지정 이미지의 존재를 확인합니다. 시험은 대상 진단이나 컨테이너 생성을 수행하지 않습니다.
6. 승인된 서비스·범위와 연결된 프로파일로 실제 진단을 요청하고 작업 이력에서 결과를 확인합니다.

원격 컨테이너는 같은 Hunter 이미지의 고정 probe 모드를 사용합니다. 대상 DNS를 승인 단계에서 검사하고 IP를 고정한 단일 HEAD·TLS 연결·TCP 연결만 수행합니다. HTTP 본문·리다이렉트 탐색, 임의 셸·코드·스캐너 설치는 없습니다. 비특권 UID10001·읽기 전용·마운트 없음·capability 제거·재시작 없음·메모리/CPU/PID 제한을 적용하고 서비스의 DB·bootstrap 자격증명을 넘기지 않습니다.

생성 전 확인 실패에만 다른 서버를 선택합니다. 생성·시작 이후 응답이 불명확하면 저장한 컨테이너 이름·이미지·진단 ID를 대조해 같은 작업을 관찰합니다. 실제 시작 여부가 불명인데 새 컨테이너를 만들어 중복 실행하지 않습니다. 원격 실행 서버는 선택 사항이며 기본 서비스 이미지에 Docker 데몬·Kali·다수 공격 도구를 묶어 제공하지 않습니다.

실행 서버의 **서비스 망 분류**(`service_network` , 예: 업무망)와 **Docker 네트워크 이름**(`network` , 예: hunter-sandbox)은 별도입니다. 전자는 현재 서비스·Hunter 워커의 망과 정확히 맞추며 한글 1~200바이트를 허용합니다. 후자는 별도로 만든 Docker bridge/overlay 네트워크의 ASCII 이름입니다. 기존 API에서 service_network를 생략하면 network 값을 사용하지만 새 설정은 둘 다 지정하세요. 서버의 연속 실패·회복 대기 값도 PUT에 명시해야 합니다.

14.10 관측 수집기·Langfuse와 장애 분리



OTLP HTTP 수집기 또는 Langfuse의 주소·인증·신호를 설정합니다. OTLP는 JSON `/v1/traces`, `/v1/metrics`, `/v1/logs`로 전송합니다. Jaeger·VictoriaMetrics·Loki 등은 조직의 OpenTelemetry Collector에서 라우팅하며 Hunter가 해당 서버들을 번들하거나 모든 제품에 직접 연결하는 것은 아닙니다.

Langfuse는 공식 OTLP `/api/public/otel/v1/traces`와 공개 키·비밀키의 Basic 인증을 사용합니다. 오래된 ingestion endpoint를 혼용하지 않으며 Langfuse에는 traces만 보냅니다. 관리자에게 표시할 대시보드 주소를 최대 10개 저장할 수 있습니다.

수집기는 최대 10개입니다. 같은 **대체 그룹**의 동일 신호 수집기는 우선순위 순으로 시도하고, 그룹이 다르면 별도 전달합니다. 신호가 서로 다른 수집기를 같은 그룹에 넣지 않습니다. 요청 시간은 1~30초, 큐 시도는 1~10회(기본5), 보존은 1~90일(기본7)입니다.

수집 자료는 실행·도구·제공자 종류, 상태, 소요 시간, 요청·토큰·결과 수 같은 제한된 메타데이터입니다. 프롬프트·모델 답·도구 인자·원본 증거·비밀값은 관측 payload에 넣지 않습니다. 로그 본문은 고정된 사건·상태 문자열이며 metrics는 사건 개수 신호입니다. 완전한 운영 로그 수집기나 원문 대화 분석으로 설명하지 않습니다.

메타데이터를 짧은 DB 제한 시간 안에 암호화 큐로 저장하고 제어 서버가 비동기 전송합니다. 큐는 최대 10,000건이며 가득 차거나 DB enqueue가 불가하면 관측을 생략하고 업무 요청은 계속합니다. 설정이 바뀐 과거 대기 자료는 폐기하고 오래된 자료는 제한된 배치로 삭제합니다.

429·일시적 연결/502·503·504 오류는 유한 재시도·대체를 적용합니다. OTLP 부분 접수는 다시 전송하지 않습니다. 네트워크에서 접수 응답을 잃으면 동일 관측 ID 재전송이 발생할 수 있으므로 정확히 한 번 전달을 보장하지 않습니다. 이는 진단·도구의 재실행을 뜻하지 않습니다. 관측 상태와 큐를 확인해 연결을 복구하세요.

15. REST API와 MCP·GraphQL

15.1 API 인증

개인 키를 Bearer 헤더에 넣습니다. 브라우저 세션으로 상태 변경 API를 직접 호출할 때는 `X-Hunter-CSRF: 1`과 동일 출처 조건이 필요합니다. 개인 Bearer 키 인증은 CSRF 헤더 대상이 아닙니다.

```
curl 'https://hunter.internal/api/findings' \

  -H 'Authorization: Bearer YOUR_HUNTER_KEY'
```

경로	용도
GET /api/health	상태·버전
GET /api/openapi.json	OpenAPI 명세
/api/services	서비스 조회·등록·수정
/api/findings	발견 건 관리
POST /api/imports	외부 진단 결과 수입
POST /api/findings/bulk	현재 권한·수정 버전 확인 후 최대 100개 담당자·기한·허용 진행 상태 변경
GET /api/finding-queue	서버 검색·페이지·SLA·위협 정보와 공통 원인 후보
GET·POST /api/findings/{id}/activity	활동 이력 조회·댓글 작성
GET /api/intelligence	관리자 반입 자료 기준일·건수·해시
POST /api/intelligence/import	KEV JSON·EPSS CSV 교체 반입
GET /api/sboms, POST /api/sboms/import	서비스별 SBOM 조회·반입
GET /api/sboms/{id}/compare?baseline=ID	동일 서비스의 SBOM 버전 비교
GET /api/components	최신 SBOM 구성요소·영향 서비스
GET·POST /api/campaigns	캠페인 조회·초안 생성
POST /api/campaigns/{id}/start	전체 대상 진단을 원자적·멱등 시작
GET /api/campaigns/{id}/compare?baseline=ID	동일 조건 내장 완료 실행 비교
GET /api/operations	관리자 읽기 전용 운영 점검
GET·POST /api/notification-channels	관리자 알림 채널 조회·등록
PUT·DELETE /api/notification-channels/{id}	채널의 현재 수정 기준 검사·삭제
POST /api/notification-channels/{id}/test	저장된 채널의 실제 시험 발송 요청 생성
GET·POST /api/notification-rules	규칙 조회·등록, 지원 이벤트·변수 조회

경로	용도
PUT·DELETE /api/notification-rules/{id}	규칙의 현재 수정 기준 검사·삭제
POST /api/notification-rules/preview	외부 발송 없는 합성 템플릿 확인
GET /api/notification-deliveries	필터·서버 페이지 전달 이력, 전체 상태 요약
GET /api/notification-deliveries/{id}	마스킹 본문·시도 이력·접수 ID
POST /api/notification-deliveries/{id}/retry	실패·결과 불명 수동 재시도
POST /api/notification-deliveries/{id}/cancel	대기 취소·발송 중 취소 요청
/api/scans	진단 요청·조회
POST /api/scans/{id}/cancel	진단 취소
POST /api/scans/{id}/approve	활성화된 검토 흐름 승인·반려
/api/events	변경 이벤트
POST /api/emergency-stop	긴급 중지·해제
GET /api/reports/export?format=json	보고서 내보내기
/api/keys	개인 키 관리
POST /api/ai/chat	AI SSE 스트리밍
GET·POST /api/agent-runs	에이전트 실행 목록·생성
GET /api/agent-runs/{id}	에이전트 실행 상세
GET /api/agent-runs/{id}/events	실시간 SSE 이벤트
POST /api/agent-runs/{id}/stop	해당 실행 중지 요청

모든 자원이 모든 HTTP 메서드를 제공하는 것은 아닙니다. 워커·승인 이력 등은 직접 CRUD 대상이 아닌 경우가 있으며 실행 중 서비스의 OpenAPI와 API 오류 메시지를 확인합니다.

15.2 일반 자원 수정 충돌과 일괄 변경

일반 자원 수정 API에는 조회한 `updated_at`을 `expected_updated_at`으로 전달하세요. 화면은 편집을 시작한 자료의 기준 시각을 자동 전달합니다. 다른 변경이 반영된 경우 `409`를 반환하므로 최신 자료를 다시 조회해 내 변경과 비교한 뒤 재작성합니다. 이 기준값을 폼에서 임의의 현재 시각으로 만들거나 `409`를 무시해 반복 전송하지 않습니다.

```
{
  "name": "검토 후 변경한 서비스 이름",
  "expected_updated_at": "2026-09-12T01:02:03.123456Z"
}
```

이 보호는 서비스·발견 건·정책·허용 범위·대상 인증·연동·자동발견 후보·보고서 자원·권한 시나리오·개선 요청·예약의 일반 저장 경로에 적용합니다. 사용자·개인 프로필·서비스 설정·워커의 별도 handler는 같은 버전 비교 계약이 아닙니다. 기존 일반 자원 API 클라이언트와의 호환을 위해 기준 필드는 선택적이지만, 조회 후 사용자가 수정하는 클라이언트에는 명시적으로 전달하는 것을 권장합니다. 새 알림 채널·규칙 PUT에서는 이 기준값이 필수입니다.

`POST /api/findings/bulk`는 최대 100개 발견 건의 담당자·수동 기한·허용된 진행 상태를 한 번에 변경합니다. `findings:read`와 `findings:write`가 모두 필요합니다. 각 항목의 현재 `updated_at`을 포함하며 현재 사용자·역할·개인 키와 부모 서비스 접근을 트랜잭션 안에서 다시 확인합니다.

```
{
  "items": [
    {"id": "FINDING_ID_FROM_GET", "updated_at": "2026-09-12T01:02:03.123456Z"}
  ],
  "patch": {"assignee": "보안운영팀", "status": "in_progress"}
}
```

`patch`는 `assignee`, `due_date`, `status`만 허용하며 누락한 필드는 유지합니다. 담당자 빈 문자열은 지정 해제, 수동 기한 해제는 SLA 계산으로 돌아갈 수 있음을 뜻합니다. 상태는 `candidate`, `confirmed`, `in_progress`, `retest`, `inconclusive`만 허용합니다. 해결·위험 수용·오탐의 설정이나 해당 상태에서의 재개는 개별 검토로 처리합니다. 권한 변경·누락·수정 충돌이 하나라도 있으면 일부 성공 없이 전체 롤백합니다. `404`·`409`에서는 목록을 다시 조회하고 재선택합니다.

응답은 `updated`, 변경된 `items`, 공통 `operation_id`를 반환합니다. 실제 바뀐 항목만 갱신하며 같은 값 재적용으로 감사 기록을 불필요하게 늘리지 않습니다. 일괄 변경의 세 필드 변경 내역은 개별 활동과 감사 기록에 연결됩니다. 이 API를 진단 실행이나 재검증 없이 해결 상태를 만드는 용도로 사용하지 않습니다.

15.3 MCP 연결

HTTP 엔드포인트는 `/mcp`입니다. MCP 프로토콜 2025-06-18과 2025-11-25에 대한 초기화 협상을 지원하고, 개인 API 키 인증으로 사용합니다. 브라우저 로그인으로 토큰을 받아 오는 MCP 클라이언트(Claude, Cursor 등)를 키 없이 연결하려면 §15.6의 MCP·SSO 연결을 켭니다.

```
{
  "url": "https://hunter.internal/mcp",
  "headers": {
    "Authorization": "Bearer YOUR_HUNTER_KEY"
  }
}
```

위 예시는 주소와 헤더를 보여주는 개념 설정입니다. 각 MCP 클라이언트의 실제 설정 파일 문법에 맞춰 적용합니다. 기존 `hunter_list_services`, `hunter_list_findings`, `hunter_request_scan`에 v1.4의 읽기 전용 도구 네 개를 추가했습니다. REST와 같은 현재 권한·팀 범위를 적용하며 키에서 허용하지 않은 도구는 목록에서도 제외됩니다.

새 MCP 도구	기능	필수 권한
hunter_finding_queue	SLA·점수·위협 정보가 있는 조치함, 검색·페이지	services:read + findings:read
hunter_list_components	최신 SBOM 구성요소와 영향 서비스	services:read; 발견 내용은 findings:read 추가
hunter_list_campaigns	캠페인·연결 진단의 실제 상태	services:read + scans:read
hunter_compare_campaigns	기준/현재 캠페인 관측 비교	services:read + scans:read + findings:read

`hunter_compare_campaigns` 입력은 `current_id`와 `baseline_id`입니다. 도구에서 결과를 읽어도 상태를 변경하지 않고, `not_seen`을 해결로 자동 처리하지 않습니다. 새 도구로 위협 정보 반입·SBOM 삭제·캠페인 시작을 수행하지 않습니다.

15.4 조회 전용 GraphQL

`GET/POST /api/graphql`은 기존 세션 또는 개인 Bearer 키로 인증합니다. POST 쿠키 요청에는 기존 CSRF 규칙을 적용합니다. 익명 introspection은 허용하지 않으며 `GET /api/graphql/schema`에서 인증된 SDL을 읽을 수 있습니다. mutation·subscription·JSON batch 요청은 지원하지 않습니다.

```
query ServiceFindings($service: ID!, $n: Int!) {
  service(id: $service) { id name team environment }
  findings(serviceId: $service, first: $n, offset: 0) {
    total offset hasMore
    items { id title severity status component cve assignee dueDate }
  }
}
```

```
{"query":"query($n:Int!){services(first:$n){total hasMore items{id name}}}","variables":{"n":25}}
```

목록·상세 필드	필요한 현재 권한
`services` / `service`	`services:read`
`findings` / `finding`	`findings:read`와 현재 부모 서비스 접근
`scans` / `scan`	`scans:read`와 현재 부모 서비스 접근

목록·상세 필드	필요한 현재 권한
`agentRuns` / `agentRun`	`agents:read` , `services:read` , `findings:read` , `scans:read` 모두

모든 resolver와 최종 응답 전에 현재 역할·키·팀·자료 접근을 검사합니다. 서비스 소유 관계를 잃은 발견 건 작성자가 자식 소유자라는 이유로 계속 조회하지 못합니다. 허용되지 않은 상세 ID는 null, 필요한 범위가 없는 요청은 403과 `data:null` ·안전한 오류 코드로 반환합니다. 관리자 키도 키에 없는 조회 범위를 얻지 않습니다.

한 요청은 JSON 64KiB·쿼리 32KiB·파서 토큰5,000·펼친 필드/조각500·깊이8·예상/실제 응답 복잡도10,000·처리10초로 제한합니다. 페이지 `first` 는 기본25·최대100, `offset` 은 최대10,000입니다. 목록 건수는 해당 SQL 조회 시점의 전체 현재 접근 범위이며 기존 일반 UI의 최신5,000건 제한과 다릅니다. 실행 안의 작업·연결 진단은 각각 앞100개, 결과는30,000자까지입니다. 전체 대화·비밀·증거를 반환하는 범용 JSON 필드는 없습니다.

성공 JSON 응답 전체는 최대 4MiB입니다. `data` 봉투·개행·응답 별칭·객체와 배열의 구분 문자, UTF-8와 JSON escape에 필요한 크기를 포함해 결과를 구성하는 동안 보수적으로 검사합니다. 초과하면 HTTP `400` , `errors[].extensions.code` 가 `QUERY_LIMIT` , `data` 가 `null` 인 오류만 반환하며 일부 조회 자료를 먼저 전송하지 않습니다. 경계에 가까운 요청은 보수적 계산으로 실제 JSON이 4MiB 이하라도 거절될 수 있습니다. 같은 긴 필드를 반복 요청하지 말고 필요한 필드·페이지 크기를 줄여 나누어 조회하세요. 초기 권한과 응답 직전의 현재 사용자·키·부모 서비스 권한 검사도 유지합니다.

제어 API `POST /api/agent-runs/{id}/pause|resume|input` 의 `expected_updated_at` 에는 상세의 `control_updated_at` 을 전달합니다. 진행 이벤트는 제어 revision을 바꾸지 않고 다른 사용자 제어 변경과의 충돌을 검사합니다. 기존 현재 실행 `updated_at` 도 호환 허용하지만 새 클라이언트는 제어 값을 사용하세요. 현재 상태·원래 키·정책은 별도로 다시 검사합니다.

15.5 실행 보고서 API

`GET /api/agent-runs/{id}/report?format=md|html|pdf` 는 기존 에이전트 조회 네 권한과 현재 서비스 접근을 요구합니다. 기본 형식은 md이며 파일명은 `hunter-agent-{실행ID}.{형식}` 입니다. 결과는 JSON envelope가 아닌 다운로드 파일이고 `Cache-Control: no-store` 와 `Content-Disposition: attachment` 를 적용합니다.

PDF는 내장 NanumGothic 폰트로 Go 프로세스 안에서 생성합니다. HTML은 결과 텍스트 이스케이프와 외부 자원 차단 CSP를 적용합니다. 동시 생성4개·요청20초 제한이며 혼잡하면503, 형식오류400, 권한없음403, 비접근실행404를 반환합니다. 보고서의 생략 한도와 중간 상태 해석은 사용자 가이드를 확인하세요.

15.6 MCP·SSO 연결 — 키 없이 Keycloak 토큰으로

MCP 인가 규격(2025-06-18 이후)은 OAuth 2.1입니다. 이 절을 켜면 MCP 클라이언트에 `/mcp` 주소 하나만 주어도 클라이언트가 스스로 Keycloak 로그인 창을 띄우고 액세스 토큰을 받아 옵니다. **Hunter 는 리소스 서버**입니다 — 토큰을 발급하지 않고(`/authorize` · `/token` ·동적 클라이언트 등록 없음), 토큰을 저장하거나 세션으로 바꾸지도 않으며, 요청마다 Keycloak 서명키로 검사합니다. 개인 키 체계는 그대로이고 기본값은 **꺼짐**입니다.

흐름은 다음과 같습니다.

1. 토큰 없이 `/mcp` 를 부르면 `401` 과 `WWW-Authenticate: Bearer realm="hunter", resource_metadata="https://<공개 주소>/.well-known/oauth-protected-resource/mcp"` 를 돌려줍니다. 이 헤더는 MCP 경로에서만 붙고 REST 401 에는 붙지 않습니다.
2. 클라이언트가 그 메타데이터(RFC 9728, 인증 없이 맨 JSON, `Access-Control-Allow-Origin: *`)를 읽어 `authorization_servers` 의 Keycloak realm 으로 갑니다. Hunter 는 인증 서버 메타데이터를 대신 서빙하지 않고 클라이언트가 Keycloak 의 `/.well-known/openid-configuration` 을 직접 읽습니다.
3. 사람이 Keycloak 에 로그인하면(이미 로그인돼 있으면 화면이 거의 없음) 클라이언트가 액세스 토큰을 받아 같은 `Authorization: Bearer` 헤더로 `/mcp` 를 부릅니다. 값이 `hnt_` 로 시작하면 키, 점 두 개의 JWT 모양이면 SSO 토큰으로 가르고, 둘 다 아니면 지금과 같은 "로그인이 필요합니다" 입니다.

설정 표 (`관리자 → 서비스 설정 → MCP · SSO 연결` , API 로는 `PUT /api/settings/mcp` 의 `oauth` 객체)

키	기본값	뜻
`mcp.oauth.enabled`	`false`	꺼짐이 기본. 켜려면 SSO·로그인 그룹의 OIDC 가 켜져 있고 Issuer URL 이 저장돼 있어야 하며, 아니면 저장이 거부됩니다
`mcp.oauth.resource`	빈 값	리소스 식별자. 비우면 **서비스 외부 접근 주소 + `/mcp`** 로 만듭니다. 프록시 뒤 내부 주소가 아니라 클라이언트가 실제로 접속하는 공개 HTTPS 주소여야 하며, 요청 `Host` 헤더는 쓰지 않습니다
`mcp.oauth.audience`	빈 목록	허용 대상. 토큰의 `aud` 또는 `azp` 와 비교합니다(화면은 목록, API 는 배열 또는 공백 구분 문자열). 최대 20개
`mcp.oauth.scopes`	`services:read findings:read scans:read`	SSO 토큰 주체에게 주는 권한의 **상한**. 실제 권한은 이 목록 ∩ 사용자 역할 권한이며, 교집합이 비면 연결을 거부합니다. 켤 때 비어 있으면 저장이 거부됩니다
(재사용) `oidc.issuer` , `oidc.client_id`	SSO·로그인 그룹	새로 만들지 않습니다. 발급자는 서명·`iss` 검사에, 웹 로그인 Client ID 는 항상 허용 대상에 포함됩니다

켜진 뒤에도 OIDC 를 끄거나 외부 접근 주소를 지우면 조용히 꺼진 것처럼 동작하고(메타데이터 404, 토큰 거부) 이유를 `mcp oauth switched on but inactive` 로그로 남깁니다.

토큰 검사 항목

항목	규칙
서명	Keycloak JWKS(Discovery 의 `jwks_uri`). RS·ES·PS 계열만, `HS*` · `none` 은 서명키를 받기 전에 거부
`iss`	`oidc.issuer` 와 같아야 함
`exp` · `nbf`	만료·아직 유효하지 않음 거부
`typ`	`ID` 면 거부 — ID 토큰은 로그인 증거이지 API 자격이 아님

항목	규칙
`cnf`	있으면 거부(검증할 수 없는 DPoP·mTLS 소지자 증명)
`sub`	비어 있으면 거부
대상	`aud` 에 리소스 식별자가 있거나(Audience 매퍼 정식 경로), `aud` 또는 `azp` 가 허용 대상 목록 또는 웹 로그인 Client ID 에 있어야 함(호환 경로). 실제 Keycloak 26 은 `aud` 에 `account` 만 싣고 클라이언트 ID 는 `azp` 에 담습니다
계정	`iss

Keycloak 쪽 할 일

1. MCP 클라이언트용 **공개(public) 클라이언트**를 만듭니다. Standard Flow 켬, PKCE `S256`, Direct Access Grants·Implicit·Service accounts 끔. 웹 로그인 클라이언트(`oidc.client_id`)와 **다른** 클라이언트입니다.

2. Valid Redirect URIs 에 쓰는 MCP 클라이언트의 콜백을 정확히 적습니다(Claude 는 `https://claude.ai/api/mcp/auth_callback`, 로컬 클라이언트는 `http://127.0.0.1:*/callback` 류). `*` 하나로 다 여는 것은 금지입니다.

3. 정식 경로: 그 클라이언트(또는 전용 client scope)에 **Audience 매퍼**를 둡니다.

Mapper 항목	값
Mapper type	Audience
Included Custom Audience	리소스 식별자(예: `https://hunter.internal/mcp`)
Add to access token	ON
Add to ID token	OFF

   호환 경로: 매퍼 없이 Hunter 의 허용 대상에 그 클라이언트 ID 를 적습니다. 거부 메시지가 무엇을 적어야 하는지 그대로 알려 줍니다.

4. 액세스 토큰 수명은 짧게(5분 안팎) 둡니다. Hunter 는 introspection 을 하지 않으므로 Keycloak 에서 로그아웃하거나 사용자를 끄더라도 이미 발급된 토큰은 만료까지 삽니다. 급하면 Hunter 사용자도 비활성화하세요 — 비활성 계정의 토큰은 즉시 거부됩니다.

curl 로 확인하기

```
# 1) 메타데이터: 인증 없이 200, 맨 JSON

curl -si https://hunter.internal/.well-known/oauth-protected-resource/mcp

# {"resource":"https://hunter.internal/mcp","authorization_servers":

["https://keycloak.internal/realms/company"],

#  "bearer_methods_supported":["header"],"scopes_supported":

["services:read","findings:read","scans:read"],"resource_name":"hunter MCP"}


# 2) 토큰 없는 /mcp: 401 과 resource_metadata 헤더

curl -si -X POST https://hunter.internal/mcp -H 'Content-Type: application/json' \

  -d '{"jsonrpc":"2.0","id":1,"method":"ping"}' | grep -i www-authenticate

# WWW-Authenticate: Bearer realm="hunter", resource_metadata="https://hunter.internal/.well-

known/oauth-protected-resource/mcp"


# 3) 토큰으로 tools/list (토큰은 MCP 클라이언트나 Keycloak 에서 받은 액세스 토큰)

curl -s -X POST https://hunter.internal/mcp -H "Authorization: Bearer $TOKEN" -H 'Content-Type:

application/json' \

  -d '{"jsonrpc":"2.0","id":1,"method":"tools/list"}'


# 4) 같은 토큰은 REST 에서 거부돼야 함 (401, WWW-Authenticate 없음)

curl -si https://hunter.internal/api/auth/me -H "Authorization: Bearer $TOKEN" | head -1
```

거부 메시지별 조치 (`401` 본문의 `error` ; 하위 원인은 서버 로그 `mcp sso token rejected` 의 `cause` 에 남습니다)

메시지	조치
이 서버는 SSO 액세스 토큰을 받지 않습니다	`mcp.oauth.enabled` 를 켜거나(전제: OIDC 켜짐·Issuer·외부 접근 주소), 개인 키를 씁니다. 로그의 `cause` 가 어떤 전제가 빠졌는지 말합니다
SSO 토큰이 이 서버를 위해 발급된 것이 아닙니다(aud […], azp "…")	메시지에 적힌 `azp` 값을 허용 대상에 더하거나, Keycloak 클라이언트에 메시지의 리소스 식별자로 Audience 매퍼를 둡니다. 다른 앱용 토큰이라면 의도된 차단입니다
SSO 액세스 토큰이 유효하지 않습니다(서명·발급자·만료)	클라이언트에서 다시 로그인. 계속되면 `oidc.issuer` 가 realm issuer와 정확히 같은지, Hunter 의 신뢰 CA·시계를 확인합니다
ID 토큰은 로그인 증거이지 MCP 자격이 아닙니다	클라이언트가 `id_token` 을 보내고 있습니다. 액세스 토큰을 쓰도록 클라이언트 설정을 고칩니다
서명 알고리즘을 받지 않습니다	realm 의 액세스 토큰 서명 알고리즘을 RS256(또는 ES·PS 계열)로 둡니다

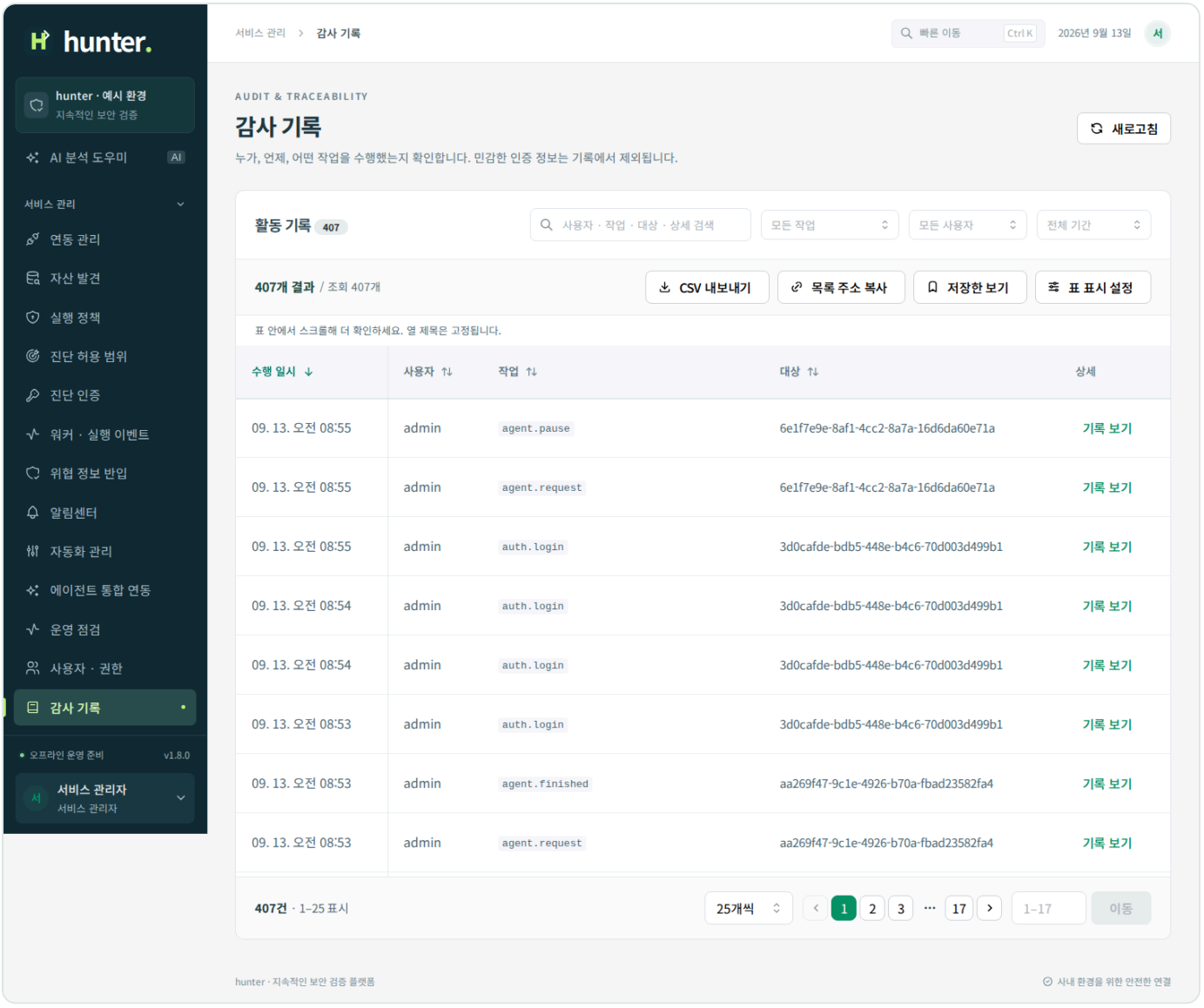
메시지	조치
소지자 증명(cnf)이 묶인 토큰	해당 클라이언트의 DPoP·mTLS 바인딩을 끄거나 개인 키를 씁니다
이 SSO 계정은 Hunter 에 등록되지 않았거나 비활성입니다	그 사람이 웹으로 한 번 SSO 로그인해 계정을 만든 뒤 다시 연결합니다. 비활성 계정은 관리자가 활성화해야 합니다
이 계정의 역할에는 SSO 로 허용된 MCP 권한이 없습니다	`mcp.oauth.scopes` 와 역할 권한(§ 7.3)의 교집합이 비었습니다. 둘 중 하나를 넓히거나 의도된 제한이면 그대로 둡니다
Keycloak 발급자 정보를 읽지 못해	Hunter 서버에서 Keycloak Discovery 주소로 나가는 연결·DNS·신뢰 CA 를 확인합니다

SSO 토큰으로 호출한 도구는 감사 기록 `mcp.<도구>` 에 `auth: sso` 로 표시됩니다. 토큰과 사용자 식별자는 로그에 남기지 않습니다.

16. 감사 기록과 증거 관리

관리자 → 감사 기록에서 수행자, 작업, 대상과 시각을 확인합니다. 주요 설정·계정·키·진단 변경을 조사할 때 사용합니다.

감사 목록에서 사용자·작업·대상을 검색하고 작업·사용자·기간 필터로 범위를 좁힙니다. 일시 열로 시간순을 바꾸고 페이지당 표시 수와 페이지 이동을 사용합니다. 검색 조건은 조회 권한이나 서버의 자료 보존·조회 한도를 늘리지 않습니다.



감사 기록은 애플리케이션 DB에 저장되므로 독립적인 WORM 저장소나 외부 SIEM의 변조 방지 증거를 대체하지 않습니다. 규정상 보존 요건이 있으면 DB 접근 통제, 백업·복제와 별도 로그 수집을 조직 정책으로 구성합니다.

증거는 필요한 정보를 마스킹하여 저장하고, 암호화된 데이터도 접근 권한이 있는 API 응답에서는 사용자가 읽을 수 있다는 점을 고려합니다. 자동 마스킹이 모든 개인정보를 탐지한다는 전제로 운영하지 않습니다. 발견 증거와 코어 대화의 자동 보존 기간 파기·독립 오브젝트 저장소는 제공하지 않으므로 해당 보존 절차를 별도로 관리합니다. 알림 본문과 관측 큐의 제한된 보존 기능은 각 설정에서 별도로 관리합니다.

에이전트의 사용자 화면 이벤트, 서비스 메모리와 발견 증거는 Hunter 암호화 저장소를 사용합니다. PentAGI 코어 호환 스키마의 대화 이력·작업·사용량·체크포인트 테이블에는 별도의 필드 암호화를 적용하지 않습니다. 전달 전에 질문과 도구 결과를 마

스킹하지만 모델의 후속 처리에 필요한 비공개 추론이 포함될 수 있으며, 이 기록은 일반 UI 이벤트에 노출하지 않습니다. 코어 스키마까지 포함한 DB 접근 통제와 백업 보호가 필요합니다. 모델 API 키는 대화나 코어 기록에 넣지 않습니다.

16.1 위험 수용 만료와 재검토

위험 수용은 사유와 미래의 만료 일시를 요구합니다. 만료 시각을 지나면 대시보드는 해당 발견 건을 즉시 열린 위험·심각한 위험·보안 부채 집계에 다시 포함합니다. 제어 서버의 분 단위 유지보수 작업은 상태를 탐지 후보로 바꾸고 finding.acceptance_expired 감사 기록을 같은 DB 작업으로 남깁니다.

이미 만료 처리한 항목은 다음 작업에서 다시 전환하지 않습니다. 유지보수 시점 전의 짧은 구간에도 대시보드에서 만료 항목을 제외하지 않으므로 수용 기간이 끝난 위험이 계속 숨겨지지 않습니다.

17. 백업과 복구

17.1 백업 대상

- PostgreSQL 전체 DB: 사용자, 설정, 암호화된 비밀·증거·알림, 자산, 발견 건, 작업·발송 큐와 이력, 감사
- 현재 DB에 대응하는 `ENCRYPTION_KEY`
- 배포에 사용한 이미지 버전과 체크섬
- Compose 설정, TLS 프록시 설정, 인증서와 비밀 저장소의 복구 절차

DB 백업만으로 암호화된 비밀을 복원할 수 없습니다. 키를 잃으면 데이터의 암호화 부분을 복구할 수 없습니다. DB와 키는 권한과 보관 위치를 분리합니다.

17.2 일관된 백업

1. 긴급 중지를 켜서 새 진단과 진행 진단을 중지합니다.
2. 유지보수 시간을 공지하고 Hunter 컨테이너를 정지하여 변경을 멈춥니다.
3. 조직의 PostgreSQL 백업 도구로 전체 DB를 백업합니다.
4. 이미지 태그·체크섬과 암호화 키의 안전한 보관 여부를 기록합니다.
5. 서비스를 시작하고 상태 확인 후 긴급 중지를 해제합니다.

다음 명령은 PostgreSQL 클라이언트가 설치된 백업 실행 환경에서 연결 변수가 안전하게 제공되었다는 전제의 예시입니다.

```
docker compose stop hunter

pg_dump --dbname="$POSTGRES_DSN" --format=custom --file=hunter-backup.dump

docker compose up -d
```

명령 이력이나 프로세스 목록의 자격 증명 노출이 우려되면 조직의 PostgreSQL service 파일·비밀 주입 방식을 사용합니다. 백업 파일을 암호화하고 복구 테스트 없이 정상 백업으로 판정하지 않습니다.

17.3 복구

복구 환경의 SMTP·문자·알림톡 API 통신을 먼저 차단합니다. 과거 백업에는 실제 공급자에게 이미 접수된 메시지가 아직 대기 상태로 남아 있을 수 있습니다. 복구 뒤 전달 이력과 원래 공급자의 접수 ID를 대조하고 불필요한 대기를 취소한 후 발송 경로를 허용합니다. DB 복구만으로 외부 시스템의 발송 이력을 되돌리거나 중복을 자동 제거할 수는 없습니다.

1. 복구 대상에 별도 DB를 생성합니다.
2. 백업을 복원하고 원본과 동일한 암호화 키를 안전하게 제공합니다.

3. 백업에 대응하는 Hunter 버전 이미지를 불러옵니다.
4. DSN을 복구 DB로 지정하여 실행합니다.
5. 로그인, 비밀 설정 해독, 서비스·발견 건·감사 기록을 확인합니다.
6. 검증계의 승인된 작은 진단으로 기능을 확인한 뒤 운영 전환합니다.

```
pg_restore --dbname="$RESTORE_POSTGRES_DSN" --no-owner hunter-backup.dump

docker load -i hunter-v1.25.0.tar.gz

docker compose up -d
```

새 DB를 위한 자동 초기 관리자 생성과 기존 DB 복원 절차를 혼동하지 않습니다. 복원한 DB에 사용자가 있으면 bootstrap 환경변수로 계정을 다시 생성하지 않습니다.

17.4 마스터 암호화 키 변경

개인 API 키 회전과 `ENCRYPTION_KEY` 변경은 다릅니다. 현재 버전은 전체 DB 비밀을 새 마스터 키로 재암호화하는 온라인 마이그레이션 도구를 제공하지 않습니다. 운영 중 환경변수만 새 키로 바꾸면 서비스가 시작되지 않습니다. 이 키의 변경이 필요하면 전체 백업과 별도로 검증된 재암호화 마이그레이션을 준비해야 합니다.

18. 업그레이드와 롤백

1. 릴리즈의 변경 내용과 실제 제공 범위를 검토합니다.
2. 기존 이미지와 DB 백업, 암호화 키를 확보합니다.
3. 검증계에서 복원한 DB로 새 버전을 먼저 실행합니다.
4. 승인된 작업의 실제 결과, OIDC·키·AI·연동과 화면을 점검합니다.
5. 유지보수 창에서 진단 중지 후 새 이미지로 전환합니다.
6. `compose.yaml`의 이미지 태그를 새 버전으로 바꿉니다.
7. 상태·버전과 주요 화면을 확인하고 진단을 다시 허용합니다.

18.1 v1.5 증거 형식 보완과 기존 자료 복구

증거 입력은 문자열을 사용합니다. 객체·배열·숫자 등 구조형 값을 직접 전달하면 입력 오류로 거부합니다. JSON 증거가 필요하면 마스킹할 텍스트로 직렬화해서 제출하세요. API 호출에서 객체로 전달한 과거 증거가 암호화 경로를 벗어날 수 있었던 문제를 보완했습니다.

v1.5는 기존 `ENCRYPTION_KEY`가 DB와 맞는지 먼저 검증한 뒤 HTTP 서버·워커를 시작하기 전에 남아 있는 구조형 증거를 복구합니다. 50행씩 잠금을 얻어 JSON 텍스트 변환·기존 길이 제한·마스킹·암호화를 적용하고 변경 시각과 원문 없는 건수 감사를 남깁니다. 완료한 배치는 보존하며 중단 후 다시 시작하면 남은 항목을 처리합니다.

잠긴 행을 처리 완료로 간주하지 않습니다. DB 접근 오류나 잠금 때문에 최대 2분 안에 복구를 끝내지 못하면 시작을 거부하므로 DB 잠금과 오류를 확인한 뒤 같은 암호화 키로 다시 시작하세요. 과거 백업·스냅샷·별도 복제본의 내용을 소급해서 정리하지는 않습니다. 업그레이드 전후 백업은 조직의 접근·암호화·보존 절차로 관리합니다. 이 복구는 마스터 키 변경 기능이 아닙니다.

시작 시 필요한 DB 스키마를 자동으로 준비합니다. 스키마 변경이 있는 업그레이드에서 이전 바이너리만 다시 띄우면 호환되지 않을 수 있습니다. 롤백은 이전 이미지와 대응하는 DB 백업을 함께 복원하는 절차로 검증합니다.

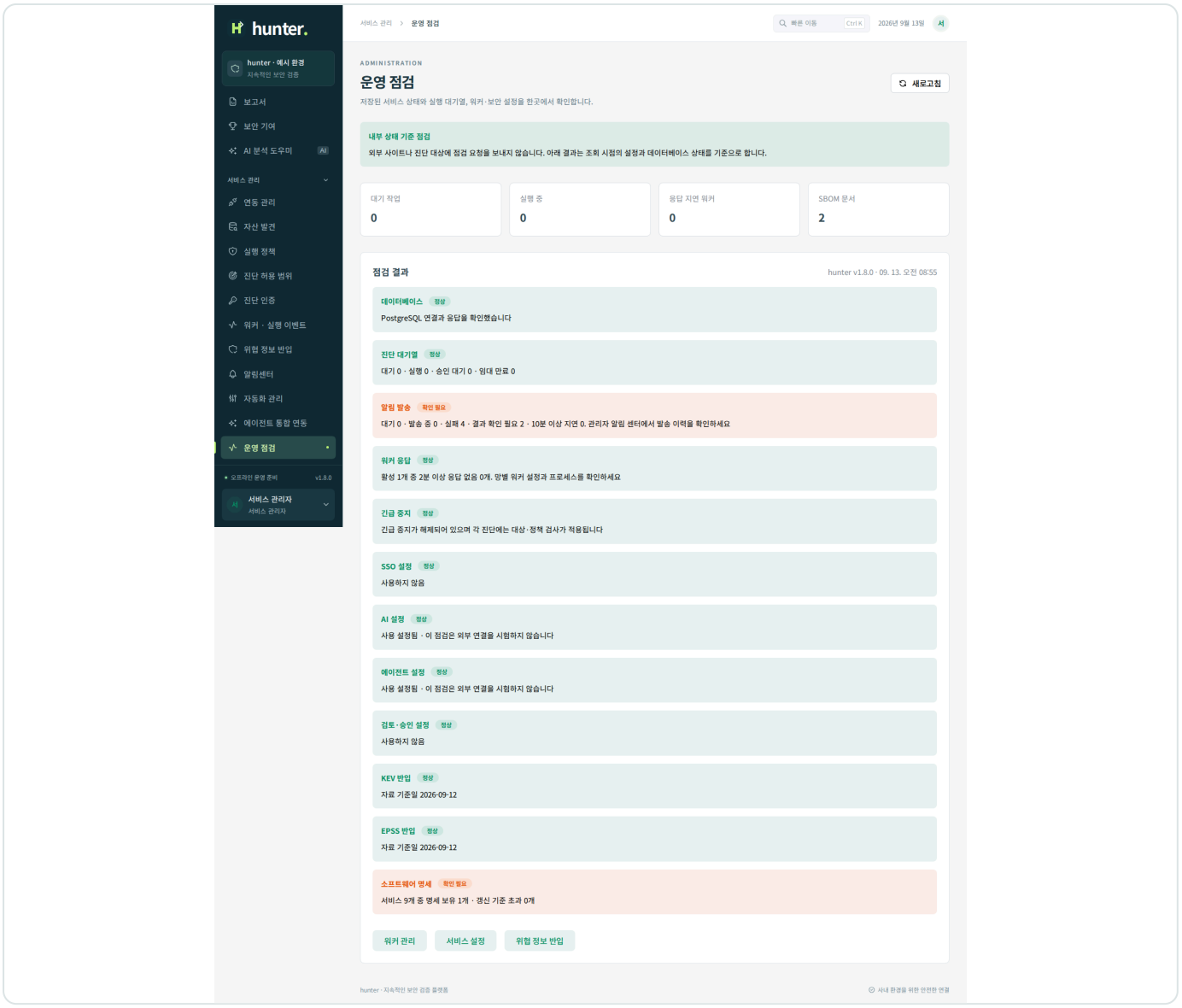
19. 운영 장애 점검

증상	점검 순서
컨테이너 즉시 종료	네 가지 환경변수, DSN, DB 접근·권한, 32바이트 base64 키
기존 증거 암호화 복구 미완료	DB 접근과 장기 잠금 확인, 동일 암호화 키로 재시작. 완료한 배치는 유지됨
편집·일괄 변경 409	현재 항목 재조회와 입력 비교, 자동 재전송 대신 명시적 재검토
기존 DB 복호화 실패	원래 ENCRYPTION_KEY 확인, 임의 재생성 금지
로그인 반복 이동	공개 URL, HTTPS 쿠키, 프록시 Host, 브라우저 쿠키
로그인 429 응답	사용자명·IP 시도 횟수, 동시 처리 한도, 공유 프록시 IP
OIDC callback 실패	정확한 redirect URI, issuer, secret, 사내 CA, 시간 동기화
SSO 후 권한 부족	신규 사용자 기본 역할, 실제 사용자 역할
API 키 인증 실패	유효 기간, 회전·폐기 여부, 계정 비활성화
HTTP 진단 거부	서비스 승인, 범위·CIDR·호스트·경로·만료, 정책
작업이 멈춤	워커 생존, 임대 상태, 긴급 중지, 대기 승인
AI가 한 번에 표시됨	프록시·gateway 버퍼링과 SSE 전달
AI 토큰 오류	모델 실제 컨텍스트·최대 출력, 입력 크기
DB 연동 실패	읽기 계정 권한, SQL, 연결 문자열, TLS, 제한
새로고침 경로 오류	Go SPA 경로 전달, 프록시 rewrite 설정

장애 재현 시각, 버전, 대상 작업 ID와 마스킹한 오류를 남깁니다. 서비스 로그와 DB 오류의 원문에는 내부 주소가 포함될 수 있으므로 필요한 사람에게만 공유합니다.

19.1 관리자 운영 점검 화면

관리자 → 운영 점검(`/admin/operations`)을 열어 현재 점검 시각과 버전을 확인합니다. 이 화면은 관리자 권한이 필요하며 외부 서비스에 접속하거나 진단을 시작하지 않습니다.



점검 항목	의미와 후속 조치
데이터베이스	PostgreSQL 응답 확인. 실패 시 DSN·사내 경로·DB 가용성 확인
진단 대기열	대기·실행·승인 대기·임대 만료 건수. 임대 만료는 워커 프로세스와 로그 확인
워커 응답	활성 워커의 2분 이상 응답 지연 확인. 워커 활성화·망 이름·프로세스 확인
긴급 중지	현재 활성 상태. 장애가 해소됐는지 확인 후 기존 관리 기능으로 조정
SSO·AI·에이전트·승인	사용 설정 여부만 확인. 연결 시험·모델 응답·OIDC 로그인 성공 보장이 아님
KEV·EPSS	미반입과 오래된 기준일 확인. 승인된 새 원본을 반입
소프트웨어 명세	서비스별 명세 보유 여부와 마지막 반입 갱신 기준 초과 확인

운영 점검이 정상이라고 백업 복구, TLS 인증서 만료, 외부 서비스 상태와 모든 진단의 성공이 보장되는 것은 아닙니다. 이 버전의 화면은 저장된 설정·DB·큐·워커·자료 갱신 상태를 확인합니다. 외부 연동 발송 실패·불확실 상태는 기존 개선 요청 화면에서 확인하고, 불확실한 발송을 자동 재시도하지 않습니다.

19.2 새 운영 기능 오류 복구

- KEV·EPSS 반입 오류: 오류가 난 행·중복 CVE·기준일을 원본과 대조합니다. 실패한 반입은 이전 자료를 보존합니다. 오래된 날짜의 409를 피하려고 날짜만 바꾸지 않습니다.
- SBOM 반입 오류: 지원 JSON 버전·파일 크기·구성요소 수·참조를 확인하고 생성 도구에서 다시 내보냅니다. 이미 반입한 동일 바이트는 중복 저장되지 않습니다.
- 캠페인 시작 응답 유실: 같은 캠페인을 다시 조회·시작합니다. 서버는 기존 진단을 반환합니다. 새 캠페인부터 만들면 실제로 새 진단이 생성됩니다.
- 캠페인 초안 유지: 한 대상의 준비 또는 저장 실패로 전체 시작이 취소된 상태입니다. 접근·승인·범위·정책을 확인한 뒤 다시 시작합니다.
- 결과 비교 불가: 양쪽 완료·대상·정책·버전·스냅샷을 확인합니다. 외부 반입과 이전 버전 실행은 현재 비교 범위에 없습니다.
- 조치함·캠페인이 보이지 않음: 현재 역할·키 범위·부모 서비스 소유권을 확인합니다. 캠페인은 모든 대상 서비스에 접근할 수 있어야 합니다.
- 댓글 작성 실패: 내용과 권한을 확인하고 현재 활동 목록을 다시 읽습니다. 재시도 전 동일 의견의 저장 여부를 확인합니다.

20. 개발·문서 재생성·릴리즈

20.1 로컬 빌드

빌드 구간에는 Go 1.26.5 이상, Node.js 26과 npm 패키지·Go 모듈 접근이 필요합니다. **빌드 시 인터넷 요구와 배포 후 오프라인 운영은 별개입니다.**

```
npm --prefix web ci

npm --prefix web run build

mkdir -p internal/webassets/dist

cp -a web/dist/. internal/webassets/dist/

go test ./...

go build ./cmd/hunter
```

20.2 가이드 재생성

문서 원본은 `docs/guides/*.md`이고 HTML·PDF에는 같은 본문과 이미지가 들어갑니다.

```
npm --prefix docs ci

npm --prefix docs exec -- playwright install chromium

node scripts/render-guides.mjs

node scripts/check-docs.mjs
```

실제 화면 캡처는 `docs/images`에 저장합니다. 운영 데이터·비밀값이 담긴 화면은 공개 문서로 사용하지 않습니다. 가이드의 이미지가 모두 존재해야 PDF를 정상 생성할 수 있습니다.

20.3 릴리즈 규칙

```
bash scripts/release.sh 1.25.0
```

스크립트는 `VERSION` 일치 여부를 확인하고 Docker 이미지를 만든 뒤 `docker image save | gzip`으로 `dist/hunter-v1.25.0.tar.gz`를 생성합니다. 파일에는 `hunter:v1.25.0` 서비스 이미지 하나만 들어갑니다.

GitHub Actions는 main에서 빌드·테스트를 수행하고 버전 태그에서 서비스 이미지 릴리즈를 생성합니다. 문서는 별도 GitHub Pages workflow에서 `docs` 를 배포합니다. GitHub 저장소의 Pages 배포 소스는 **GitHub Actions**로 설정합니다.

21. 참고 문서

- Docker 이미지 저장
- GitHub Pages 사용자 지정 workflow
- Keycloak OIDC 엔드포인트
- PostgreSQL 백업과 복원
- Playwright PDF 생성

사용자 일상 업무 가이드로 이동
